Module : Sécurité des réseaux

Rapport de projet

Sécurisation de l'infrastructure réseau

d'une plateforme de prise de rendez-vous médicaux

MediConnect

Architecture, segmentation, VPN, pare-feux, identité, contrôle applicatif et journalisation

Réalisé par : Zakari BOUDACHE

Groupe : Cybersécurité et Cloud

Enseignant : Dr Salim Benayoune

Efrei Paris — Paris Panthéon-Assas Université

Maquette : Stormshield SNS 4.8.14 sous VirtualBox 7.2

Octobre 2026

Sommaire

Synthèse **4**
Correspondance avec les attendus du sujet 4
1. Introduction **6**
1.1 Contexte 6
1.2 Enjeux de sécurité 6
1.3 Menaces prises en compte 6
1.4 Périmètre et hypothèses 6
1.5 Démarche 7
2. Environnement et outils **8**
2.1 Poste et logiciels 8
2.2 Machines virtuelles 8
3. Architecture retenue **10**
3.1 Vue d'ensemble 10
3.2 Choix structurants 10
3.3 Application des principes du cours 11
3.4 Correspondance avec la passerelle recommandée par l'ANSSI 11
4. Plan d'adressage **13**
4.1 Principes 13
4.2 Tableau d'adressage 13
4.3 Objets et traduction d'adresses (NAT) 13
5. Zones de sécurité et niveaux de confiance **15**
5.1 Justification de l'ordre 15
6. VPN utilisés **16**
6.1 VPN IPsec site à site 16
6.2 VPN SSL pour les utilisateurs nomades 18
6.3 Comparaison des technologies (cours 3) 21
7. Mécanismes d'authentification **22**
7.1 Annuaire et comptes 22
7.2 Politique d'authentification 23
7.3 Portail captif 25
7.4 Authentification forte des médecins (TOTP) 25
7.5 Distinction entre patients et médecins 28
8. Politique de filtrage **29**
8.1 Méthode d'organisation (cours 2) 29
8.2 Politique complète du siège 29
8.3 Matrice des flux entre zones 31
8.4 Règles implicites 32
8.5 Politique du site 2 32
9. Règles basées sur l'identité **34**
9.1 Démonstration : deux profils, deux périmètres 34
9.2 Validation des six groupes de télétravail 36
10. Contrôle applicatif **40**
10.1 Prévention d'intrusion (IPS) 40
10.2 Filtrage d'URL pour la navigation des employés 40
10.3 Trafic HTTPS : contrôle sans déchiffrement 42
10.4 Protection contre le déni de service 43
11. Protection de la DMZ **46**
11.1 Exposition minimale, en HTTPS uniquement 46
11.2 Un seul flux de la DMZ vers l'intérieur 46
11.3 Aucune initiative depuis les zones internes 47
11.4 Séparation stricte entre production et démonstration 47

12. Sécurisation de l'administration **49**
12.1 Pourquoi un bastion plutôt que l'accès direct depuis le VPN 49
12.2 Validation 49
13. Stratégie de journalisation **55**
13.1 Ce qui est journalisé 55
13.2 Protection des données personnelles des journaux 55
13.3 Alarmes 57
13.4 Stockage, horodatage, supervision et sauvegardes 57
14. Tests réalisés **60**
14.1 Méthode 60
14.2 Tableau des tests 60
14.3 Bilan des tests 61
15. Difficultés rencontrées **65**
16. Limites de la solution et pistes d'amélioration **68**
16.1 Limites de la maquette 68
16.2 Feuille de route proposée 68
17. Conclusion **69**
Annexe A — Objets et comptes **70**
Annexe B — Sauvegardes et instantanés **71**
Annexe C — Captures complémentaires **72**

Synthèse

MediConnect lance une plateforme de prise de rendez-vous médicaux concurrente de Doctolib. Le projet consistait à **concevoir, mettre en œuvre et tester** l'infrastructure réseau qui protège cette plateforme et le système d'information de l'entreprise, réparti sur deux sites disposant chacun de son propre accès Internet. Le développement web était hors sujet : le portail est simulé par des serveurs nginx en HTTPS.

La solution a été réalisée sur une maquette fonctionnelle VirtualBox avec **deux pare-feux Stormshield SNS 4.8.14** (un par site). Elle a été vérifiée par **une quarantaine de tests positifs et négatifs**, tous prouvés par des captures (99 captures numérotées) et par les journaux du pare-feu.

Indicateur	Valeur
Pare-feux	2 (FW-SIEGE : 6 interfaces physiques ; FW-SITE2 : 2 interfaces)
Zones de sécurité au siège	6 : OUT, LAN, SRV, ADMIN, DMZ-PROD, DMZ-DEMO
Politique de filtrage du siège	30 règles en 7 blocs, interdiction par défaut journalisée
VPN	IPsec IKEv2 site à site (AES-256) et VPN SSL OpenVPN pour les utilisateurs nomades
Identités	Annuaire LDAP interne, 7 groupes (un par profil du sujet), MFA TOTP pour les médecins
Contrôle applicatif	IPS sur toutes les règles, filtrage d'URL, blocage par service web, anti-DoS (proxy SYN)
Administration	Zone ADMIN dédiée, bastion SSH, comptes nominatifs à droits différenciés
Traçabilité	Journaux locaux nominatifs, alarmes, accès aux données privées lui-même tracé

Résultat principal : chaque population n'accède qu'à ce dont elle a besoin. Le patient n'atteint que le portail en HTTPS ; le médecin n'atteint l'espace professionnel qu'après une authentification à deux facteurs, sans jamais toucher les serveurs internes ; chaque télétravailleur n'atteint que la ressource de son groupe ; le commercial travaille sur le CRM et sur une plateforme de démonstration isolée de la production ; l'administration n'est possible que depuis la zone ADMIN ; tout ce qui n'est pas explicitement autorisé est bloqué et journalisé.

Correspondance avec les attendus du sujet

Le tableau suivant indique où chacun des 14 points demandés par le sujet est expliqué et justifié, et quelles captures en apportent la preuve.

Point demandé	Section	Preuves principales
1. Architecture retenue	3	Figure 1, captures 1, 2, 11, 15
2. Plan d'adressage	4	Captures 11, 12, 15, 17
3. Zones de sécurité	5	Figure 1, captures 11, 89a-b
4. Niveau de confiance par zone	5	Tableau des zones, ordre des blocs (89a-b)
5. VPN utilisés	6	Captures 41 à 47 (IPsec), 48 à 60 (VPN SSL)
6. Mécanismes d'authentification	7	Captures 28 à 38, 50, 69
7. Politique de filtrage	8	Captures 89a-b, 39a-b, 22, 27
8. Règles basées sur l'identité	9	Captures 33, 51a, 55, 56, 58, 72, 93 à 99
9. Contrôle applicatif	10	Captures 74 à 83b
10. Protection de la DMZ	11	Captures 6a, 6b, 7, 20, 21, 24 à 26
11. Sécurisation de l'administration	12	Captures 61 à 73
12. Stratégie de journalisation	13	Captures 10, 27, 84 à 88
13. Tests réalisés	14	Tableau de 44 tests, captures associées
14. Limites de la solution	16	Tableau des limites et feuille de route

Les onze objectifs du sujet sont tous couverts : interconnexion des sites (6.2), accès distant des employés et des commerciaux (6.3, 9), accès Internet des patients et exposition sécurisée de la plateforme (11), accès authentifié

des médecins (7.4, 7.5), séparation production / démonstration (5, 11.4), contrôle applicatif (10), politiques par identité (9), administration sécurisée (12) et journalisation (13).

1. Introduction

1.1 Contexte

MediConnect est une entreprise française en forte croissance qui exploite une plateforme de prise de rendez-vous médicaux : recherche d'un praticien, consultation de ses disponibilités, réservation en ligne, espace personnel du patient et espace réservé aux professionnels de santé. L'entreprise est implantée sur **deux sites** :

- **le siège**, qui héberge la direction, les équipes administratives, commerciales, support et informatique, les principaux serveurs, les équipements de sécurité et la plateforme exposée sur Internet ;
- **un site secondaire**, qui accueille des employés, une partie du support et des commerciaux, et qui doit accéder à certaines ressources du siège.

Cinq populations utilisent le système : les **patients** (Internet), les **médecins** (cabinet, domicile, déplacement), les **employés en télétravail** (cinq profils métier), les **commerciaux itinérants** et les **administrateurs**.

1.2 Enjeux de sécurité

La plateforme traite des **données de santé** : identité des patients, praticiens consultés, motifs et historique des rendez-vous. Au sens du RGPD (article 9), ce sont des données d'une catégorie particulière, dont le traitement exige des mesures de sécurité renforcées. La CNIL et, à titre de référence internationale, la réglementation américaine HIPAA vue en cours, imposent notamment la confidentialité, le contrôle des accès et la traçabilité. Les quatre critères DICP du cours s'appliquent ainsi :

Critère	Enjeu pour MediConnect	Réponse réseau apportée
Disponibilité	Le portail doit rester joignable 24 h/24 pour la prise de rendez-vous.	Exposition limitée au seul HTTPS, IPS, limites de connexions par source, proxy SYN.
Intégrité	Les agendas et rendez-vous ne doivent pas être modifiés par un tiers.	Seul le serveur web parle à la base, sur un port précis ; VPN chiffrés et authentifiés (ESP, TLS).
Confidentialité	Les données de santé ne doivent pas fuiter.	Segmentation en zones, moindre privilège, accès par identité, aucun déchiffrement du trafic des employés.
Preuve	Savoir qui a accédé à quoi et quand.	Comptes nominatifs, journaux attribués à chaque utilisateur, accès aux données privées lui-même tracé.

1.3 Menaces prises en compte

L'architecture répond aux menaces vues dans le cours sur les attaques réseau :

- **attaque du portail exposé** (injection, exploitation d'une vulnérabilité web) puis **mouvement latéral** vers le SI : la DMZ est isolée et ne peut joindre que la base, sur un seul port ;
- **vol d'identifiants d'un médecin** (hameçonnage) : le mot de passe seul ne suffit pas, un code TOTP est exigé ;
- **poste du LAN compromis** qui tenterait d'administrer les équipements : l'administration est réservée à une zone dédiée ;
- **écoute du trafic** entre les sites ou depuis un télétravailleur : tunnels IPsec (ESP) et TLS ;
- **usurpation et prédiction de numéros de séquence TCP** (attaque de type Mitnick) : réécriture aléatoire des séquences ;
- **déni de service** et inondation SYN : proxy SYN et limites par adresse source ;
- **balayage et reconnaissance** (première étape de la kill chain) : tout flux non autorisé est bloqué et journalisé, les tentatives vers la zone d'administration sont signalées.

1.4 Périmètre et hypothèses

- **Outil :** Stormshield SNS, utilisé dans l'ensemble des travaux pratiques du module (hypothèse de travail retenue en l'absence d'outil imposé).

- **Mise en œuvre réelle :** le sujet demande de « mettre en œuvre » et de présenter les « tests réalisés » ; une maquette fonctionnelle a donc été construite et chaque exigence a été démontrée.
- **Plateforme simulée :** le portail patients, l'espace médecins, la plateforme de démonstration et les applications internes sont simulés par des pages HTTPS servies par nginx.
- **Authentification applicative des patients :** la connexion à l'espace personnel du patient relève de l'application ; elle est hors du périmètre réseau. Le réseau garantit seulement que le patient n'atteint que le portail, en HTTPS.
- **Application mobile des patients :** elle utilise le même flux HTTPS vers le portail que le navigateur ; côté réseau, rien ne la distingue d'un patient sur navigateur (même adresse publique, même port 443, mêmes protections). Aucune règle supplémentaire n'est nécessaire.
- **Routeurs :** dans la maquette, les pare-feux SNS assurent seuls le routage entre les zones et entre les sites, il n'y a donc pas de routeur distinct. Si des routeurs existaient en production, ils seraient administrés comme les pare-feux : SSH uniquement depuis le poste d'administration de la zone ADMIN, comptes nominatifs, journalisation et aucune administration depuis le LAN ou le VPN (section 12).
- **Internet simulé :** un réseau NAT VirtualBox (192.36.253.0/24) joue le rôle d'Internet ; il donne aussi un accès réel à Internet pour les tests de navigation.

1.5 Démarche

Le travail a été mené en seize étapes successives (installation, socle des pare-feux, serveurs, NAT, filtrage par zone, authentification, IPsec, VPN SSL, administration, contrôle applicatif, journalisation, tests finaux, rapport et vidéo). À la fin de chaque étape, la configuration a été sauvegardée et un instantané VirtualBox a été pris. Chaque fonction a été validée par un **test positif** (ce qui doit passer passe) et par un **test négatif** (ce qui doit être bloqué l'est), puis confirmée dans les **journaux** du pare-feu.

2. Environnement et outils

2.1 Poste et logiciels

Élément	Caractéristiques
Poste hôte	Asus Zenbook UX3402ZA, Intel i7-1260P, 16 Go de RAM (facteur limitant), Windows 11
Hyperviseur	Oracle VirtualBox 7.2
Pare-feux	Stormshield SNS 4.8.14, machine virtuelle EVA1 issue du lab CSNx v4.8 fourni
Serveurs	Alpine Linux minimal + nginx (HTTPS, TLS 1.2/1.3, HSTS, redirection HTTP 301)
Clients	Alpine Linux (Firefox, curl, ssh, OpenVPN)
Outils de test	curl, ssh, ping, openvpn, journaux et supervision SNS, VBoxManage

2.2 Machines virtuelles

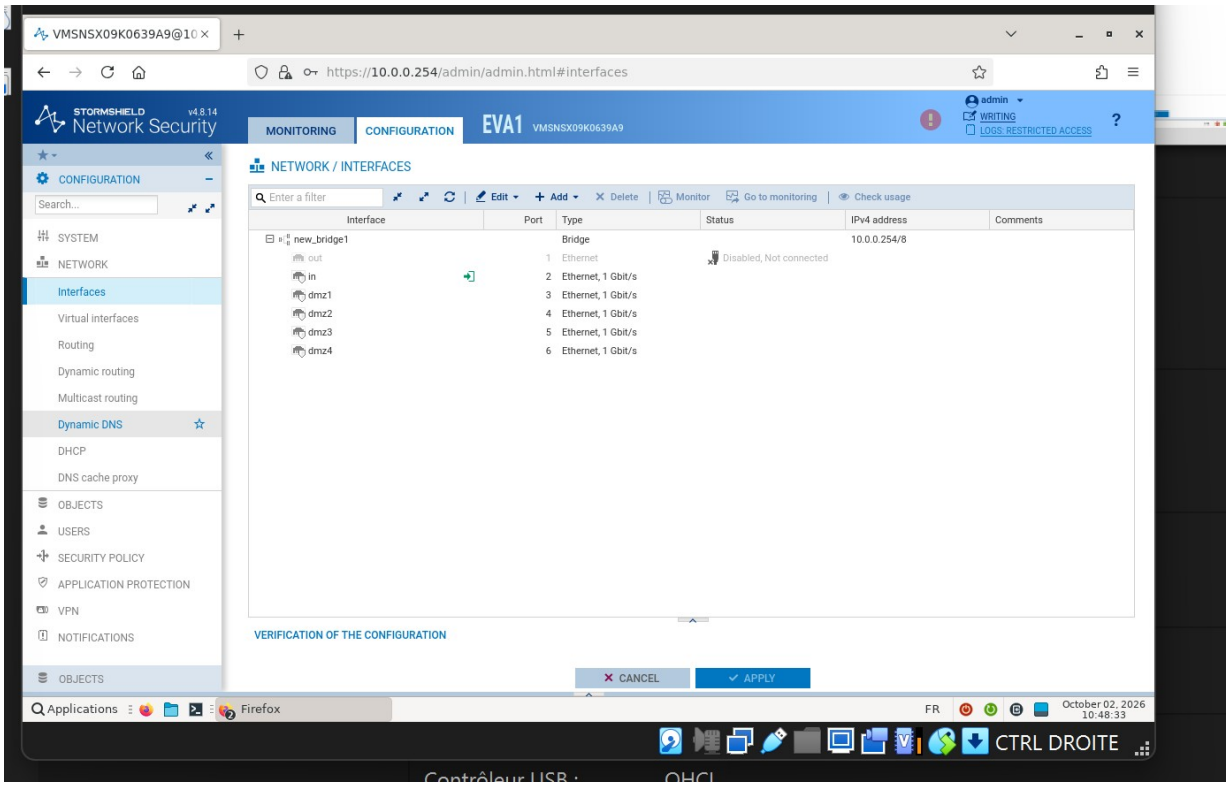
La RAM disponible (16 Go) a guidé le dimensionnement : serveurs Alpine très légers, un seul serveur interne qui porte toutes les ressources (une adresse IP par application), et un seul client « Internet » qui joue successivement le patient, le médecin, les télétravailleurs, le commercial et l'administrateur distant.

Machine	Rôle	Réseau VirtualBox	Adresse(s)
FW-SIEGE (CSNx-SNS-Firewall)	Pare-feu du siège, 1 Go	6 cartes : NatNetwork, net_a_in, net_a_dmz, net_a_demo, net_a_srv, net_a_admin	.254 dans chaque zone ; 192.36.253.10
FW-SITE2	Pare-feu du site 2, 1 Go	NatNetwork, net_b_in	192.36.253.20 ; 192.168.2.254
web-prod	Portail patients et espace médecins	net_a_dmz	172.16.1.11 et 172.16.1.12
web-demo	Plateforme de démonstration (données fictives)	net_a_demo	172.17.1.11
srv-interne	CRM, comptabilité, support, bureautique, ressources techniques, base PROD simulée	net_a_srv	192.168.11.10 à .14 et .20 (TCP 5432)
CSNx-Client	Poste d'administration et bastion SSH (initialement poste du LAN)	net_a_admin	192.168.91.2
Client-Internet	Patient, médecin, télétravailleur, commercial, administrateur distant ; ponctuellement poste du LAN ou du site 2	NatNetwork	192.36.253.100

Les trois serveurs ont été produits à partir d'un modèle Alpine commun et d'un script de rôle (/usr/local/bin/mc-role) qui configure les adresses, le nom, le certificat et les pages HTTPS de chaque clone. Cette industrialisation garantit des serveurs identiques et reproductibles.

```
C:\Program Files\Oracle\VirtualBox>VBoxManage showvminfo "CSNx-SNS-Firew
all" | findstr /i "NIC"
NIC 1:                       MAC: 08002779B030, Attachment: NAT Network
'NatNetwork', Cable connected: on, Trace: off (file: none), Type: 82540E
M, Reported speed: 0 Mbps, Boot priority: 0, Promisc Policy: allow-all,
Bandwidth group: none
NIC 2:                       MAC: 0800273982EE, Attachment: Internal Net
work 'net_a_in', Cable connected: on, Trace: off (file: none), Type: 825
40EM, Reported speed: 0 Mbps, Boot priority: 0, Promisc Policy: allow-al
l, Bandwidth group: none
NIC 3:                       MAC: 08002736205D, Attachment: Internal Net
work 'net_a_dmz', Cable connected: on, Trace: off (file: none), Type: 82
540EM, Reported speed: 0 Mbps, Boot priority: 0, Promisc Policy: allow-a
ll, Bandwidth group: none
NIC 4:                       MAC: 0800279A70B4, Attachment: Internal Net
work 'net_a_demo', Cable connected: on, Trace: off (file: none), Type: 8
2540EM, Reported speed: 0 Mbps, Boot priority: 0, Promisc Policy: allow-
all, Bandwidth group: none
NIC 5:                       MAC: 080027F942C0, Attachment: Internal Net
work 'net_a_srv', Cable connected: on, Trace: off (file: none), Type: 82
540EM, Reported speed: 0 Mbps, Boot priority: 0, Promisc Policy: allow-a
ll, Bandwidth group: none
NIC 6:                       MAC: 080027BF860E, Attachment: Internal Net
work 'net_a_admin', Cable connected: on, Trace: off (file: none), Type:
82540EM, Reported speed: 0 Mbps, Boot priority: 0, Promisc Policy: allow
-all, Bandwidth group: none
NIC 7:                       disabled
NIC 8:                       disabled
```

Capture 1 — Ajout des cartes 4 à 6 au pare-feu du siège avec VBoxManage (une carte par zone)



Capture 2 — Les 6 interfaces détectées par SNS EVA1 : une interface physique par zone, sans VLAN

3. Architecture retenue

3.1 Vue d'ensemble

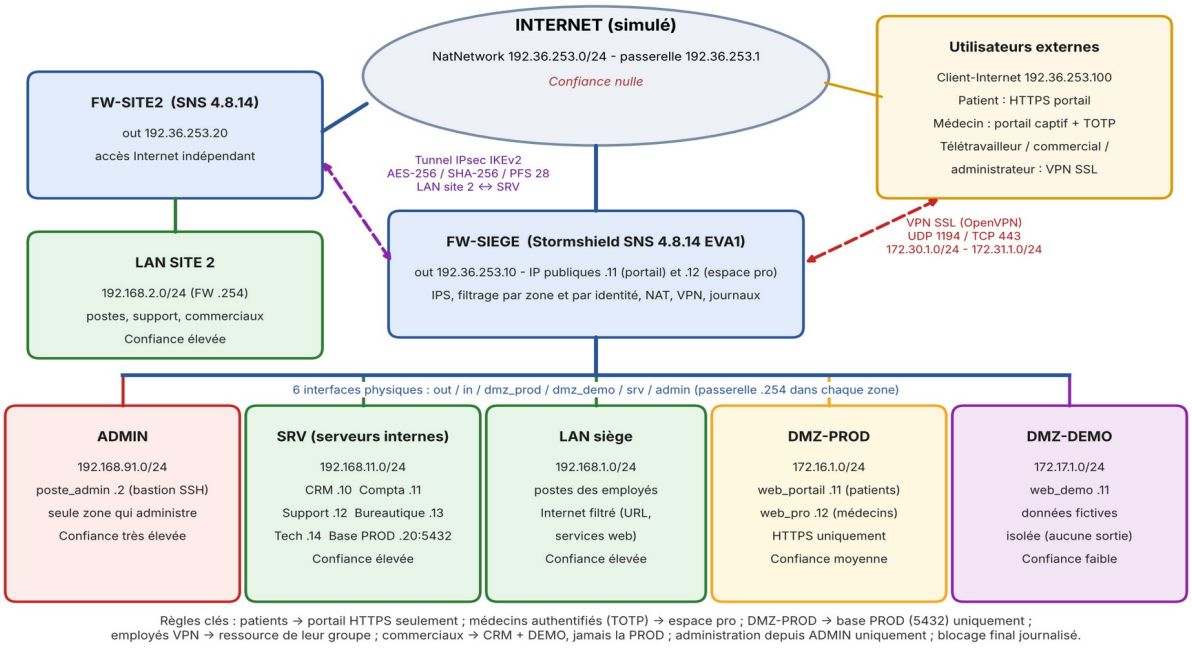


Figure 1 — Architecture réseau de MediConnect : deux sites, six zones au siège, VPN IPsec et VPN SSL

Chaque site dispose de son **propre pare-feu et de son propre accès Internet**, conformément au sujet. Au siège, **FW-SIEGE** est le point de passage obligé entre six zones séparées physiquement. Le site 2 est relié au siège par un **tunnel IPsec** établi à travers Internet. Les utilisateurs nomades (télétravailleurs, commerciaux, administrateurs) entrent par un **VPN SSL** terminé sur FW-SIEGE. Les patients et les médecins n'utilisent aucun VPN : ils atteignent uniquement deux services HTTPS publiés en DMZ.

3.2 Choix structurants

Choix	Alternative écartée	Justification
Une interface physique par zone (6 au siège)	VLAN sur une seule interface ; fusion de zones	Séparation la plus nette et la plus simple à vérifier ; pas de risque de VLAN hopping ou d'erreur de marquage 802.1Q (cours 1) ; la licence EVA1 accepte les 6 interfaces (capture 2).
Deux DMZ distinctes : PROD et DEMO	Une seule DMZ hébergeant aussi la démonstration	Le sujet interdit l'usage de la production pour les démonstrations : sous-réseaux, interfaces et règles séparés rendent tout flux DEMO → PROD impossible.
Zone SRV séparée du LAN	Serveurs internes dans le LAN	Les serveurs portent les données sensibles et ne naviguent pas sur Internet ; les isoler des postes réduit l'impact d'un poste compromis.
Zone ADMIN dédiée avec bastion	Administration depuis le LAN	Exigence du sujet : un utilisateur du LAN ne doit pas pouvoir administrer ; principe du « maillon le plus faible ».
IPsec site à site	VPN SSL entre sites, liaison louée	Standard pour l'interconnexion de réseaux, chiffrement ESP, IKEv2, géré nativement par les deux pare-feux.
VPN SSL pour les nomades	IPsec nomade, WireGuard	Authentification par l'annuaire et par groupe, traversée des réseaux restrictifs (TCP 443), client standard OpenVPN.
Médecins par HTTPS + portail captif + TOTP	VPN pour les médecins	Le sujet interdit tout accès réseau direct des médecins aux serveurs internes : ils n'atteignent qu'un service HTTPS en DMZ.

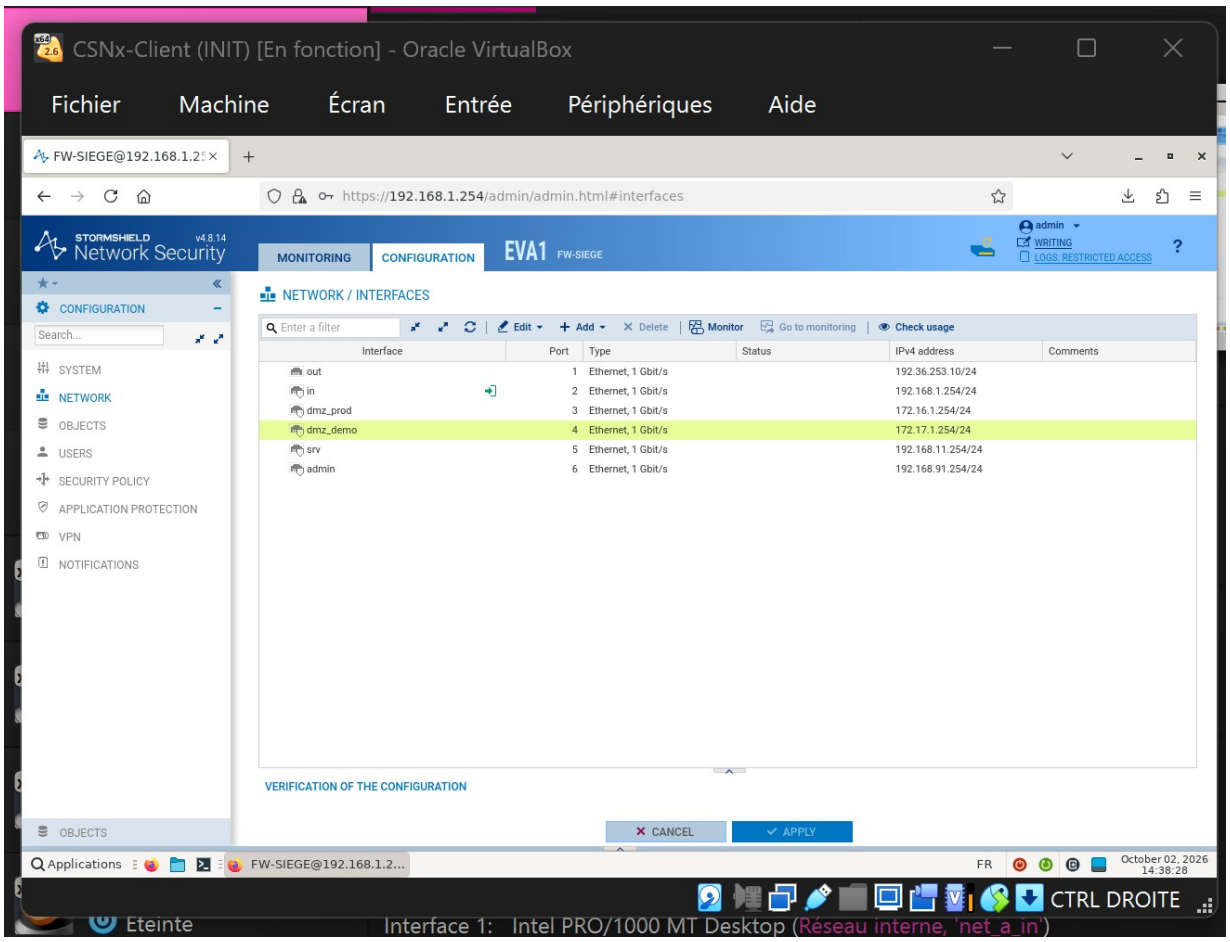
3.3 Application des principes du cours

Principe (cours 2)	Mise en œuvre dans MediConnect
Moindre privilège	Chaque groupe n'atteint qu'une ressource, sur un seul port ; le VPN n'annonce que les réseaux utiles ; le profil lecture seule pour les informaticiens.
Défense en profondeur	Routage limité + filtrage par zone + authentification + droits VPN + règles par identité + IPS + journaux : plusieurs barrières indépendantes.
Goulot d'étranglement	Tous les flux entre zones et vers Internet passent par FW-SIEGE (ou FW-SITE2) ; aucun contournement possible. Le pare-feu devient critique : la haute disponibilité est une amélioration prévue (section 16).
Maillon le plus faible	Le poste d'administration est isolé, sans accès Internet, et seul autorisé à administrer.
Interdiction par défaut	Blocs « block » à la fin de chaque zone, règle finale « block any » journalisée, authentification et droits VPN refusés par défaut, règle SSH implicite désactivée.
Participation des utilisateurs	Page de blocage explicite, seuils anti-DoS larges, VPN TCP 443 de secours, accès sans VPN pour les médecins.
Simplicité	Une zone = une interface = un /24 ; objets nommés ; règles commentées et regroupées par séparateurs.

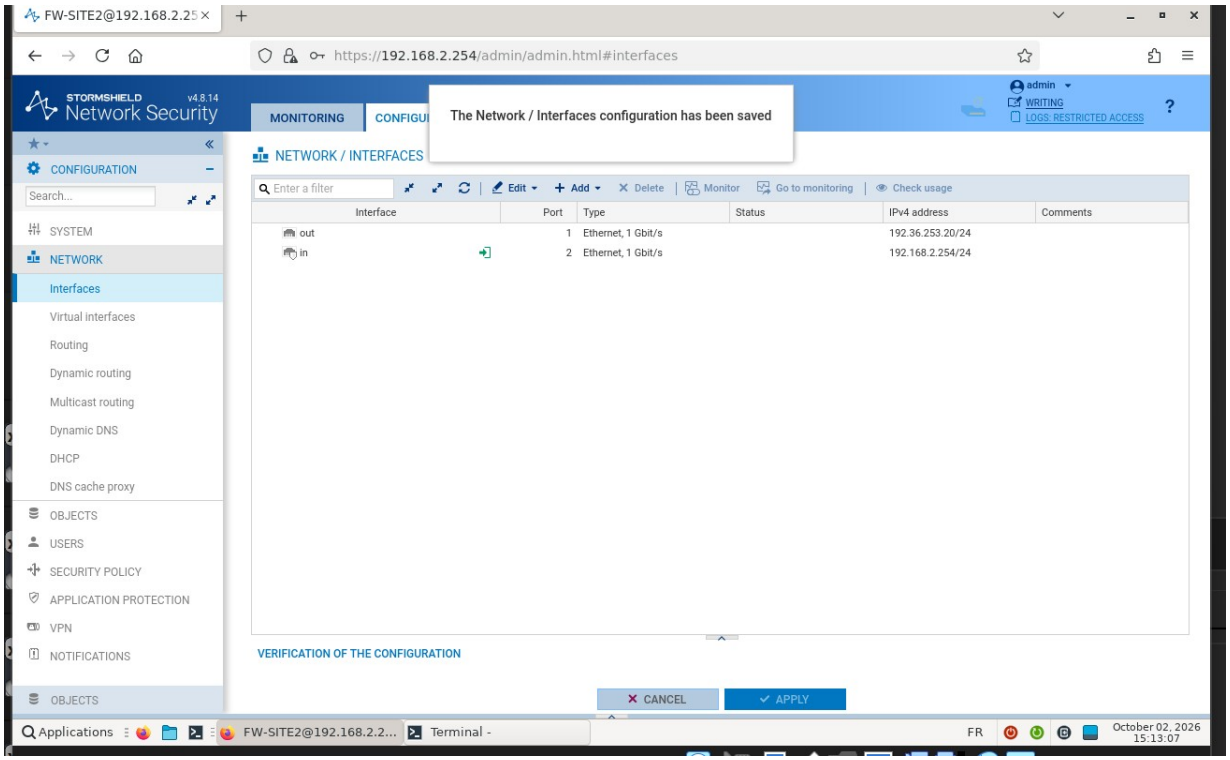
3.4 Correspondance avec la passerelle recommandée par l'ANSSI

Le cours présente l'architecture de passerelle sécurisée à base de DMZ recommandée par l'ANSSI. La maquette en reprend les zones principales :

Zone du modèle ANSSI	Zone MediConnect	Commentaire
Zone d'accès externe	OUT (Internet) et terminaison des VPN	Seuls le portail, l'espace pro, le portail captif et les ports VPN sont exposés.
Zone de services exposés	DMZ-PROD	Portail patients et espace médecins, publiés en HTTPS uniquement.
Zone de services exposés (isolée)	DMZ-DEMO	Plateforme de démonstration, sans aucun lien avec la production.
Zone de services internes	SRV	CRM, comptabilité, support, bureautique, ressources techniques, base PROD.
Zone d'accès interne	LAN (siège) et LAN du site 2	Postes des employés.
Zone d'administration	ADMIN	Poste d'administration et bastion.
Zone de services relais	Non réalisée	Un relais applicatif (reverse proxy / WAF) devant le portail est recommandé en production (section 16).



Capture 11 — Les 6 interfaces du siège renommées et adressées (une zone par interface)



Capture 15 — Interfaces de FW-SITE2 : out et LAN du site 2

4. Plan d'adressage

4.1 Principes

- **un /24 privé (RFC 1918) par zone**, ce qui laisse 253 adresses par zone et rend chaque adresse lisible ;
- **le pare-feu toujours en .254**, comme passerelle de chaque zone ;
- **une convention mnémotechnique** : 192.168.1.x = LAN du site 1, 192.168.2.x = LAN du site 2, 192.168.11.x = serveurs du site 1, 192.168.91.x = administration, 172.16.x = DMZ de production, 172.17.x = DMZ de démonstration ;
- **des réseaux VPN distincts de tous les autres** (172.30.1.0/24 et 172.31.1.0/24) : un chevauchement empêcherait le routage des clients VPN ;
- **des adresses publiques dédiées** à chaque service publié (192.36.253.11 pour le portail, .12 pour l'espace professionnel), ce qui permet de distinguer les deux populations dès l'entrée.

4.2 Tableau d'adressage

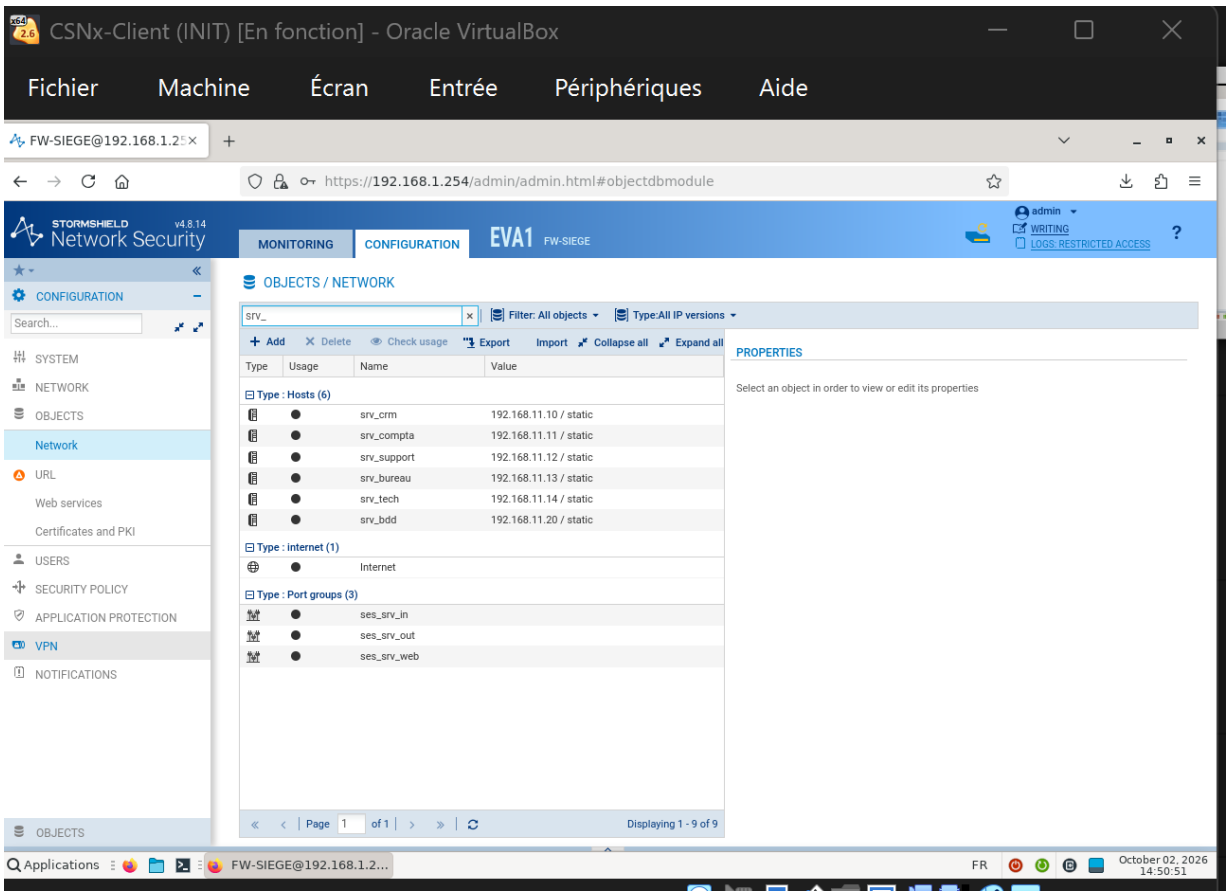
Site / zone	Réseau	Interface SNS	Équipements et adresses
Internet (simulé)	192.36.253.0/24	—	Passerelle 192.36.253.1 ; Client-Internet 192.36.253.100
Siège — OUT	192.36.253.0/24	out (port 1)	FW-SIEGE 192.36.253.10 ; pub_portail 192.36.253.11 ; pub_pro 192.36.253.12
Siège — LAN	192.168.1.0/24	in (port 2)	Passerelle .254 ; postes .2 et suivants
Siège — DMZ-PROD	172.16.1.0/24	dmz_prod (port 3)	Passerelle .254 ; web_portail .11 ; web_pro .12
Siège — DMZ-DEMO	172.17.1.0/24	dmz_demo (port 4)	Passerelle .254 ; web_demo .11
Siège — SRV	192.168.11.0/24	srv (port 5)	Passerelle .254 ; srv_crm .10 ; srv_compta .11 ; srv_support .12 ; srv_bureau .13 ; srv_tech .14 ; srv_bdd .20 (TCP 5432)
Siège — ADMIN	192.168.91.0/24	admin (port 6)	Passerelle .254 ; poste_admin .2
VPN SSL — UDP	172.30.1.0/24	sslvpn_udp	Adresses attribuées aux clients (ex. 172.30.1.6)
VPN SSL — TCP	172.31.1.0/24	sslvpn_tcp	Mode de secours sur TCP 443
Site 2 — OUT	192.36.253.0/24	out	FW-SITE2 192.36.253.20
Site 2 — LAN	192.168.2.0/24	in	Passerelle .254 ; poste .2

4.3 Objets et traduction d'adresses (NAT)

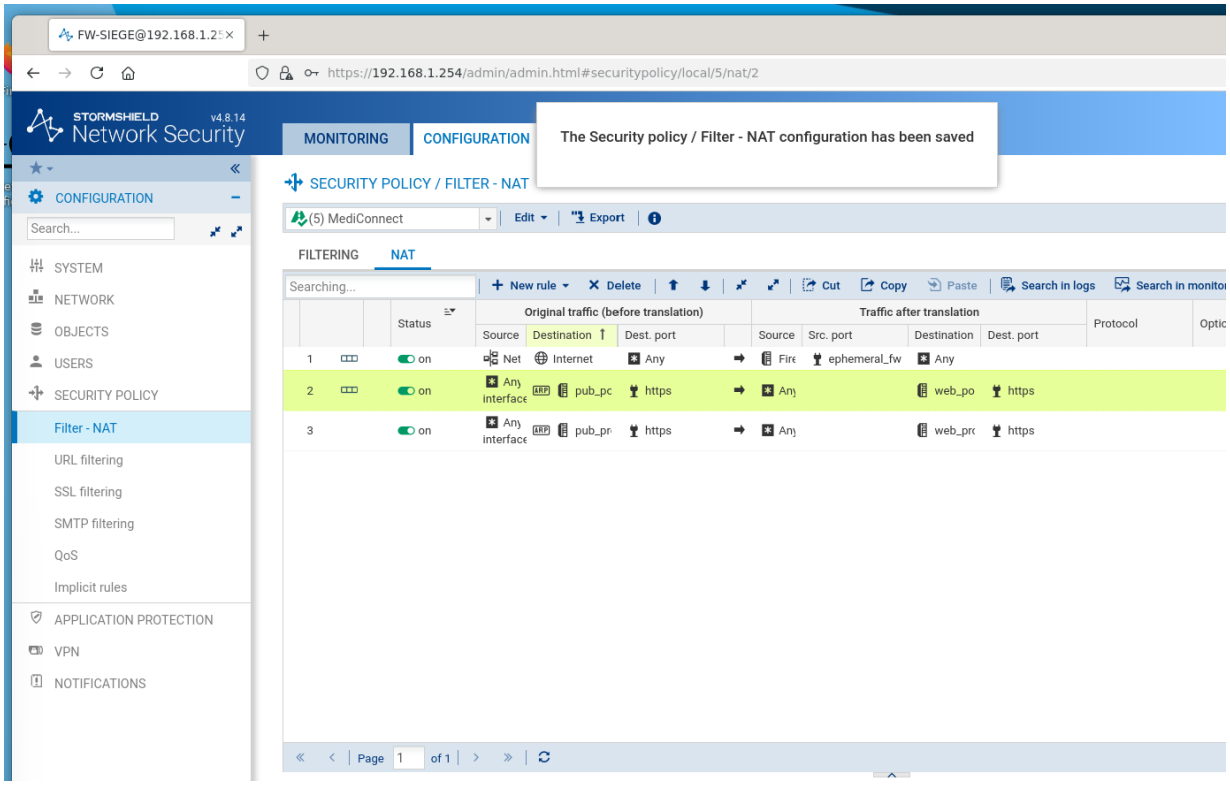
Toutes les règles utilisent des **objets nommés** (srv_compta, web_portail, pub_pro…) plutôt que des adresses : la politique se lit comme une description fonctionnelle et une adresse ne se modifie qu'à un seul endroit (la liste complète figure en annexe A).

N°	Type	Trafic d'origine	Après traduction	Justification
1	PAT dynamique	Network_in → Internet	Source = Firewall_out (ports éphémères)	Seul le LAN sort sur Internet ; les serveurs, la DMZ et la zone ADMIN n'ont pas de NAT sortant, donc aucun accès Internet.
2	NAT statique par port	Any → pub_portail : https	Destination web_portail : https (publication ARP)	Seul le port 443 du portail est publié.
3	NAT statique par port	Any → pub_pro : https	Destination web_pro : https (publication ARP)	Adresse publique distincte pour l'espace des médecins.

Au site 2, une règle de **non-traduction** (LAN du site 2 → serveurs du siège) est placée **avant** le PAT vers Internet ; sans elle, le trafic destiné au tunnel IPsec serait traduit et ne correspondrait plus aux sélecteurs de trafic (capture 39a).



Capture 12 — Objets nommés des serveurs internes



Capture 17 — Règles NAT du siège (inchangées depuis l'étape 6, valables pour la configuration finale)

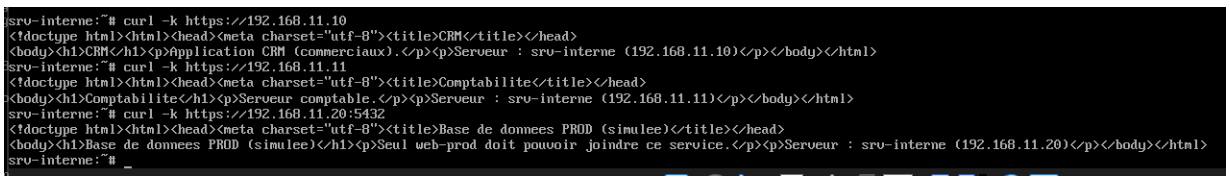
5. Zones de sécurité et niveaux de confiance

Chaque zone reçoit un **niveau de confiance** qui dépend de la sensibilité de ce qu'elle contient et de son exposition. Ce niveau détermine l'ordre des blocs de la politique de filtrage (méthode du cours 2 : blocs rangés par niveau de sécurité décroissant).

Zone	Contenu	Confiance	Ce qui peut y entrer	Ce qui peut en sortir
ADMIN 192.168.91.0/24	Poste d'administration, bastion SSH	Très élevée	Administrateurs en VPN, en SSH vers le bastion uniquement	SSH vers le pare-feu, la DMZ et les serveurs ; rien vers Internet
SRV 192.168.11.0/24	CRM, compta, support, bureautique, technique, base PROD	Élevée	Base : seulement depuis le serveur web ; chaque application : seulement le groupe concerné, en HTTPS	Rien (aucune initiative de connexion)
LAN siège 192.168.1.0/24	Postes des employés	Élevée	Rien depuis l'extérieur	Web filtré, DNS, portail, bureautique
LAN site 2 192.168.2.0/24	Postes du site secondaire	Élevée	Rien depuis l'extérieur	Bureautique du siège par IPsec, Internet par son propre accès
DMZ-PROD 172.16.1.0/24	Portail patients, espace médecins	Moyenne	HTTPS publié depuis Internet ; espace pro pour les médecins authentifiés	Base PROD sur le port 5432 uniquement
DMZ-DEMO 172.17.1.0/24	Démonstration, données fictives	Faible (isolée)	Commerciaux en VPN, en HTTPS	Rien
Clients VPN SSL 172.30-31.1.0/24	Télétravailleurs, commerciaux, administrateurs	Conditionnelle	—	Ressource de leur groupe uniquement
OUT 192.36.253.0/24	Internet	Nulle	—	Portail, espace pro (si authentifié), ports VPN

5.1 Justification de l'ordre

- **ADMIN est la zone la plus sûre** : qui la contrôle contrôle tous les équipements. Elle n'a aucun accès à Internet et n'accepte qu'un seul flux entrant (SSH des administrateurs vers le bastion).
- **SRV passe avant le LAN** : les deux zones sont de confiance élevée, mais les serveurs portent les données de santé et ne naviguent jamais, alors que les postes du LAN naviguent sur Internet et sont exposés à l'hameçonnage. Un poste compromis ne doit donc atteindre que la bureautique.
- **DMZ-PROD est de confiance moyenne** : elle est exposée à Internet par construction ; c'est la zone « perdable » du cours. Sa compromission ne doit ouvrir qu'un seul flux vers l'intérieur.
- **DMZ-DEMO est la moins sûre des zones internes** : elle est utilisée par des personnes en déplacement, devant des tiers, et n'a besoin de rien d'autre qu'elle-même.
- **Les clients VPN n'ont pas de niveau propre** : leur confiance dépend de leur **identité** (groupe LDAP), vérifiée à chaque connexion ; c'est ce qui permet de leur appliquer des règles différentes avec un seul réseau VPN.



Capture 8 — Zone SRV : une adresse par application interne (CRM, comptabilité, base PROD simulée)

6. VPN utilisés

Besoin	Solution	Raison du choix
Relier le site 2 au siège à travers Internet	IPsec IKEv2 en mode tunnel, site à site	Interconnexion de réseaux, chiffrement et intégrité ESP, anti-rejeu, standard interopérable.
Accès distant des télétravailleurs, des commerciaux et des administrateurs	VPN SSL (OpenVPN intégré à SNS)	Authentification par l'annuaire, droits par groupe, traversée des réseaux filtrés (TCP 443), client gratuit sur tous les systèmes.
Accès des médecins	Aucun VPN : HTTPS + portail captif + TOTP	Exigence : aucun accès réseau direct aux serveurs internes.
Accès des patients	Aucun VPN : HTTPS public	Service public, aucun accès au SI interne.

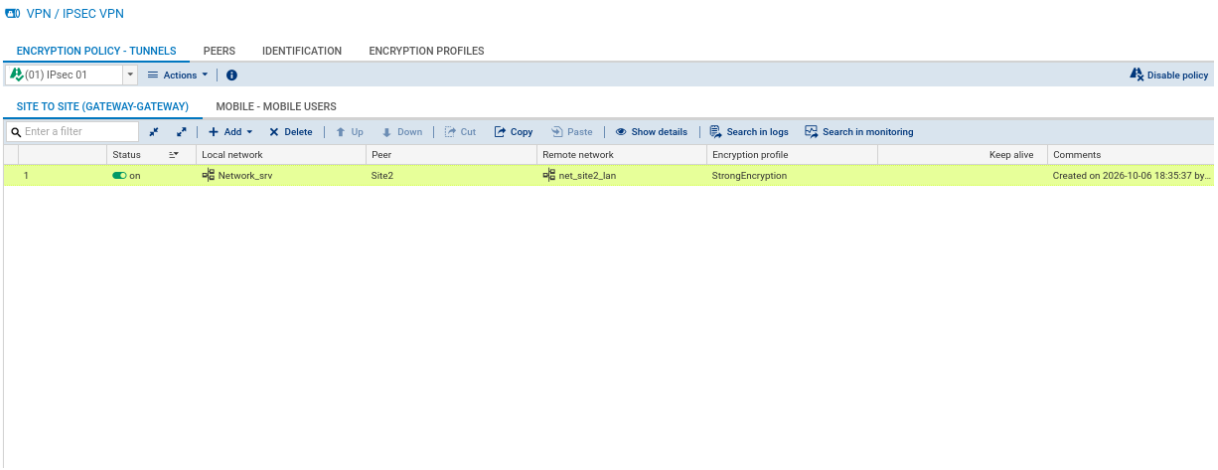
6.1 VPN IPsec site à site

Paramètre	Siège (FW-SIEGE)	Site 2 (FW-SITE2)
Correspondant (passerelle distante)	Site2 — fw_site2 (192.36.253.20)	Siege — fw_siege (192.36.253.10)
Réseau local / distant	Network_srv (192.168.11.0/24) / net_site2_lan (192.168.2.0/24)	Network_in (192.168.2.0/24) / net_siege_srv (192.168.11.0/24)
Version d'IKE	IKEv2	IKEv2
Authentification	Clé pré-partagée longue (non reproduite ici)	Identique
Profils de chiffrement	StrongEncryption (phase 1 et phase 2)	StrongEncryption
SA IKE observée	AES-256, SHA2-256, PRF SHA-256, groupe DH 28 (brainpoolP256r1)	Mêmes paramètres (négociés)
SA IPsec observée	ESP AES-256, HMAC-SHA256, PFS groupe 28, ESN	Miroir
Mode	Tunnel, politique (policy-based)	Tunnel

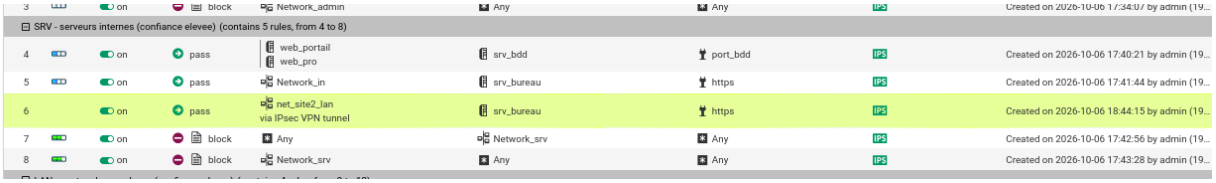
Fonctionnement (cours 3). IKEv2 négocie d'abord une SA IKE (UDP 500), qui protège ensuite la négociation des SA « CHILD » portant le trafic ESP. Les SA sont unidirectionnelles, conservées dans la SAD ; la SPD associe les sélecteurs de trafic (192.168.2.0/24 ↔ 192.168.11.0/24) au tunnel. ESP fournit confidentialité, intégrité, authentification de l'origine et protection contre le rejeu. Le **PFS** garantit que la compromission d'une clé ne permet pas de déchiffrer les sessions passées. Si un NAT se trouvait entre les deux sites, IKEv2 basculerait automatiquement en **NAT-T** (encapsulation UDP 4500) ; ce n'est pas nécessaire ici car les deux pare-feux sont sur le même segment simulé.

Moindre privilège dans le tunnel. Le tunnel ne relie que le LAN du site 2 et la zone SRV. Par-dessus, une règle de filtrage (règle 9) n'autorise que le **HTTPS vers la bureautique**, et seulement si le trafic arrive **par le tunnel IPsec**. La comptabilité et la base PROD restent bloquées depuis le site 2 (capture 46).

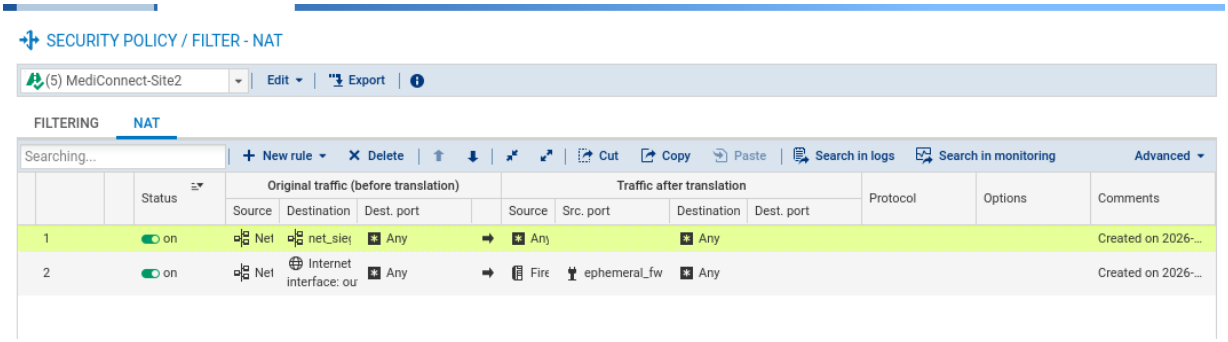
Choix de la clé pré-partagée. Elle est longue et unique pour ce tunnel. En production, des **certificats** issus d'une PKI seraient préférables (révocation, pas de secret partagé) : c'est indiqué dans les limites.



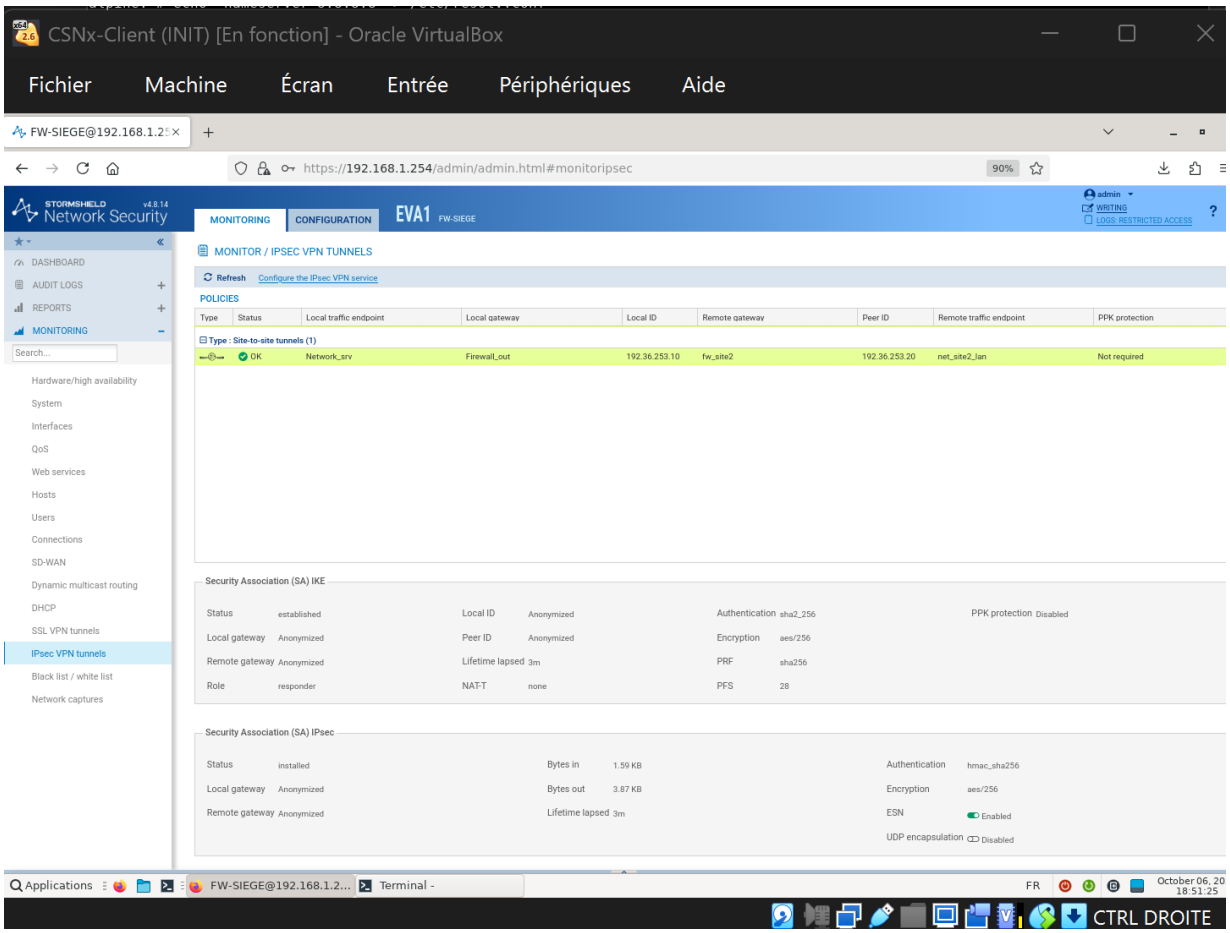
Capture 41 — Tunnel IPsec côté siège : Network_srv ↔ Site2 ↔ net_site2_lan



Capture 45 — Règle de filtrage : le LAN du site 2 n'atteint que la bureautique, en HTTPS, via le tunnel IPsec



Capture 39a — Site 2 : non-traduction vers le siège placée avant le masquerading

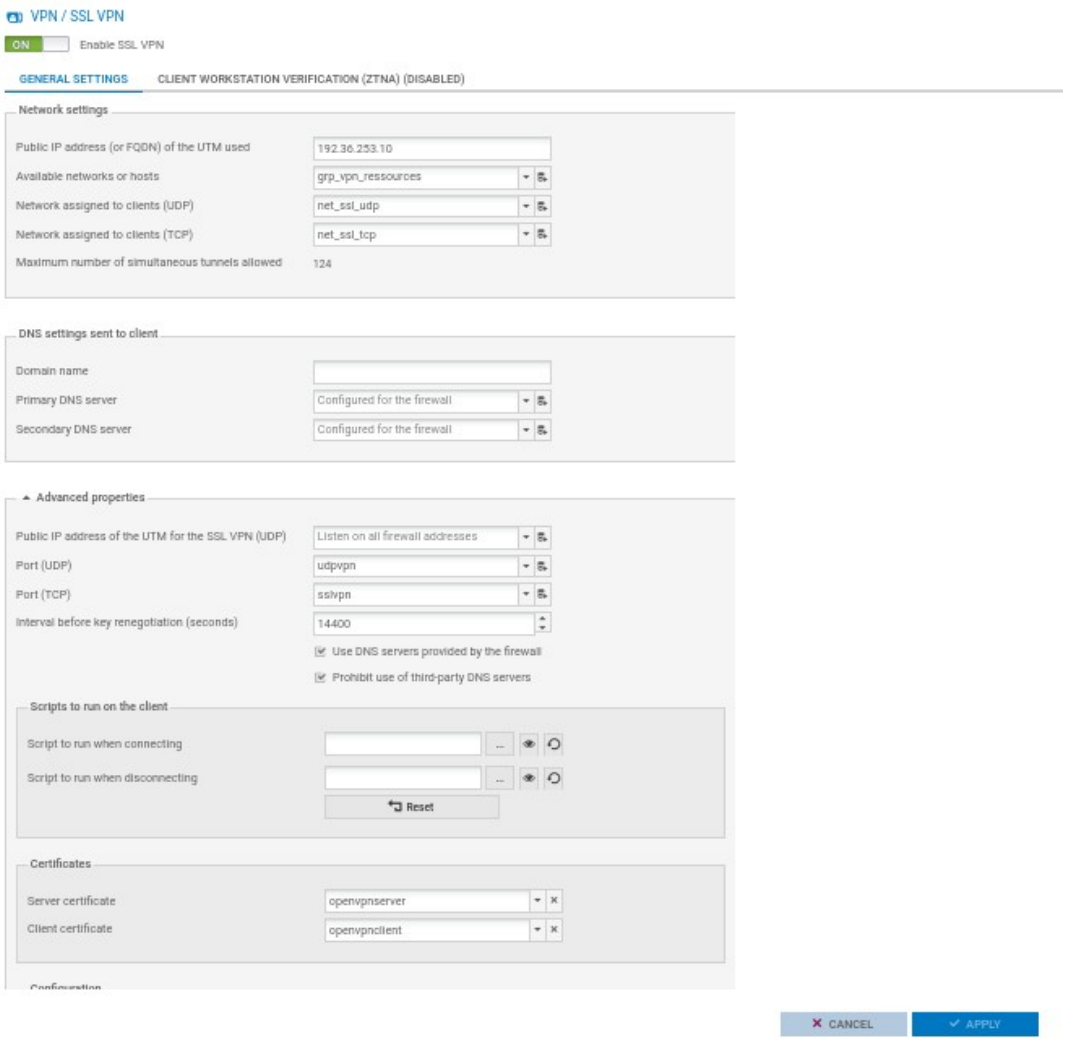


Capture 47 — Tunnel établi : SA IKE et IPsec en AES-256 / SHA-256, PFS groupe 28

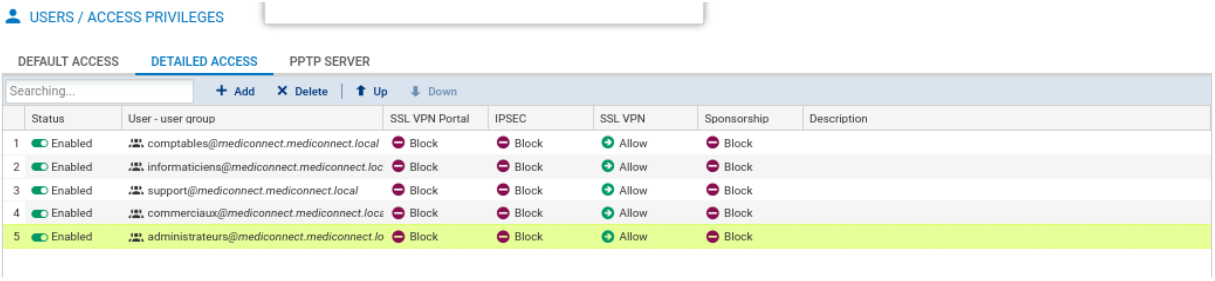
6.2 VPN SSL pour les utilisateurs nomades

Paramètre	Valeur	Justification
Adresse publique	192.36.253.10 (interface out)	Point d'entrée unique (goulot d'étranglement).
Ports	UDP 1194 (udpvpn) et TCP 443 (sslvpn)	UDP pour les performances ; TCP 443 en secours pour les réseaux qui ne laissent passer que le web (hôtels, cabinets).
Réseaux attribués	172.30.1.0/24 (UDP), 172.31.1.0/24 (TCP)	Plages dédiées, sans chevauchement.
Réseaux annoncés	grp_vpn_ressources = Network_srv + Network_dmz_demo + poste_admin	Seules les routes utiles sont poussées ; le LAN et la DMZ-PROD ne sont jamais routés par le VPN.
Certificats	openvpnserver / openvpnclient (PKI interne du pare-feu)	Authentification du serveur et chiffrement TLS.
Renégociation des clés	Toutes les 14 400 s (4 h)	Limite la durée d'exposition d'une clé.
Authentification	Annuaire LDAP, règle dédiée à l'interface SSL VPN	Identité nominative de chaque utilisateur.
Droits	VPN SSL autorisé pour 6 groupes ; refusé par défaut	Les médecins n'ont aucun droit VPN.
Distribution du profil	Téléchargé sur le portail captif interne (interface in)	L'employé récupère son profil au bureau, puis l'utilise à distance.

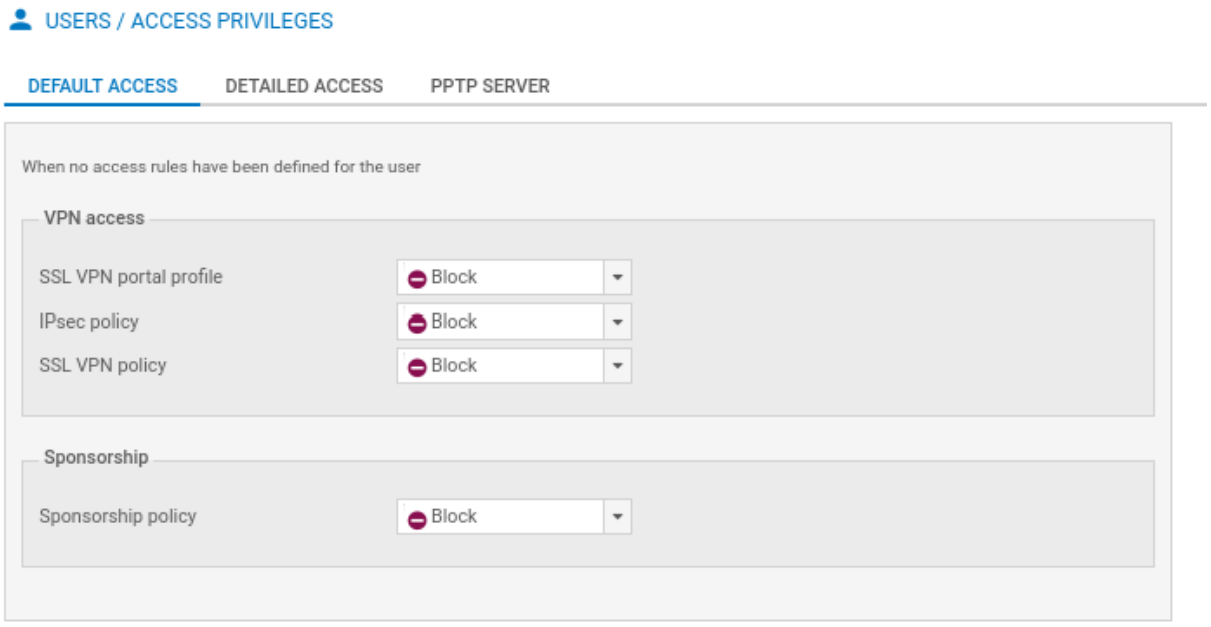
Trois contrôles successifs s'appliquent à chaque connexion : (1) la politique d'authentification vérifie l'identité sur l'interface SSL VPN ; (2) les droits d'accès vérifient que le groupe de l'utilisateur a le droit d'ouvrir un tunnel ; (3) la politique de filtrage décide, par groupe, quelles ressources sont joignables dans le tunnel (section 9).



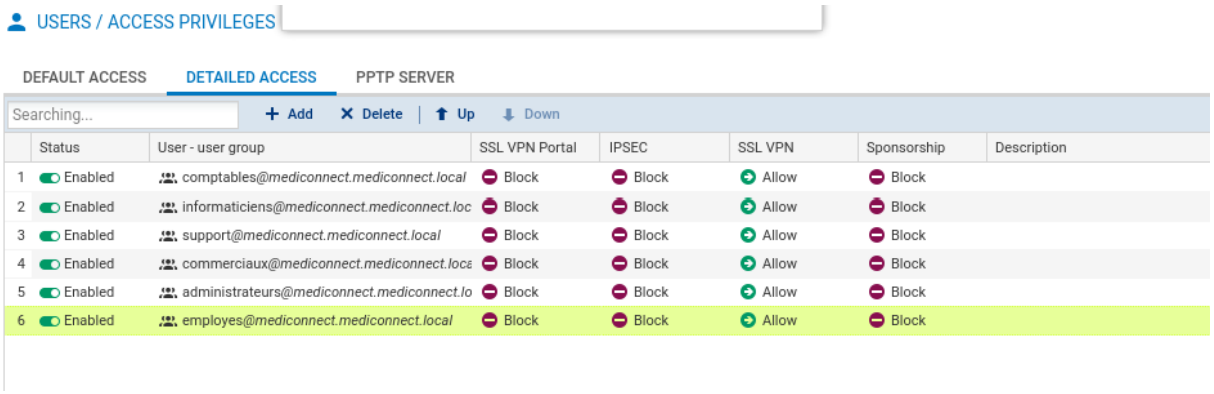
Capture 48 — Configuration du VPN SSL : réseaux annoncés limités, réseaux clients UDP/TCP, ports et certificats



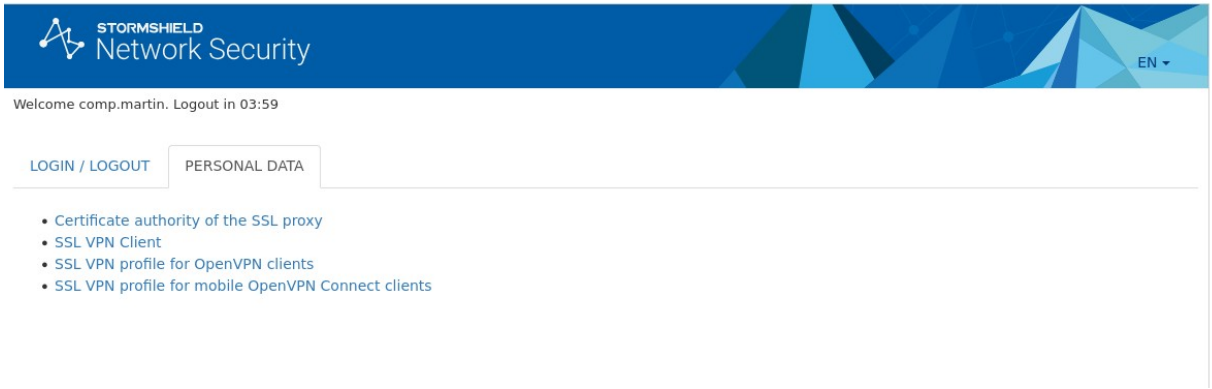
Capture 49 — Droits d'accès : état initial, VPN SSL autorisé pour cinq groupes (employes ajouté ensuite, capture 94)



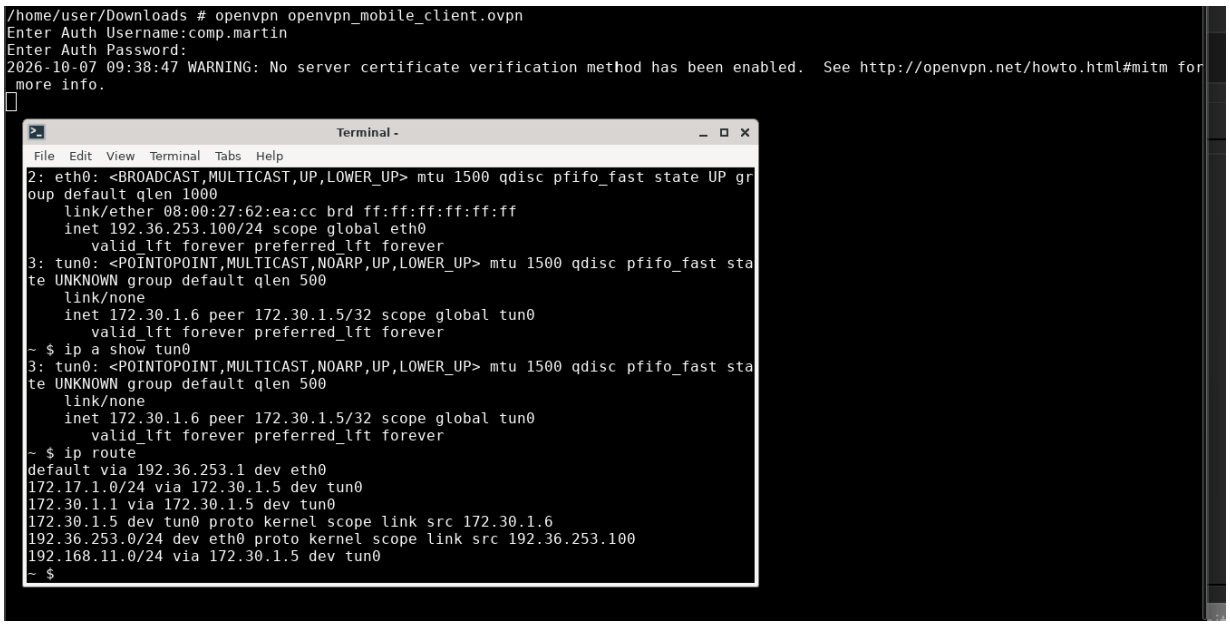
Capture 49b — Accès par défaut : tout est refusé (les médecins n'ont aucun accès VPN)



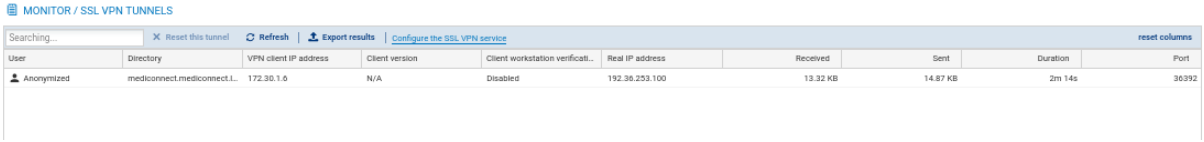
Capture 94 — Droits VPN SSL finaux : les six groupes de télétravail, dont employes



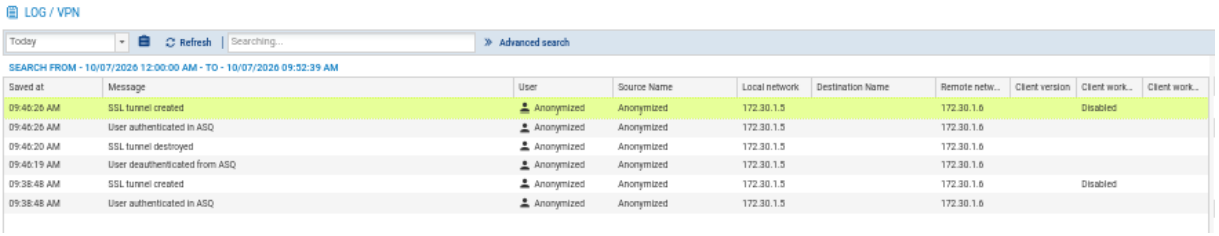
Capture 52 — Portail captif interne : le comptable peut télécharger son profil OpenVPN



Capture 54 — Tunnel établi : adresse 172.30.1.6, routes limitées à SRV et DEMO



Capture 57 — Supervision du tunnel VPN SSL actif



Capture 60 — Journal VPN : création et destruction des tunnels du comptable puis du commercial

6.3 Comparaison des technologies (cours 3)

Critère	IPsec (IKEv2)	VPN SSL / OpenVPN	WireGuard
Couche / transport	Couche 3, ESP + UDP 500/4500	TLS sur UDP ou TCP (1194, 443)	Couche 3, UDP 51820
Authentification	PSK ou certificats	Certificats + identifiant/mot de passe, MFA possible	Clés publiques uniquement
Authentification utilisateur	Possible (EAP), lourde	Native, liée à l'annuaire	Absente
Traversée des pare-feux	Moyenne (NAT-T)	Excellente (TCP 443)	Bonne
Sélection du trafic	Par politique (SPD)	Par routes poussées	Par routes
Usage retenu	Site à site	Utilisateurs nomades	Non retenu (pas d'identité utilisateur)

Tunnel partagé (split tunneling). Seuls les réseaux internes utiles passent dans le VPN SSL ; la navigation du télétravailleur reste sur sa connexion locale. Ce choix limite la charge du siège et le périmètre exposé, mais le poste reste joignable depuis Internet pendant la session : un tunnel complet est une option pour les profils les plus sensibles (section 16).

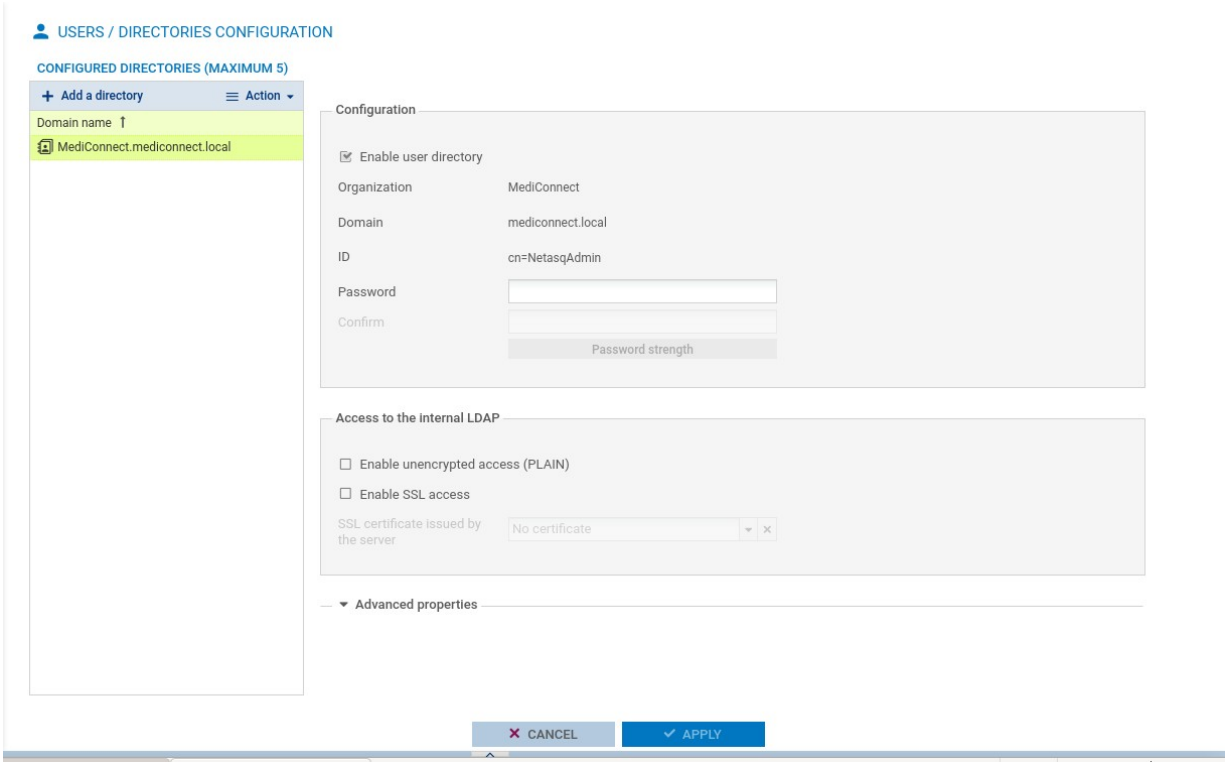
7. Mécanismes d'authentification

7.1 Annuaire et comptes

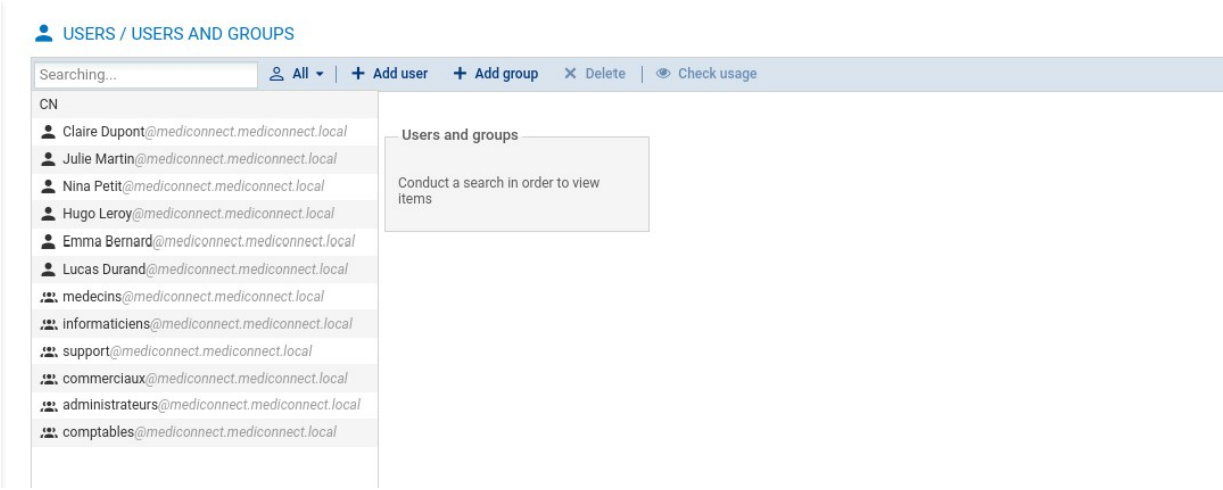
Un **annuaire LDAP interne** au pare-feu (organisation MediConnect, domaine mediconnect.local) porte les comptes et les groupes. Les accès externes à l'annuaire (LDAP en clair et LDAPS) sont **fermés**, et l'inscription libre (enrollment) est désactivée : seul l'administrateur crée les comptes. Chaque population du sujet correspond à un **groupe**, et chaque personne à un **compte nominatif**.

Identifiant	Titulaire	Groupe	Profil du sujet	Accès accordés
med.dupont	Claire Dupont	medecins	Médecin	Espace professionnel en HTTPS, après mot de passe + TOTP
comp.martin	Julie Martin	comptables	Télétravailleur comptable	VPN SSL → serveur comptable
info.durand	Lucas Durand	informaticiens	Télétravailleur informaticien	VPN SSL → ressources techniques ; administration en lecture seule
sup.bernard	Emma Bernard	support	Télétravailleur support	VPN SSL → applications de support
emp.roux	Léa Roux	employes	Télétravailleur employé	VPN SSL → ressources bureautiques
com.leroy	Hugo Leroy	commerciaux	Commercial itinérant	VPN SSL → CRM et plateforme DEMO
adm.petit	Nina Petit	administrateurs	Administrateur	VPN SSL → bastion ; administration complète

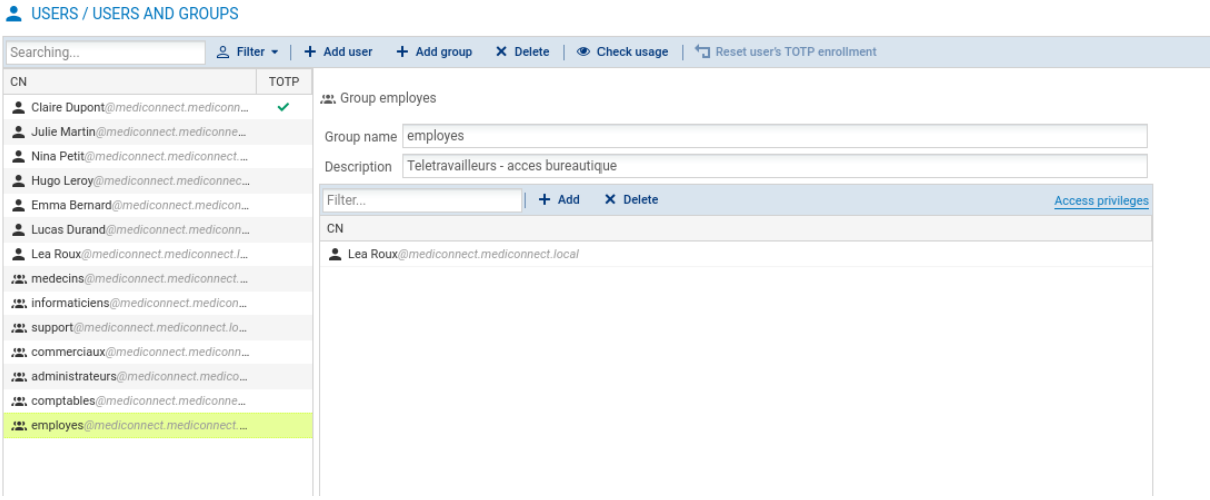
Les mots de passe de la maquette ne sont pas reproduits dans ce rapport. En production, une politique de mots de passe robuste et la synchronisation avec l'annuaire d'entreprise seraient appliquées.



Capture 28 — Annuaire LDAP interne, accès externes fermés



Capture 29 — Utilisateurs et groupes, un groupe par profil

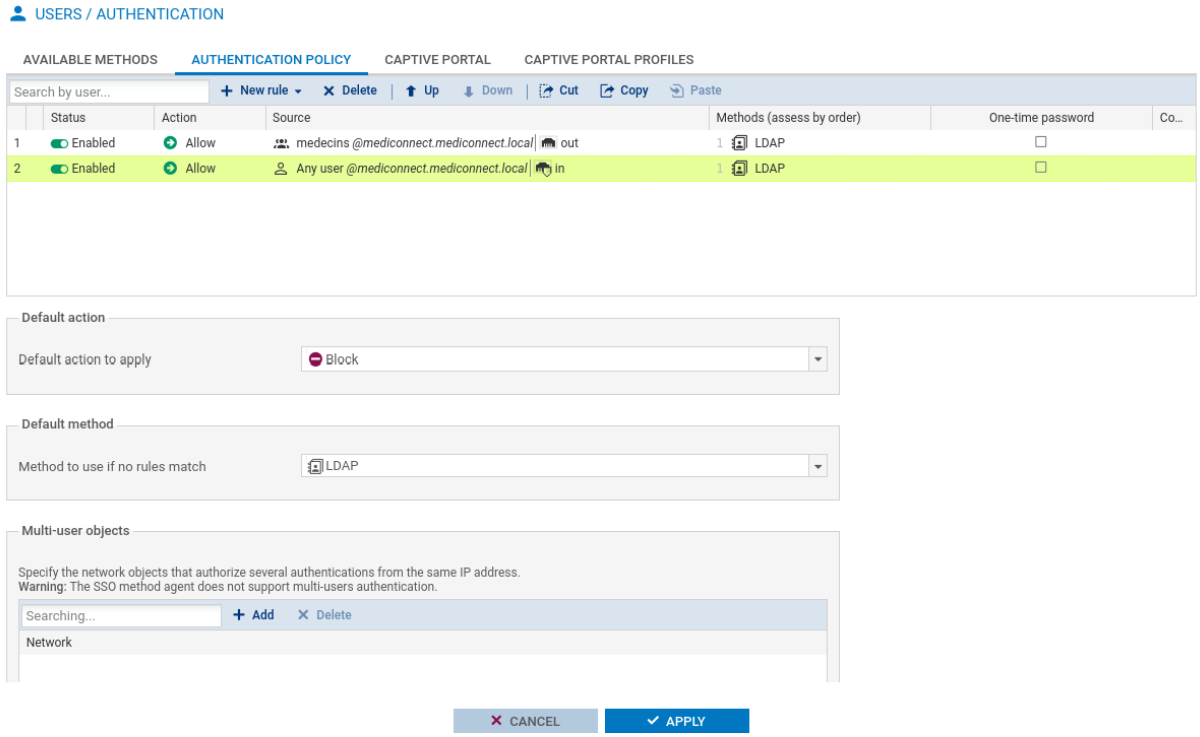


Capture 93 — Groupe employes (télétravailleurs, accès bureautique) et compte emp.roux

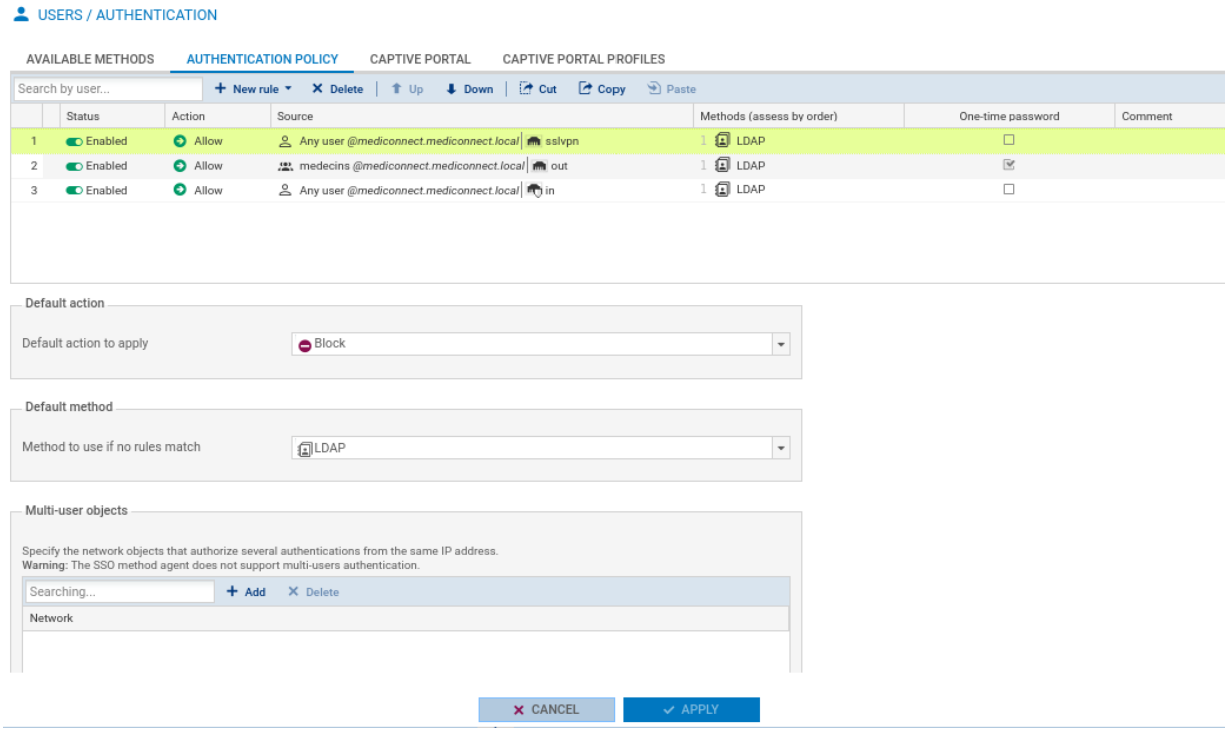
7.2 Politique d'authentification

La politique d'authentification décide **qui peut s'authentifier, depuis quelle interface et avec quelle méthode**. Son action par défaut est **Block** : toute tentative qui ne correspond à aucune règle est refusée (interdiction par défaut). Chaque règle est limitée à **une seule interface**, ce qui empêche par exemple un employé de s'authentifier sur le portail public.

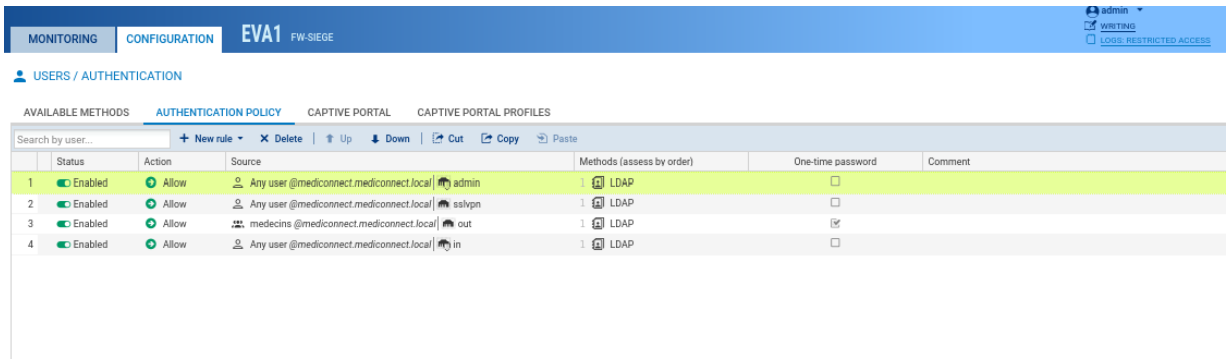
N°	Utilisateurs	Interface	Méthode	TOTP	Usage
1	Tout utilisateur de l'annuaire	admin	LDAP	Non	Connexion des administrateurs à l'interface d'administration
2	Tout utilisateur de l'annuaire	sslvpn	LDAP	Non	Ouverture d'un tunnel VPN SSL (droits filtrés par groupe ensuite)
3	Groupe medecins	out	LDAP	Oui	Accès des médecins à l'espace professionnel
4	Tout utilisateur de l'annuaire	in	LDAP	Non	Portail captif interne (récupération du profil VPN)
—	Tout le reste	—	—	—	Block (action par défaut)



Capture 30 — Politique d'authentification initiale : médecins sur out avec TOTP, employés sur in, défaut Block



Capture 50 — Ajout de la règle d'authentification de l'interface SSL VPN



Capture 69 — Politique finale : ajout de la règle de l'interface admin pour les administrateurs nominatifs

7.3 Portail captif

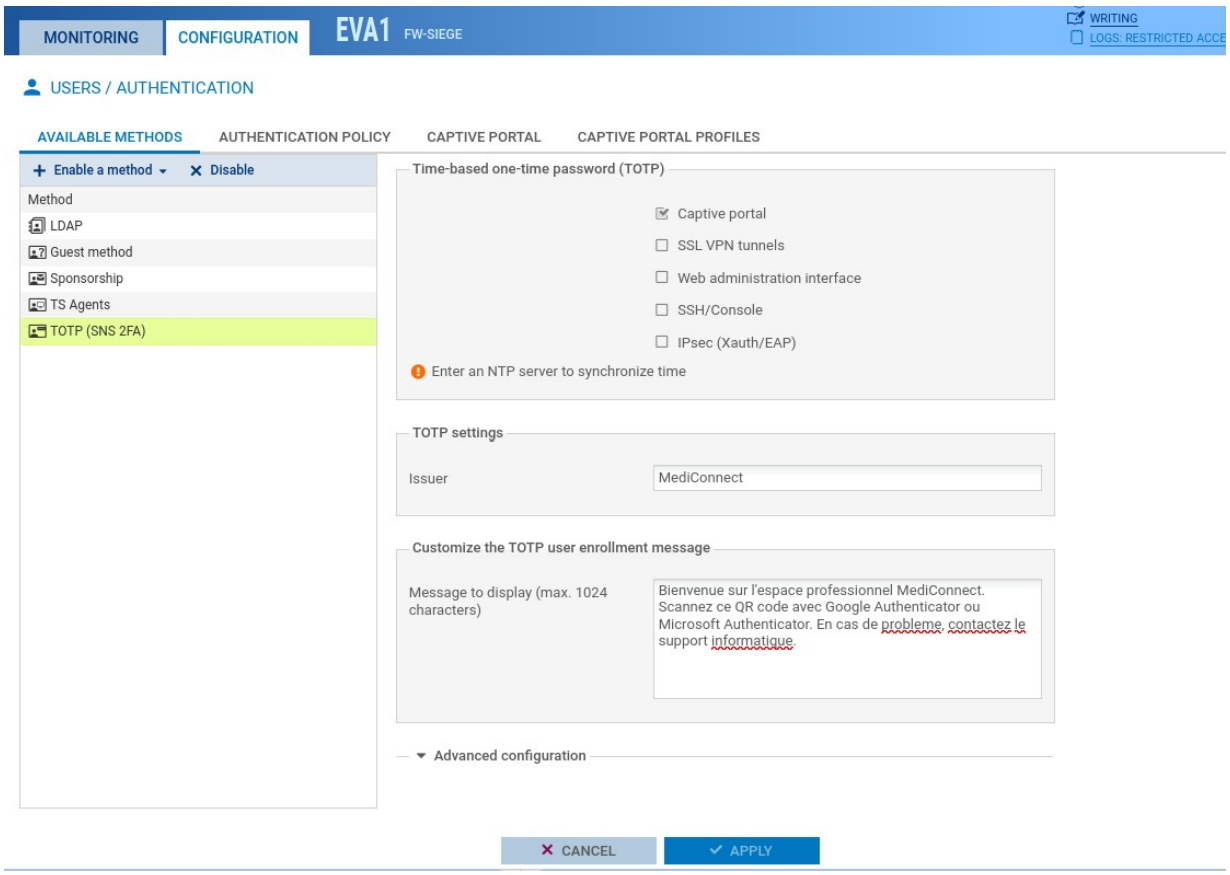
Le portail captif de SNS (https://192.36.253.10/auth côté Internet, https://192.168.1.254/auth côté LAN) authentifie l'utilisateur et associe son identité à son adresse IP pour une durée limitée (de 15 minutes à 4 heures). Les règles de filtrage qui mentionnent un utilisateur ou un groupe ne s'appliquent qu'aux adresses associées à une session valide. Le profil « External » est utilisé sur l'interface out, le profil « Internal » sur l'interface in.

7.4 Authentification forte des médecins (TOTP)

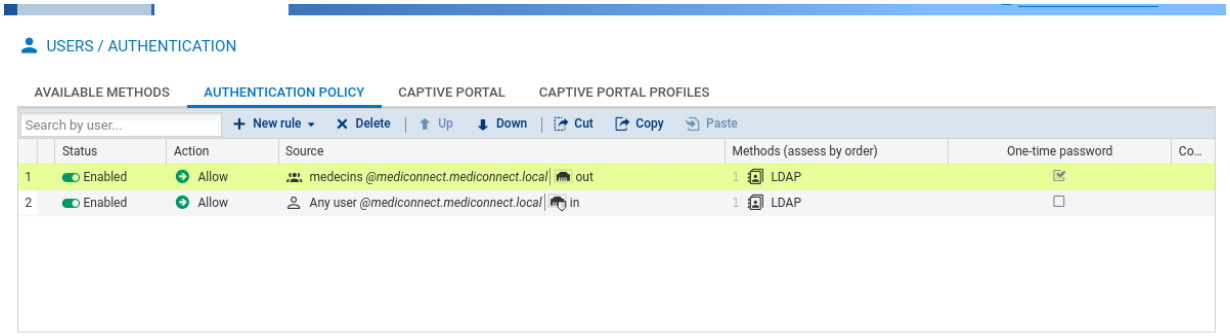
Les médecins accèdent à des fonctions plus sensibles que les patients ; le sujet demande un **niveau de sécurité supérieur**. Une authentification à deux facteurs est exigée : **ce que le médecin sait** (mot de passe) et **ce qu'il possède** (application d'authentification sur son téléphone, qui génère un code TOTP).

- méthode **TOTP intégrée à SNS (SNS 2FA)**, activée pour le portail captif ; émetteur « MediConnect » ; codes à 6 chiffres renouvelés toutes les 30 secondes ;
- **enrôlement par QR code** lors de la première connexion, avec un message d'accueil en français ; le QR code contient le secret partagé, il est donc masqué sur la capture 34 ;
- **synchronisation NTP** du pare-feu (ntp1/ntp2.stormshieldcs.eu), indispensable car le code dépend de l'heure ;
- la case « One-time password » n'est cochée que pour la règle des médecins (capture 32).

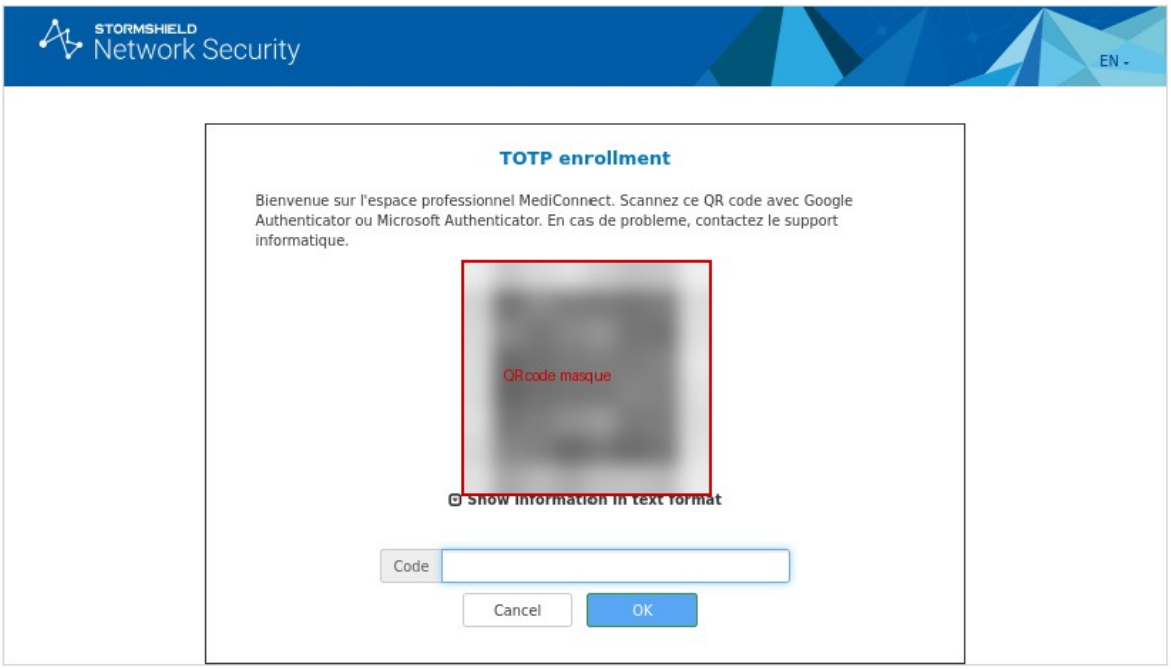
Un mot de passe volé par hameçonnage ne suffit plus : sans le téléphone du médecin, l'accès est refusé. Le journal Users confirme l'utilisation du TOTP et la durée de session (capture 37).



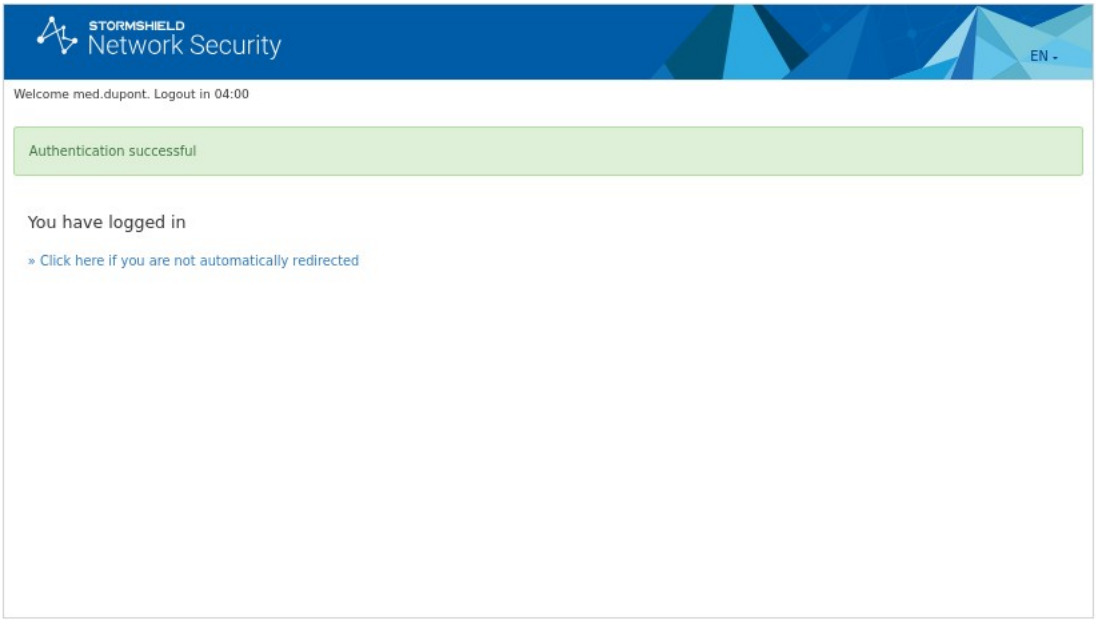
Capture 31 — Méthode TOTP (SNS 2FA) activée pour le portail captif



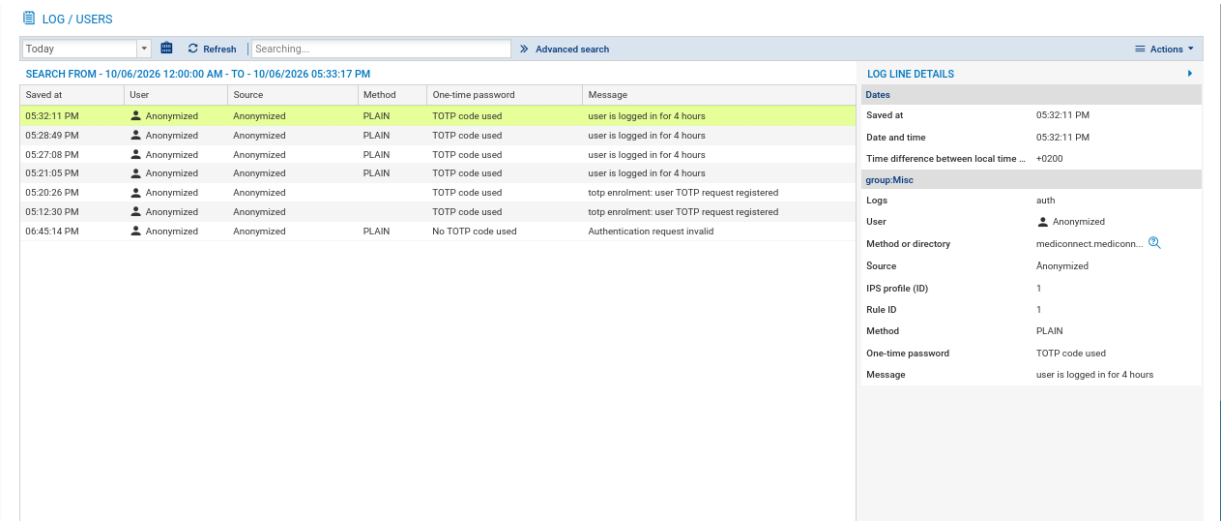
Capture 32 — TOTP exigé uniquement pour la règle des médecins



Capture 34 — Enrôlement TOTP par QR code (QR code masqué)



Capture 35 — Authentification réussie du médecin (mot de passe + code TOTP)



Capture 37 — Journal Users : TOTP utilisé, session de 4 heures

7.5 Distinction entre patients et médecins

Critère	Patients	Médecins
Adresse publique	pub_portail — 192.36.253.11	pub_pro — 192.36.253.12
Serveur en DMZ	web_portail — 172.16.1.11	web_pro — 172.16.1.12
Authentification au niveau réseau	Aucune (service public ; authentification applicative hors périmètre)	Portail captif : annuaire + TOTP
Règle de filtrage	Règle 23 : Any → pub_portail, https	Règle 24 : groupe medecins, depuis out → pub_pro, https
Accès aux serveurs internes	Aucun	Aucun (pas de droit VPN, pas de route)
Preuves	Captures 20, 21	Captures 33, 35, 36, 38a, 38b

Les deux chemins sont donc **distincts dès l'entrée** (adresse publique différente) et le chemin des médecins impose un **niveau d'authentification supérieur**. Un commercial qui tente de s'authentifier sur le portail public est refusé (capture 38b) : la règle d'authentification de l'interface out ne concerne que le groupe medecins.

8. Politique de filtrage

8.1 Méthode d'organisation (cours 2)

La politique **(5) MediConnect** du siège applique la méthode vue en cours :

1. **un niveau de sécurité par zone** (section 5) ;
2. **des règles regroupées par zone, dans l'ordre décroissant du niveau de sécurité** : ADMIN, SRV, LAN, DMZ-PROD, DMZ-DEMO, chaque bloc étant délimité par un séparateur commenté ;
3. **dans chaque bloc** : les autorisations explicites, puis l'**interdiction générale en entrée** (block Any → zone), puis l'**interdiction générale en sortie** (block zone → Any). Les flux sortants autorisés d'une zone sont placés dans le bloc de la zone la plus sûre qu'ils concernent ;
4. **une règle impliquant deux zones apparaît dans le bloc de la zone la plus sécurisée** : par exemple « DMZ-PROD → base PROD » figure dans le bloc SRV, et « commerciaux → DEMO » dans le bloc DMZ-DEMO ;
5. **une règle finale « block any any » journalisée** : elle ne devrait jamais servir ; si elle bloque quelque chose, c'est une erreur ou une attaque, et le journal la révèle.

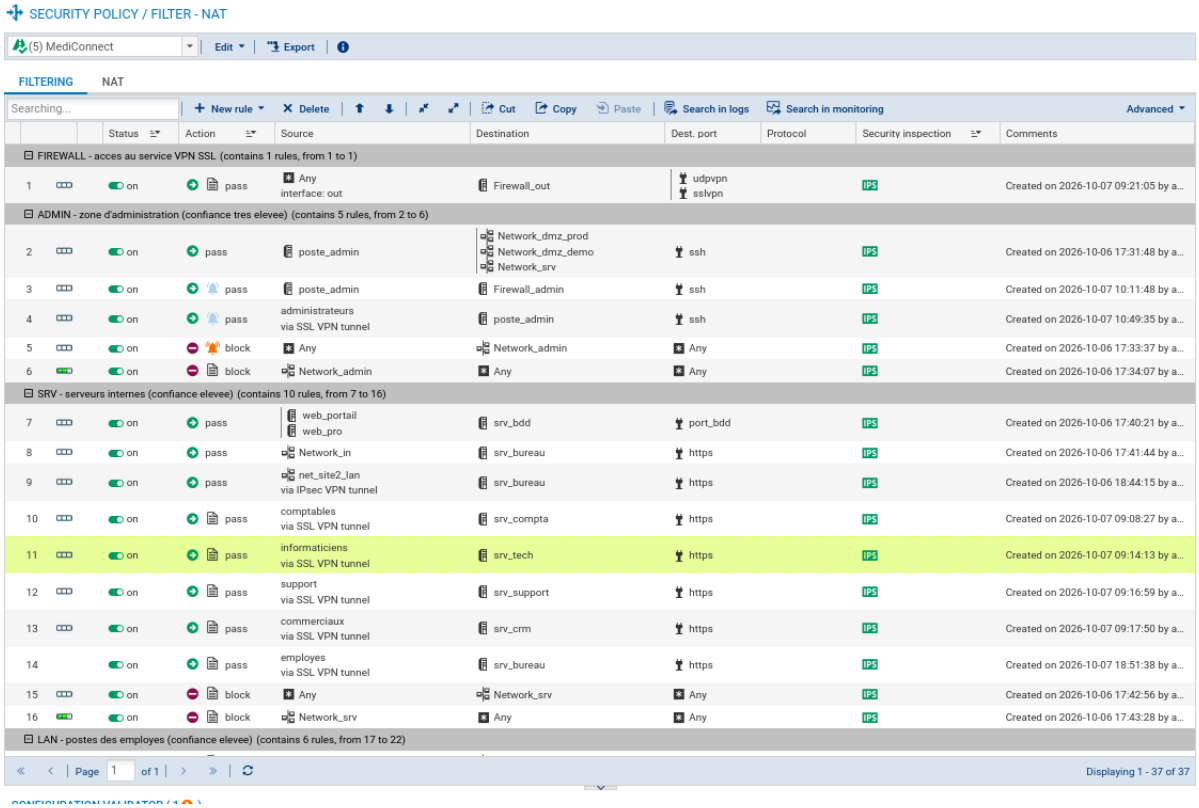
Un bloc **FIREWALL** est placé tout en haut : il ne contient que l'accès aux ports du VPN SSL depuis Internet. Le pare-feu est l'équipement le plus critique ; les services qu'il expose lui-même sont ainsi visibles en un coup d'œil. L'**IPS** est actif sur toutes les règles et toutes les règles « block » sont journalisées.

> **Point clé découvert pendant les tests :** SNS évalue la destination **avant la traduction d'adresse**. Les règles qui autorisent les services publiés visent donc l'adresse publique (pub_portail, pub_pro) et non l'adresse privée du serveur. Une première règle écrite vers web_portail ne fonctionnait pas : le journal de la règle finale montrait la destination publique bloquée, ce qui a permis de corriger (capture 20).

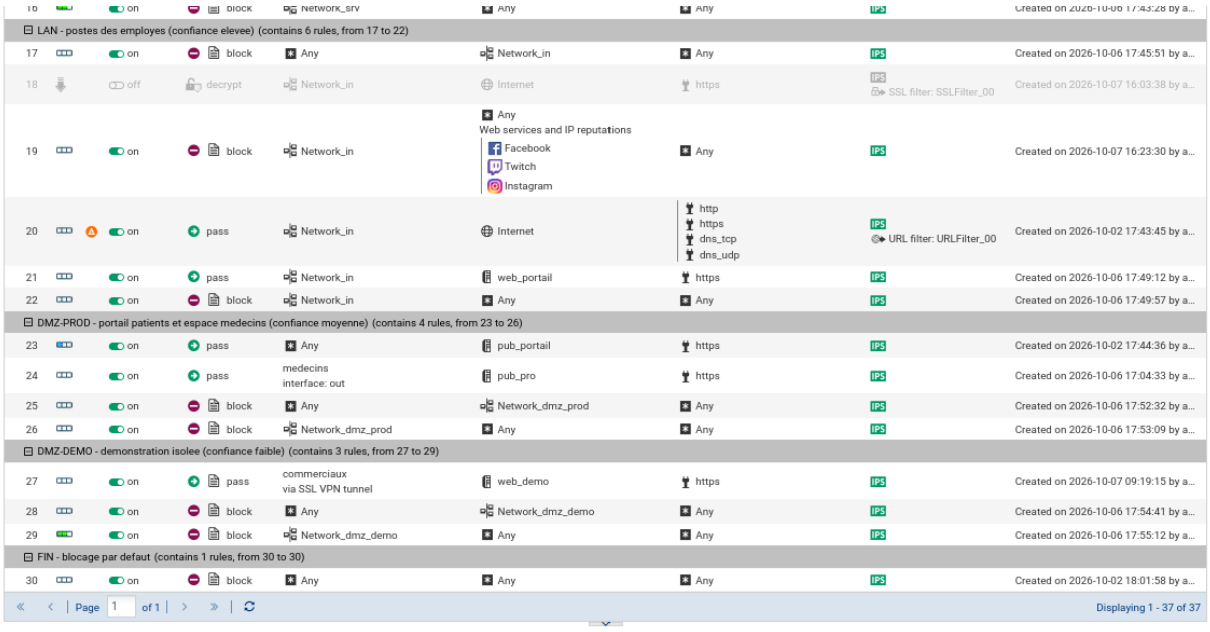
8.2 Politique complète du siège

N°	Action	Source	Destination	Port	Rôle et justification
FIREWALL					
1	pass	Any (interface out)	Firewall_out	udpvpn, sslvpn	Seuls les ports du VPN SSL du pare-feu sont ouverts sur Internet.
ADMIN — confiance très élevée					
2	pass	poste_admin	DMZ-PROD, DMZ-DEMO, SRV	ssh	Administration des serveurs depuis le poste d'administration uniquement.
3	pass (alarme mineure)	poste_admin	Firewall_admin	ssh	Administration SSH du pare-feu, remplace la règle implicite ; chaque connexion est signalée.
4	pass (alarme mineure)	groupe administrateurs via VPN SSL	poste_admin	ssh	Administration à distance par rebond sur le bastion.
5	block (alarme majeure)	Any	Network_admin	Any	Interdiction générale en entrée ; toute tentative est un signal d'attaque.
6	block	Network_admin	Any	Any	Interdiction générale en sortie : pas d'Internet pour la zone ADMIN.
SRV — confiance élevée					
7	pass	web_portail, web_pro	srv_bdd	port_bdd (5432)	Seul flux de la DMZ vers l'intérieur : le serveur web vers la base.
8	pass	Network_in	srv_bureau	https	Bureautique pour les postes du siège.
9	pass	net_site2_lan via IPsec	srv_bureau	https	Bureautique pour le site 2, uniquement à travers le tunnel.
10	pass	comptables via VPN SSL	srv_compta	https	Règle par identité.
11	pass	informaticiens via VPN SSL	srv_tech	https	Règle par identité.
12	pass	support via VPN SSL	srv_support	https	Règle par identité.
13	pass	commerciaux via VPN SSL	srv_crm	https	Règle par identité.

N°	Action	Source	Destination	Port	Rôle et justification
14	pass	employes via VPN SSL	srv_bureau	https	Règle par identité : télétravailleurs, accès bureautique.
15	block	Any	Network_srv	Any	Interdiction générale en entrée.
16	block	Network_srv	Any	Any	Les serveurs n'initient aucune connexion.
LAN — confiance élevée					
17	block	Any	Network_in	Any	Rien n'entre dans le LAN (y compris vers l'adresse du pare-feu côté LAN).
18	decrypt (désactivée)	Network_in	Internet	https	Tentative de filtrage SSL, désactivée (licence, section 10.3), conservée pour la traçabilité.
19	block	Network_in	Facebook, Twitch, Instagram (services web)	Any	Blocage des réseaux sociaux en HTTPS, sans déchiffrement.
20	pass + filtrage d'URL	Network_in	Internet	http, https, dns	Navigation professionnelle, filtrage d'URL sur le HTTP.
21	pass	Network_in	web_portail	https	Les employés peuvent consulter le portail.
22	block	Network_in	Any	Any	Interdiction générale en sortie (ping, SSH vers Internet, compta...).
DMZ-PROD — confiance moyenne					
23	pass	Any	pub_portail	https	Portail public des patients, HTTPS uniquement.
24	pass	groupe medecins (interface out)	pub_pro	https	Espace professionnel, médecins authentifiés avec TOTP.
25	block	Any	Network_dmz_prod	Any	Aucun autre accès à la DMZ (adresses privées, HTTP...).
26	block	Network_dmz_prod	Any	Any	La DMZ n'initie rien, ni vers Internet ni vers le LAN.
DMZ-DEMO — confiance faible, isolée					
27	pass	commerciaux via VPN SSL	web_demo	https	Démonstrations par les commerciaux uniquement.
28	block	Any	Network_dmz_demo	Any	Interdiction générale en entrée.
29	block	Network_dmz_demo	Any	Any	Aucune sortie : pas de lien avec la production.
FIN					
30	block	Any	Any	Any	Interdiction par défaut, journalisée.



Capture 89a — Politique de filtrage finale du siège (1/2) : blocs FIREWALL, ADMIN et SRV



Capture 89b — Politique de filtrage finale du siège (2/2) : LAN, DMZ-PROD, DMZ-DEMO et blocage final (règle 30)

8.3 Matrice des flux entre zones

Lecture : ligne = zone source, colonne = zone destination. « — » signifie bloqué et journalisé.

Source \ Dest.	Internet	LAN	SRV	ADMIN	DMZ-PROD	DMZ-DEMO	Pare-feu
Internet		—	—	—	HTTPS portail ; HTTPS espace pro (médecins + TOTP)	—	VPN SSL, portail captif
Clients VPN	Hors tunnel	—	HTTPS selon le groupe	SSH bastion (administrateurs)	—	HTTPS (commerciaux)	—
LAN siège	Web filtré, DNS		HTTPS bureautique	—	HTTPS portail	—	Portail captif, DNS

Source \ Dest.	Internet	LAN	SRV	ADMIN	DMZ-PROD	DMZ-DEMO	Pare-feu
LAN site 2	Par son propre accès	—	HTTPS bureautique (IPsec)	—	—	—	—
SRV	—	—		—	—	—	—
ADMIN	—	—	SSH		SSH	SSH	SSH, HTTPS admin
DMZ-PROD	—	—	Base PROD (5432)	—		—	—
DMZ-DEMO	—	—	—	—	—		—

8.4 Règles implicites

SNS applique des **règles implicites** avant la politique explicite. Elles ont été revues une à une. La règle « **Allow protected interfaces to access the firewall's SSH port** » ouvrait le SSH du pare-feu à toutes les zones internes, y compris le LAN, et contournait donc l'exigence d'administration séparée. Elle a été **désactivée sur les deux pare-feux** et remplacée au siège par la règle explicite n° 3, limitée au poste d'administration et journalisée (section 12). Les règles implicites conservées sont nécessaires au fonctionnement (IPsec ISAKMP/ESP, DNS du pare-feu pour les zones internes, portail d'authentification, VPN SSL, interface web d'administration, elle-même protégée par la liste des hôtes autorisés).

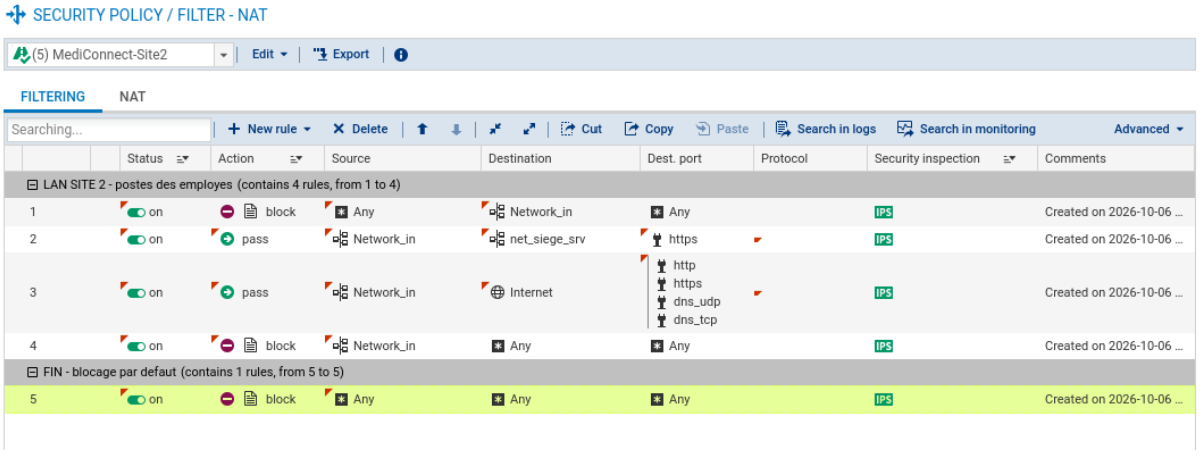
8.5 Politique du site 2

N°	Onglet	Règle	Justification
N1	NAT	Network_in → net_siege_srv : aucune traduction	Le trafic vers le siège doit garder ses adresses pour entrer dans le tunnel.
N2	NAT	PAT Network_in → Internet (Firewall_out)	Accès Internet indépendant du site 2.
B1	Filtrage	block Any → Network_in	Rien n'entre dans le LAN du site 2.
B2	Filtrage	pass Network_in → net_siege_srv, https	Accès aux ressources du siège (filtrées au siège par la règle 9).
B3	Filtrage	pass Network_in → Internet : http, https, dns	Navigation.
B4	Filtrage	block Network_in → Any	Interdiction générale en sortie.
B5	Filtrage	block Any → Any (journalisée)	Interdiction par défaut.

Le filtrage est appliqué **aux deux extrémités du tunnel** : le site 2 n'émet que du HTTPS vers les serveurs du siège, et le siège n'accepte que le HTTPS vers la bureautique. C'est une application directe de la défense en profondeur.

Profils du site 2 autres que les employés

Le sujet précise que le site 2 accueille aussi une partie du support, des commerciaux et des utilisateurs ayant besoin des ressources du siège. Le tunnel IPsec est volontairement limité à la **bureautique**, qui est le besoin commun de tous les postes du site 2 : c'est l'application du moindre privilège, car un tunnel de site à site donne le même accès à tous les postes du LAN, quel que soit leur propriétaire. Les accès plus sensibles dépendent de l'**identité** et non du site : un agent du support ou un commercial installé au site 2 ouvre un **VPN SSL** nominatif, comme un télétravailleur, et obtient exactement les ressources de son groupe (applications de support, CRM et DEMO), avec les mêmes règles par groupe (section 9). Ce choix évite de dupliquer les droits dans la politique du tunnel et garde une seule logique d'autorisation. Ce scénario n'a pas été rejoué depuis le LAN du site 2 : il repose sur le mécanisme déjà démontré depuis Internet (captures 54 à 58), et il figure parmi les limites (section 16).



Capture 39b — Politique de filtrage du site 2

9. Règles basées sur l'identité

Les télétravailleurs partagent le même réseau VPN (172.30.1.0/24) : une règle fondée sur l'adresse IP ne pourrait pas les distinguer. Les règles s'appuient donc sur l'**identité** de l'utilisateur, connue du pare-feu grâce à l'authentification (le pare-feu associe chaque adresse VPN à un utilisateur et à ses groupes).

Groupe	Ressource autorisée	Règle	Tout le reste	Preuve
comptables	Serveurs comptables (srv_compta), HTTPS	10	Bloqué (règles 15, 28, 30)	Captures 55, 58
informaticiens	Ressources techniques (srv_tech), HTTPS ; administration en lecture seule	11	Bloqué	Captures 98, 99, 67
support	Applications de support (srv_support), HTTPS	12	Bloqué	Captures 97, 99
commerciaux	CRM (srv_crm) et plateforme DEMO (web_demo), HTTPS	13, 27	Bloqué, en particulier la PROD	Captures 56, 58
employes (télétravail)	Ressources bureautiques (srv_bureau), HTTPS	14	Bloqué	Captures 93 à 96, 99
administrateurs	Bastion (poste_admin), SSH	4	Bloqué	Captures 71, 72
postes du LAN et du site 2	Ressources bureautiques (srv_bureau), HTTPS	8 et 9 (par réseau)	Bloqué	Captures 23, 46
medecins	Espace professionnel (pub_pro), HTTPS, depuis Internet	24	Aucun droit VPN, aucun serveur interne	Captures 33, 36, 49b

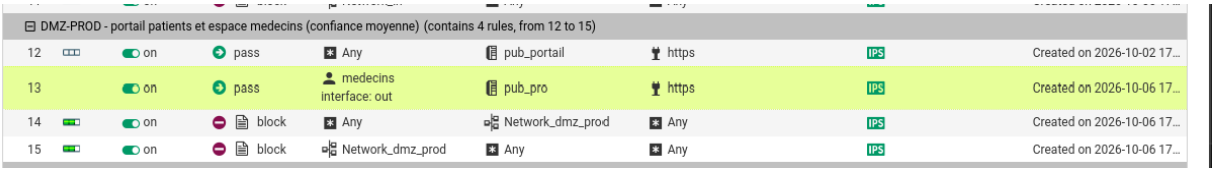
Trois niveaux successifs portent l'identité : la **politique d'authentification** (qui peut s'authentifier et où), les **droits d'accès** (qui peut ouvrir un tunnel VPN SSL) et les **règles de filtrage** (où peut aller chaque groupe). Dans l'éditeur de règle SNS, l'identité se règle dans l'onglet Source (champ User) et le canal dans les propriétés avancées (champ Via : SSL VPN tunnel ou IPsec VPN tunnel). Une règle porte toujours sur un **groupe**, jamais sur une personne : un nouveau comptable hérite automatiquement des bons droits.

9.1 Démonstration : deux profils, deux périmètres

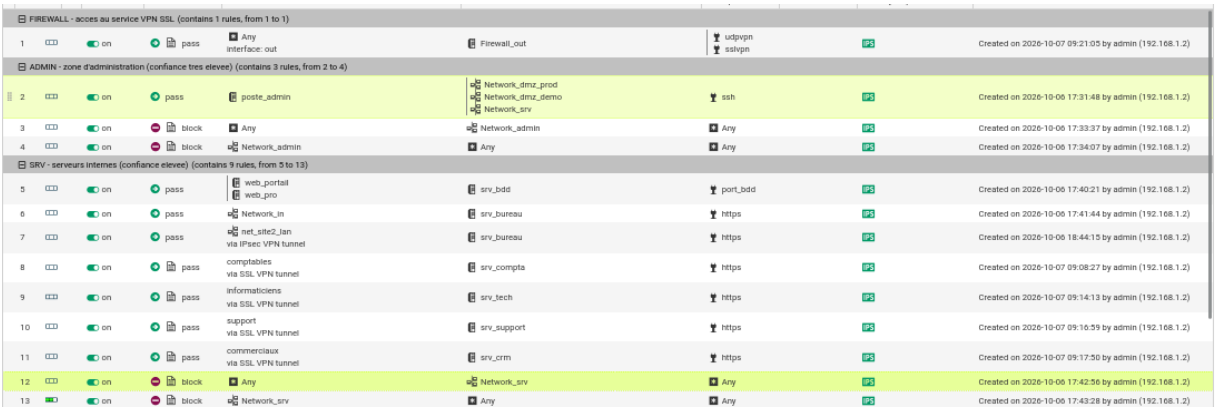
Le comptable et le commercial se sont connectés successivement **depuis le même poste**, avec le **même profil VPN** et la **même adresse attribuée** (172.30.1.6). Seule leur identité diffère, et pourtant leurs accès sont strictement différents :

Ressource	Comptable (comp.martin)	Commercial (com.leroy)
Comptabilité 192.168.11.11	Autorisé	Bloqué
CRM 192.168.11.10	Bloqué	Autorisé
DEMO 172.17.1.11	Bloqué	Autorisé
Bureautique 192.168.11.13	Bloqué	Bloqué
Base PROD 192.168.11.20:5432	Bloqué	Bloqué
Portail PROD 172.16.1.11	Non routé	Non routé

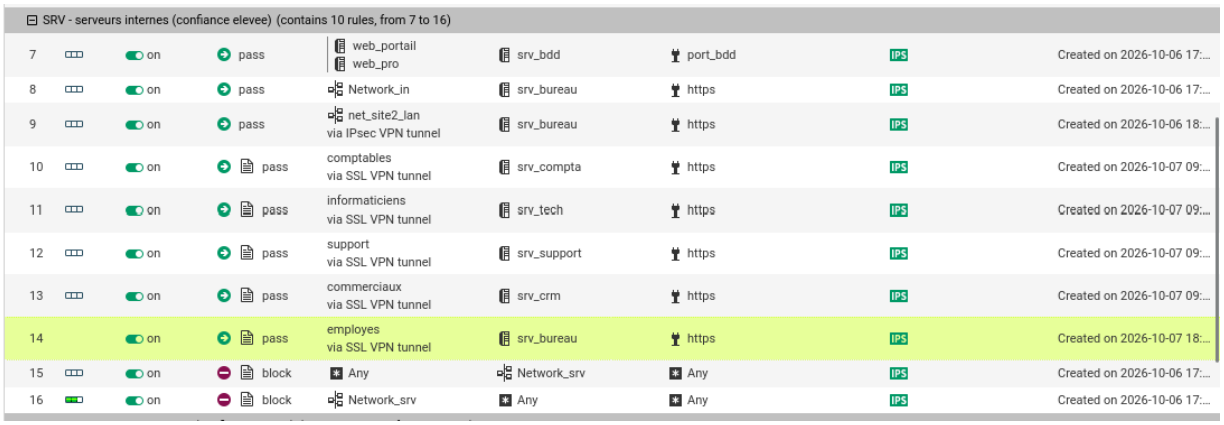
Le journal de filtrage attribue chaque décision à sa règle et à l'interface sslvpn : autorisations par les règles de groupe, blocages par les interdictions générales des zones (capture 58, numérotation de l'étape 10). Après ouverture de l'accès aux données privées, le nom de l'utilisateur apparaît en clair dans les journaux (captures 85, 88 et 99).



Capture 33 — Règle par identité : seul le groupe medecins, depuis l'interface out, atteint l'espace professionnel



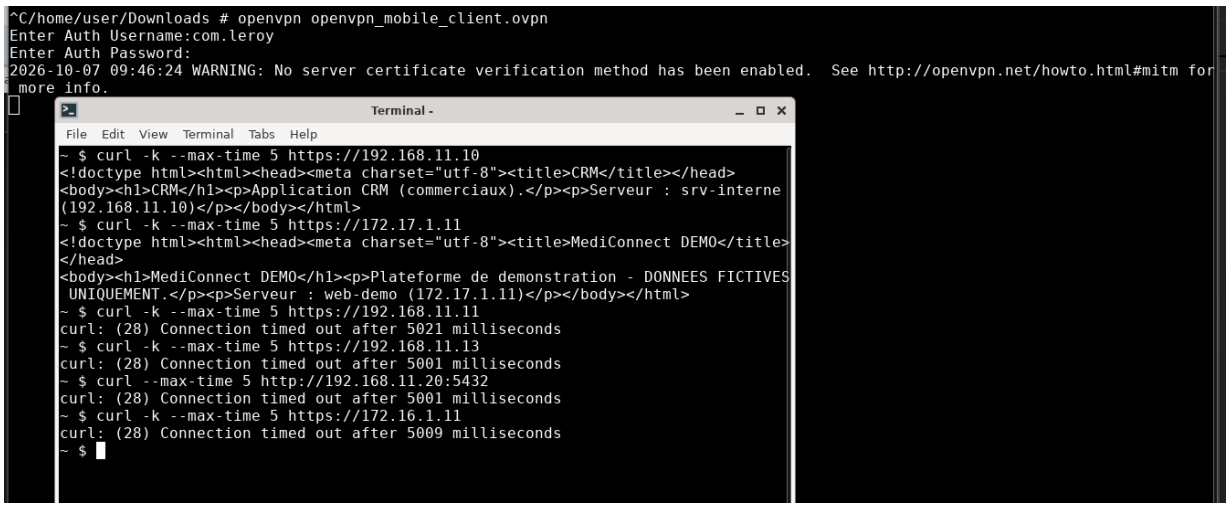
Capture 51a — Règles par groupe « via SSL VPN tunnel » dans le bloc SRV, avant les interdictions (étape 10)



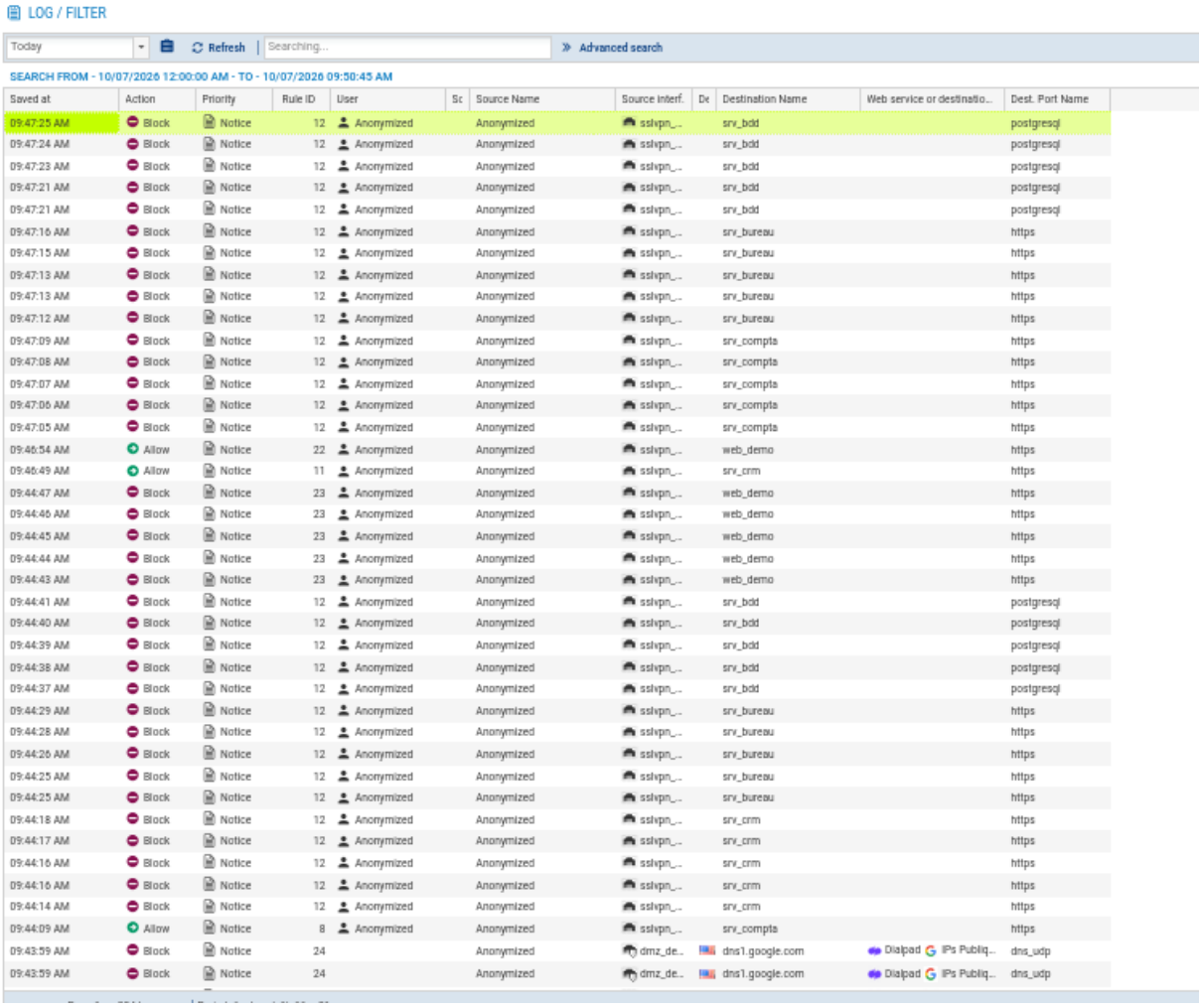
Capture 95 — Bloc SRV final : ajout de la règle employes → bureautique via VPN SSL

```
~ $ curl -k --max-time 5 https://192.168.11.11
<!doctype html><html><head><meta charset="utf-8"><title>Comptabilite</title></he
ad>
<body><h1>Comptabilite</h1><p>Serveur comptable.</p><p>Serveur : srv-interne (19
2.168.11.11)</p></body></html>
~ $ curl -k --max-time 5 https://192.168.11.10
curl: (28) Connection timed out after 5016 milliseconds
~ $ curl -k --max-time 5 https://192.168.11.13
curl: (28) Connection timed out after 5018 milliseconds
~ $ curl --max-time 5 http://192.168.11.20:5432
curl: (28) Connection timed out after 5018 milliseconds
~ $ curl -k --max-time 5 https://172.17.1.11
curl: (28) Connection timed out after 5005 milliseconds
~ $ curl -k --max-time 5 https://172.16.1.11
curl: (28) Connection timed out after 5018 milliseconds
~ $
```

Capture 55 — Comptable en VPN : comptabilité accessible, tout le reste bloqué



Capture 56 — Commercial en VPN : CRM et DEMO accessibles, tout le reste bloqué



Capture 58 — Journal Filter : chaque décision attribuée à une règle de groupe ou d'interdiction

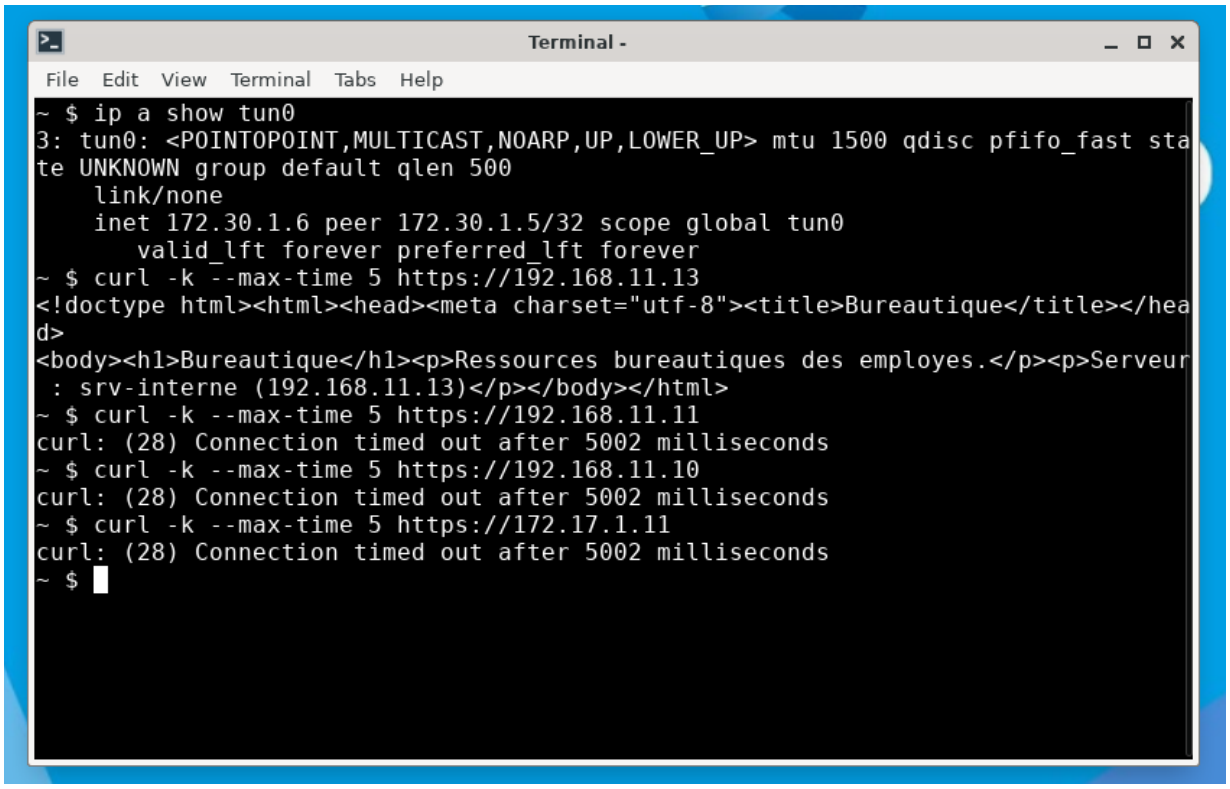
9.2 Validation des six groupes de télétravail

Chaque groupe a ensuite été testé en conditions réelles, depuis Internet, avec le même profil VPN et la même adresse attribuée. Chacun n'atteint que sa ressource ; toutes ses autres tentatives sont bloquées par l'interdiction générale de la zone SRV (règle 15) ou de la DEMO (règle 28).

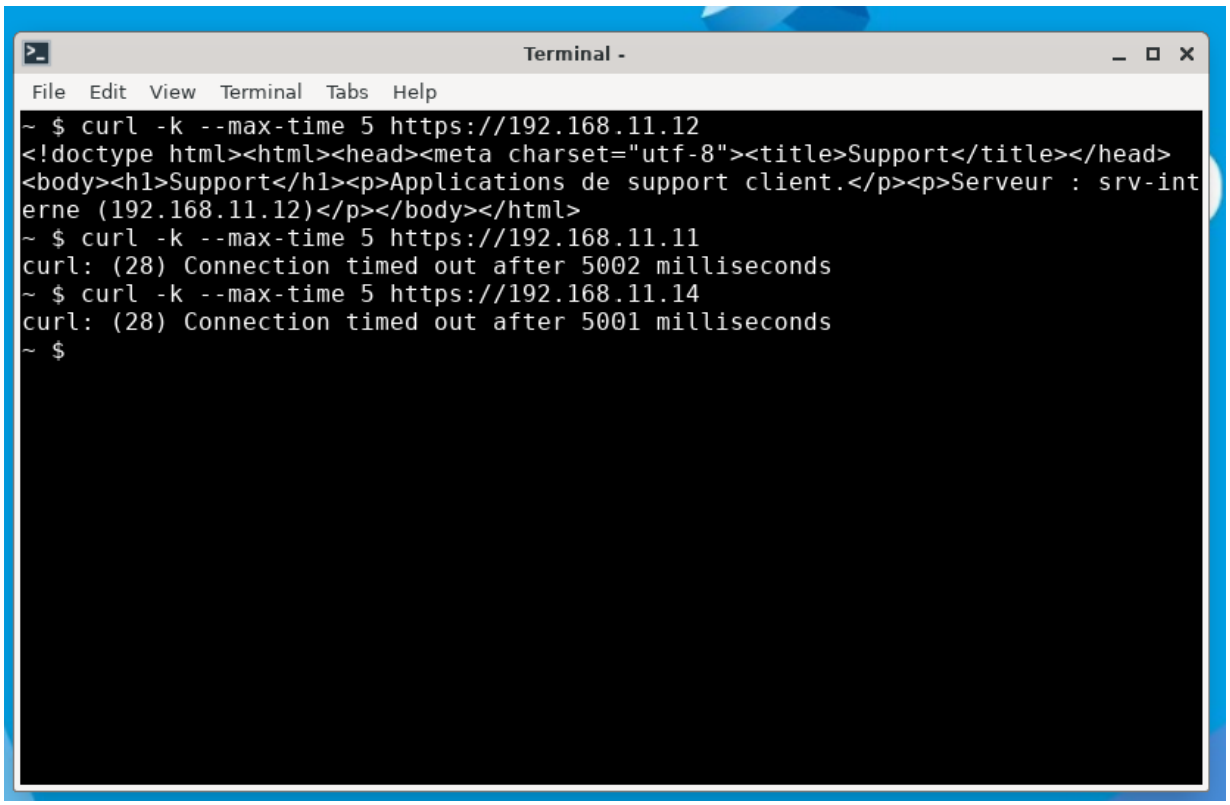
Groupe	Compte testé	Ressource autorisée (règle)	Ressources testées et bloquées	Capture
comptables	comp.martin	Comptabilité (10)	CRM, bureautique, base PROD, DEMO, PROD	55

Groupe	Compte testé	Ressource autorisée (règle)	Ressources testées et bloquées	Capture
commerciaux	com.leroy	CRM (13) et DEMO (27)	Comptabilité, bureautique, base PROD, PROD	56
employes	emp.roux	Bureautique (14)	Comptabilité, CRM, DEMO	96
support	sup.bernard	Applications de support (12)	Comptabilité, ressources techniques	97
informaticiens	info.durand	Ressources techniques (11)	Comptabilité, support	98
administrateurs	adm.petit	Bastion en SSH (4), puis pare-feu	Un comptable est refusé sur le bastion (capture 72)	71

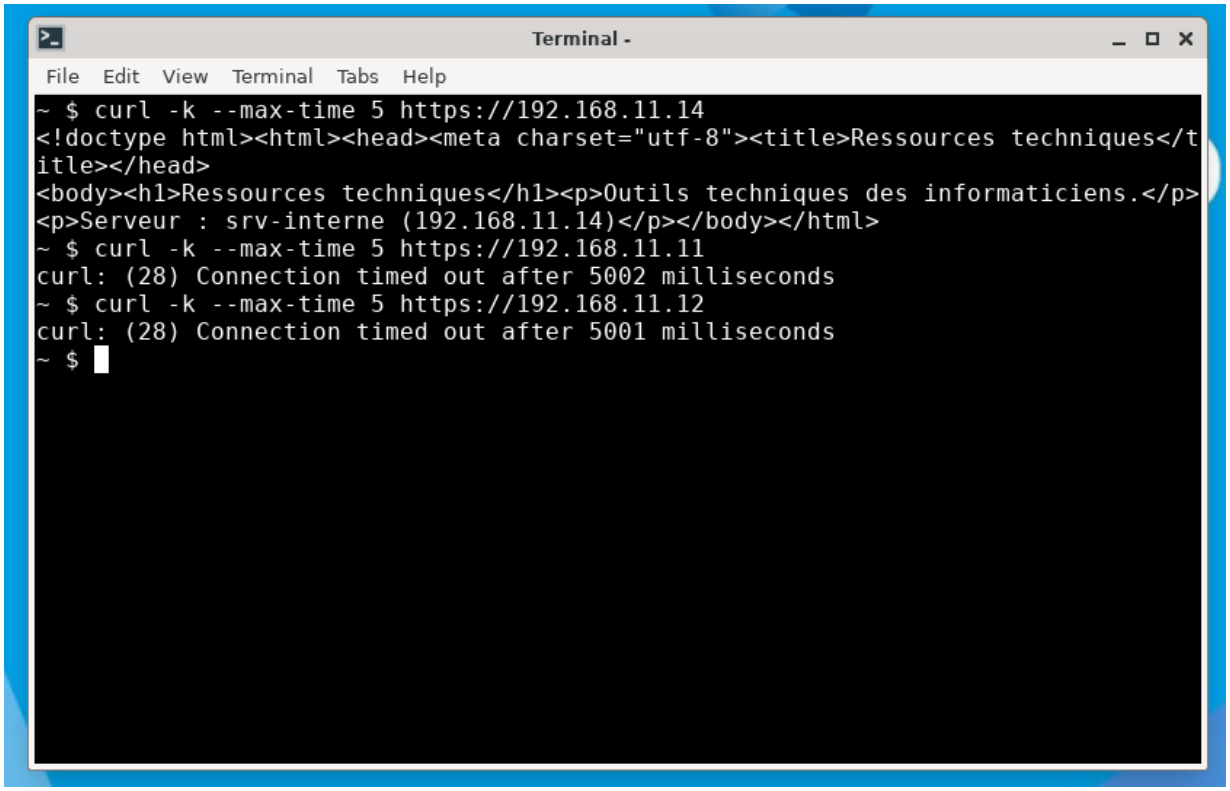
En accès complet, le journal de filtrage attribue chaque décision à une **personne nommée** : info.durand autorisé par la règle 11, sup.bernard par la règle 12, et leurs autres tentatives ainsi que celles d'emp.roux bloquées par les règles 15 et 28 (capture 99). Les six groupes de télétravail du sujet sont donc démontrés, chacun limité à sa seule ressource.



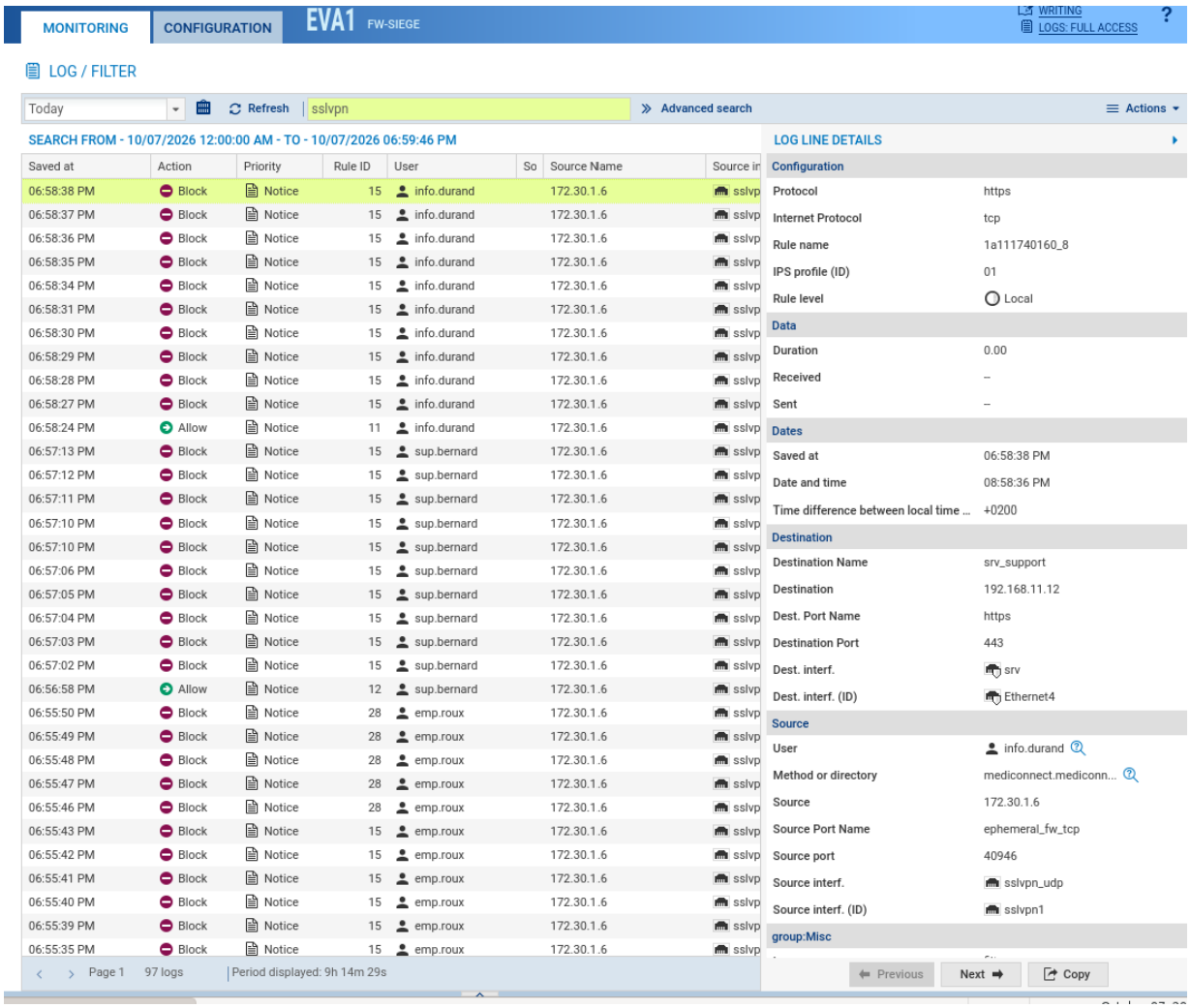
Capture 96 — Employé en VPN : bureautique accessible ; comptabilité, CRM et DEMO bloqués



Capture 97 — Support en VPN : applications de support accessibles ; comptabilité et ressources techniques bloquées



Capture 98 — Informaticien en VPN : ressources techniques accessibles ; comptabilité et support bloqués



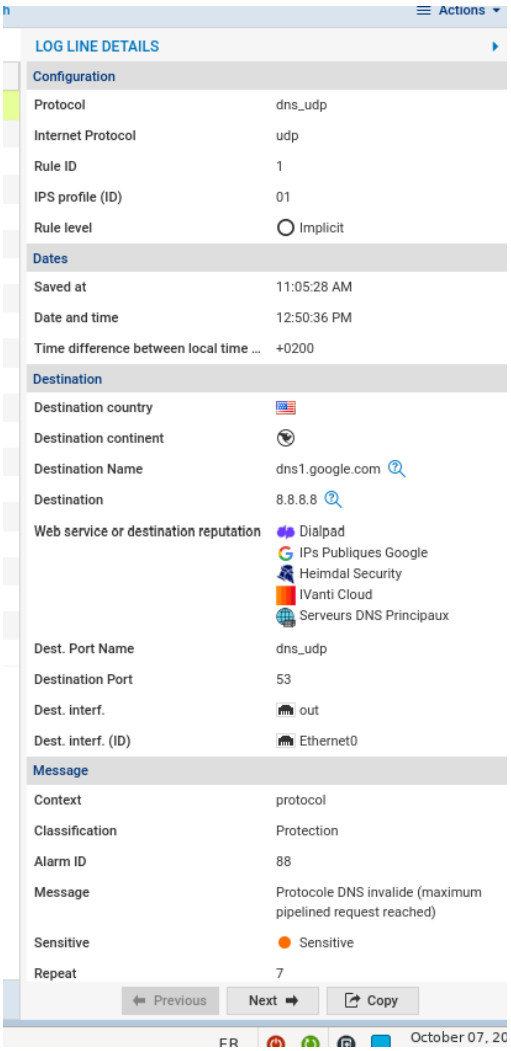
Capture 99 — Journal Filter nominatif : chaque profil autorisé sur sa seule ressource et bloqué ailleurs

10. Contrôle applicatif

Un pare-feu à états décide sur les adresses et les ports. Un **pare-feu de nouvelle génération** (NGFW, cours 2) inspecte aussi le **contenu** des protocoles. Quatre mécanismes ont été mis en œuvre.

10.1 Prévention d'intrusion (IPS)

L'IPS est actif sur **toutes les règles**, avec un profil d'inspection choisi selon le sens du trafic. Il vérifie la conformité des protocoles (HTTP, DNS, TLS, TCP…) et bloque les anomalies. Pendant la maquette, il a bloqué et signalé à plusieurs reprises une anomalie **« Protocole DNS invalide (maximum pipelined request reached) »**, classée Major : la preuve qu'il analyse réellement le contenu des échanges et pas seulement les en-têtes.

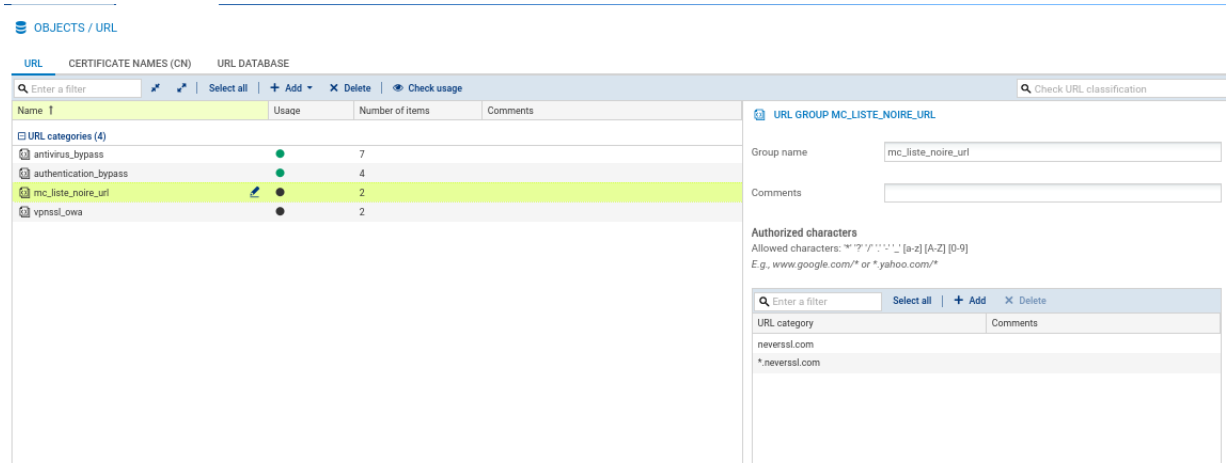


Capture 74 — Alarme IPS : anomalie DNS détectée et bloquée (priorité Major)

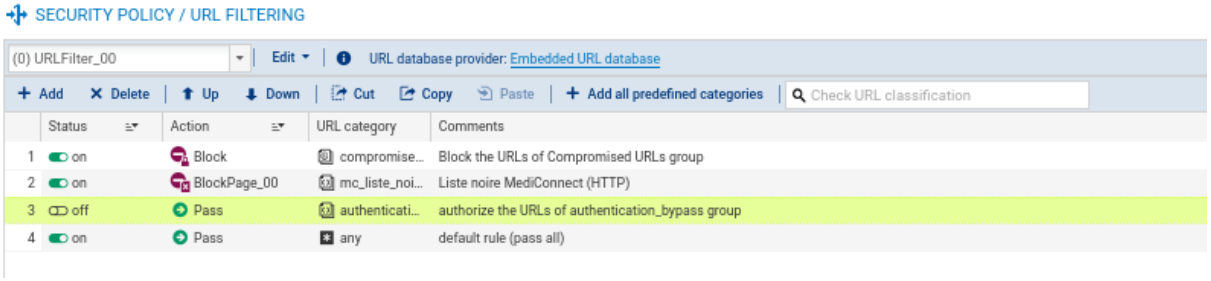
10.2 Filtrage d'URL pour la navigation des employés

La base de catégories d'URL du pare-feu n'a pas pu être téléchargée (licence de mise à jour expirée, voir capture 86). Une **liste noire personnalisée** (mc_liste_noire_url) a donc été créée et appliquée par un profil de filtrage d'URL sur la règle de navigation du LAN (règle 20). Les sites de la liste reçoivent une **page de blocage explicite** (BlockPage_00), plus compréhensible pour l'utilisateur qu'une coupure silencieuse.

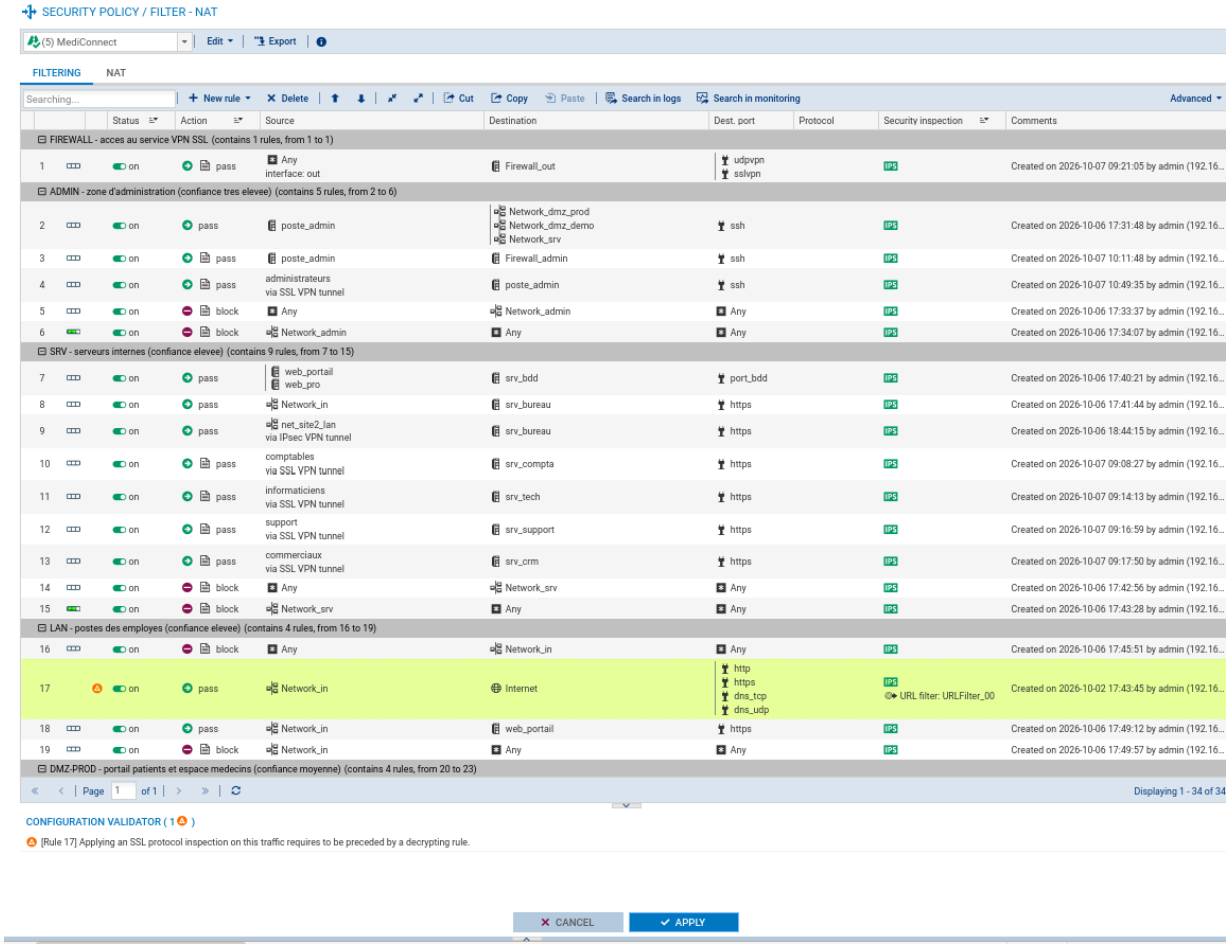
Syntaxe : une entrée porte sur l'URL complète, chemin compris (neverssl.com/* et *.neverssl.com/*). La première version sans « /* » ne bloquait rien ; l'erreur a été détectée grâce au journal Web, qui montrait la requête autorisée (section 15).



Capture 75a — Catégorie d'URL personnalisée (entrées corrigées ensuite en neverssl.com/ et *.neverssl.com/*)*



Capture 76 — Profil de filtrage d'URL : liste noire bloquée avec page d'information, le reste autorisé



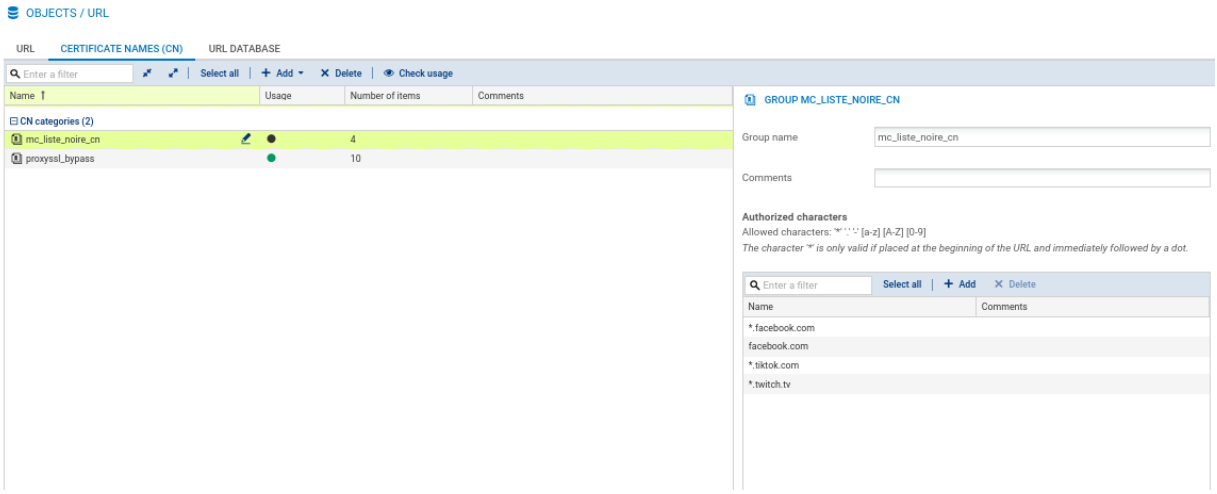
Capture 78 — Filtrage d'URL activé sur la règle de navigation du LAN

10.3 Trafic HTTPS : contrôle sans déchiffrement

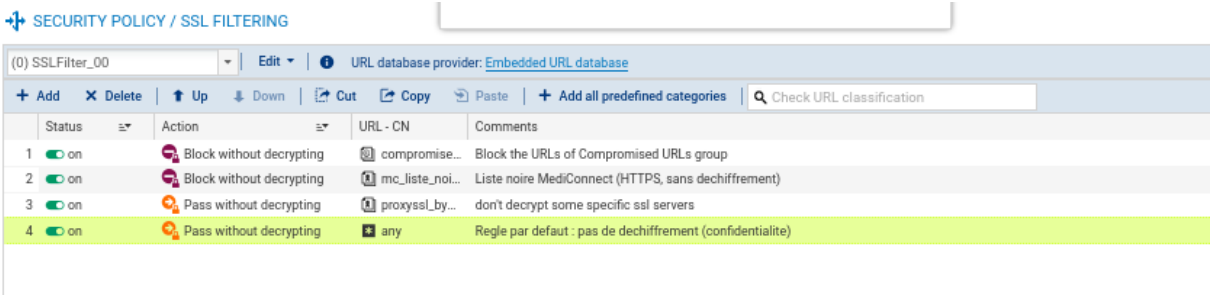
Choix de conception : le trafic HTTPS des employés n'est **pas déchiffré**. Déchiffrer reviendrait à intercepter (« homme du milieu ») des connexions bancaires, médicales ou personnelles des salariés ; dans une entreprise de santé, cela pose un problème de confidentialité et de conformité au RGPD, et impose de déployer le certificat du pare-feu sur chaque poste.

Un profil de **filtrage SSL** a d'abord été configuré pour bloquer la liste noire **sur le nom du site** (SNI / nom du certificat) sans déchiffrer le reste. SNS impose pour cela une règle d'action « decrypt » qui envoie le trafic au proxy SSL. Une fois activée, cette règle **bloquait tout le HTTPS** du LAN : le proxy dépend du moteur de classification des URL, qui ne démarre pas sans licence (« URLFiltering Licence expired » dans le journal système, capture 86). La règle a été **désactivée** et remplacée par un **blocage par service web** : SNS reconnaît 639 services par leurs adresses IP (Facebook, Twitch, Instagram…), ce qui fonctionne sans proxy ni déchiffrement.

Le test le confirme : Facebook est bloqué, Google est autorisé et son certificat est bien émis par **Google Trust Services**, et non par le pare-feu, ce qui prouve l'absence de déchiffrement (capture 80).



Capture 75b — Liste noire de noms de certificat (CN) pour le filtrage SSL



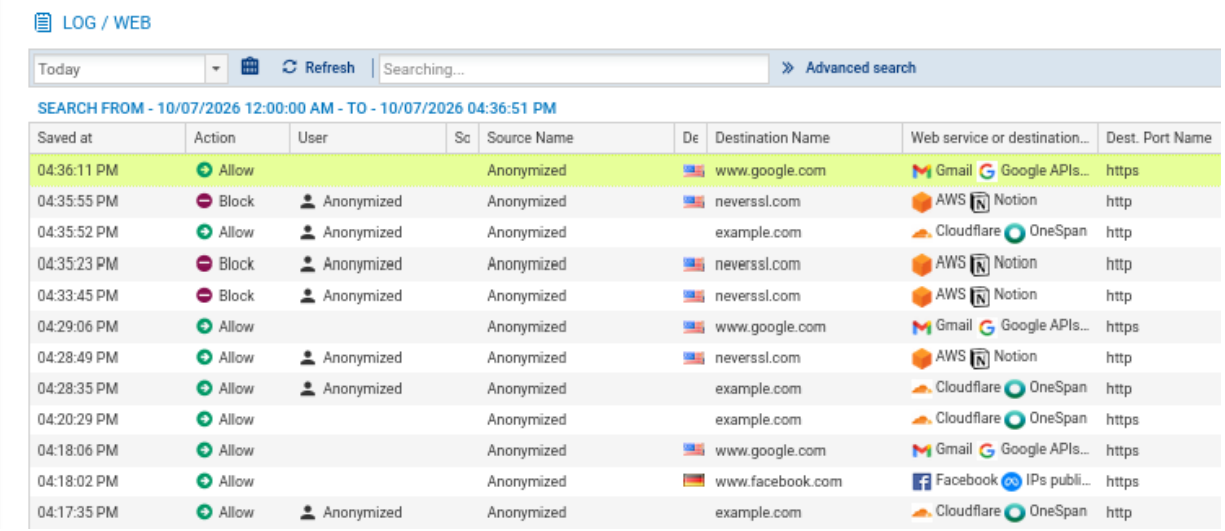
Capture 77 — Profil de filtrage SSL : blocage sur le nom du site, aucun déchiffrement



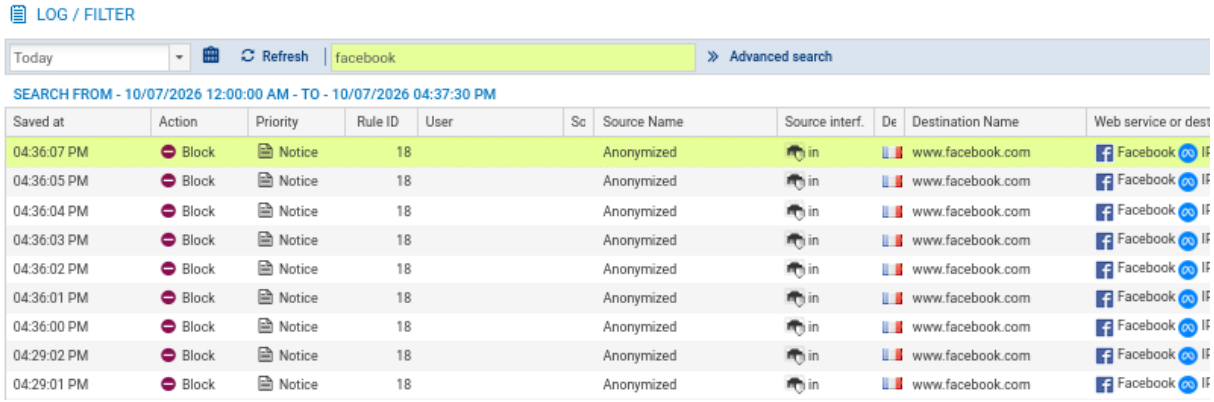
Capture 79 — Bloc LAN final : déchiffrement désactivé, blocage par service web, navigation avec filtrage d'URL



Capture 80 — Tests depuis le LAN : HTTP et HTTPS autorisés ; neverssl et Facebook bloqués ; certificat Google d'origine



Capture 81 — Journal Web : neverssl autorisé avant la correction de syntaxe, bloqué après



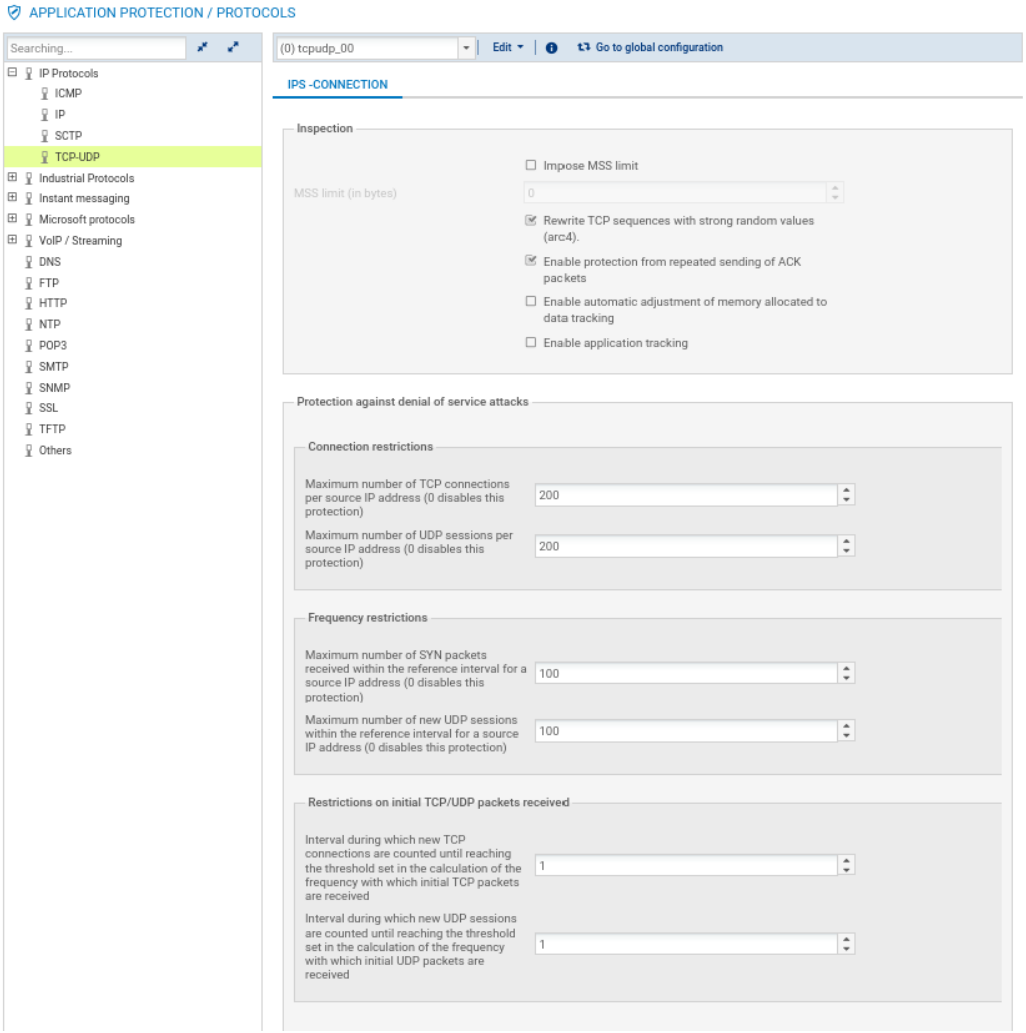
Capture 82 — Journal Filter : chaque tentative vers Facebook bloquée par la règle de service web

10.4 Protection contre le déni de service

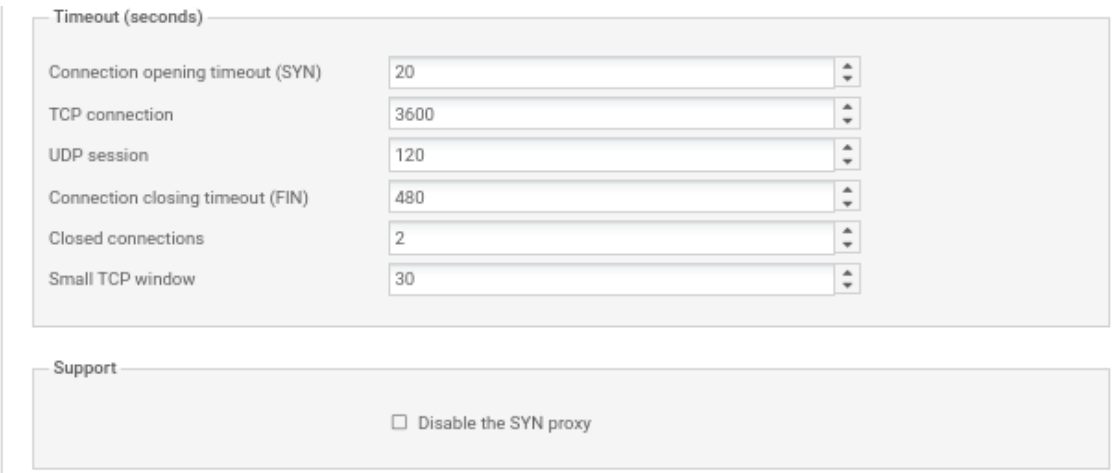
Mesure	Réglage	Menace couverte
Proxy SYN	Actif (non désactivé)	Inondation SYN : le pare-feu termine lui-même la poignée de main TCP et ne transmet au serveur que les connexions complètes.
Délai des connexions à moitié ouvertes	20 s	Libère rapidement la mémoire occupée par les connexions incomplètes.
Connexions TCP par adresse source	200 au maximum	Épuisement des ressources par un client isolé.
Sessions UDP par adresse source	200 au maximum	Inondation UDP.
Paquets SYN par adresse source	100 par seconde	Inondation SYN depuis une adresse.
Nouvelles sessions UDP par source	100 par seconde	Inondation UDP.

Mesure	Réglage	Menace couverte
Numéros de séquence TCP	Réécrits avec des valeurs aléatoires (arc4)	Prédiction de séquence et usurpation (attaque de Mitnick, cours 1).
Répétition de paquets ACK	Protection active	Abus de paquets ACK.

Choix des seuils. Les limites sont appliquées **par adresse source** et non globalement : un attaquant isolé est freiné sans pénaliser les autres patients. Elles sont volontairement larges, car plusieurs patients peuvent partager une même adresse (box familiale, NAT d'opérateur mobile) et un navigateur ouvre plusieurs connexions par page (principe de participation des utilisateurs). En production, elles seraient ajustées à partir des statistiques réelles. Un test de charge n'a pas été réalisé : la licence de la machine virtuelle limite déjà le nombre de connexions et un tel test aurait bloqué tout le laboratoire (section 16).



Capture 83a — Profil TCP-UDP : séquences aléatoires, limites de connexions et de paquets SYN par source



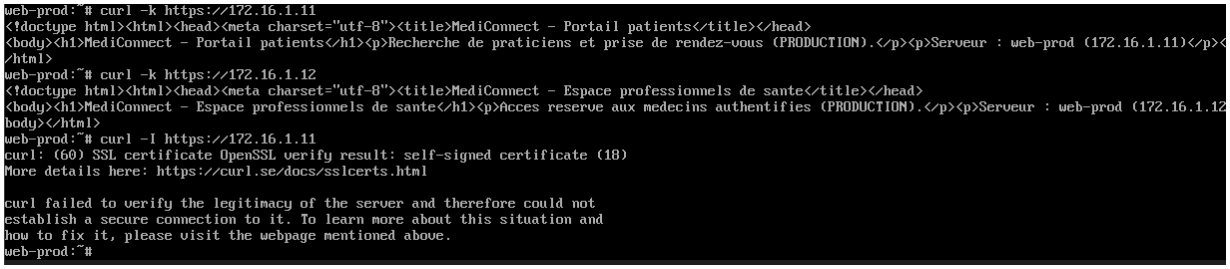
Capture 83b — Configuration globale : proxy SYN actif, délai de 20 s pour les connexions à moitié ouvertes

11. Protection de la DMZ

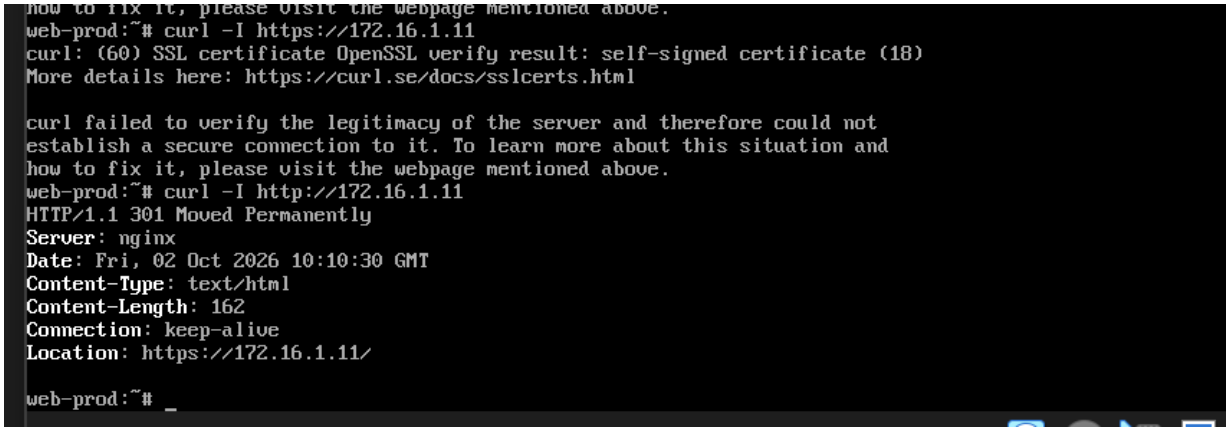
La DMZ-PROD est la zone exposée à Internet. Sa protection repose sur l'idée du cours : c'est une zone **« perdable »**, dont la compromission ne doit pas entraîner celle du système d'information.

11.1 Exposition minimale, en HTTPS uniquement

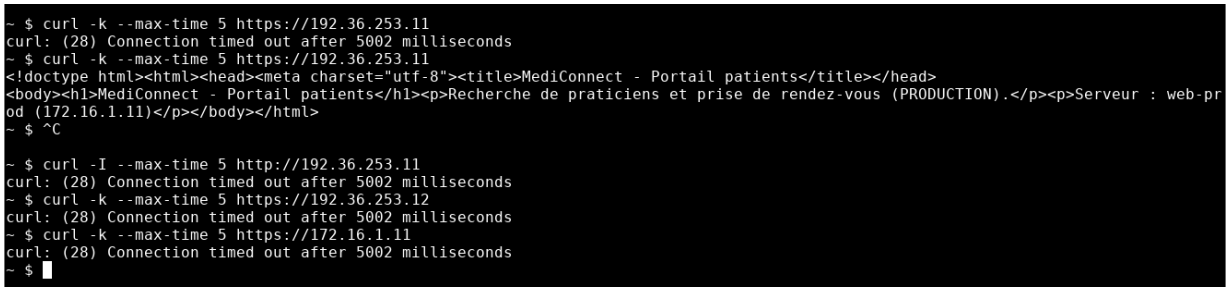
- Seul le **port 443** de deux adresses publiques est publié (NAT statique par port) ; aucun autre service de la DMZ n'est joignable depuis Internet (règle 25).
- Le serveur web n'offre **aucune page en clair** : une requête HTTP reçoit une redirection 301 vers HTTPS, et l'en-tête **HSTS** demande au navigateur de n'utiliser que HTTPS par la suite. Le port 80 n'étant pas publié, une requête HTTP depuis Internet n'atteint même pas le serveur.
- Le chiffrement est limité à **TLS 1.2 et 1.3**.
- L'**IPS**, le **proxy SYN** et les **limites par source** protègent les services publiés.



Capture 6a — web-prod : portail patients (172.16.1.11) et espace médecins (172.16.1.12) en HTTPS



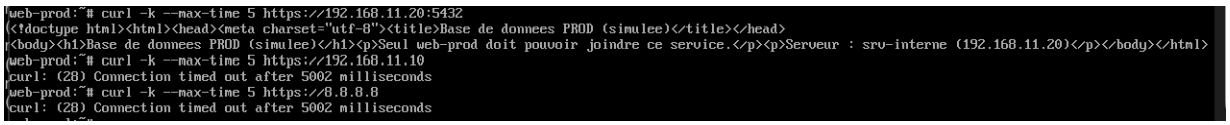
Capture 6b — web-prod : redirection HTTP 301 vers HTTPS, aucune page servie en clair



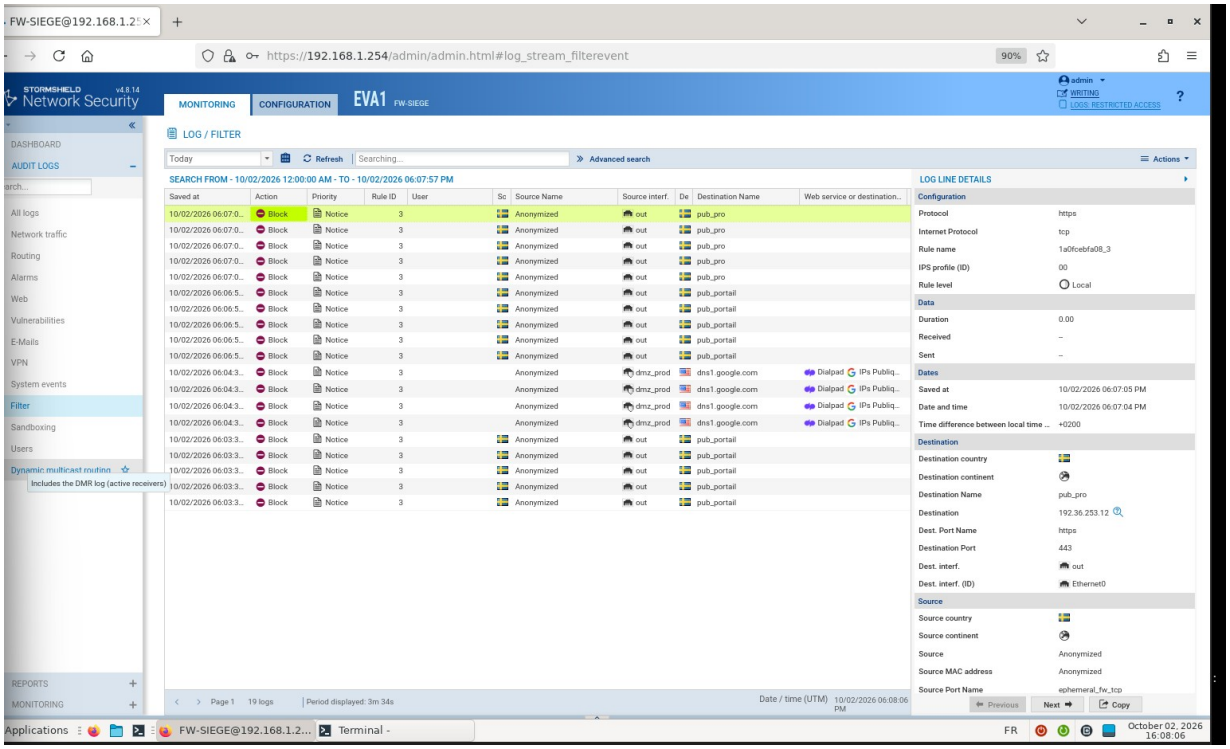
Capture 20 — Tests depuis Internet : portail HTTPS accessible ; HTTP, espace médecins non authentifié et accès direct à la DMZ bloqués

11.2 Un seul flux de la DMZ vers l'intérieur

Le serveur web n'atteint que la **base PROD, sur son seul port** (règle 7). Il ne peut joindre ni le CRM, ni le LAN, ni Internet (règle 26). Si le portail était compromis, l'attaquant ne pourrait pas rebondir vers le reste du SI ; il ne trouverait qu'un port de base de données, protégé en production par l'authentification de la base.



Capture 24 — Depuis web-prod : seule la base PROD est joignable ; CRM et Internet bloqués



Capture 21 — Journal : web-prod qui tente de joindre Internet est bloqué

11.3 Aucune initiative depuis les zones internes

Ni la DMZ, ni la zone SRV, ni la zone ADMIN n'ont de NAT sortant ni de règle vers Internet. Les journaux montrent que leurs tentatives (par exemple les requêtes DNS vers 8.8.8.8 restées dans la configuration des serveurs) sont systématiquement bloquées.



Capture 26 — srv-interne n'initie aucune connexion vers Internet

11.4 Séparation stricte entre production et démonstration

- **Interface, réseau et serveur distincts** : la DEMO (172.17.1.0/24) n'a rien en commun avec la PROD (172.16.1.0/24).
- **Aucune règle** DEMO → PROD ni DEMO → serveurs internes : la règle 29 bloque toute sortie de la DEMO.
- **Données fictives uniquement** sur la plateforme de démonstration.
- **Seuls les commerciaux** y accèdent, par le VPN SSL (règle 27) ; le VPN ne leur donne aucune route vers la PROD.



Capture 7 — Plateforme DEMO : données fictives uniquement



Capture 25 — Depuis web-demo : portail PROD, base PROD et Internet inaccessibles

12. Sécurisation de l'administration

Le sujet impose que les **flux d'administration soient séparés des flux utilisateurs** et qu'**un utilisateur du LAN ne puisse pas administrer** les équipements. Le poste d'administration est aussi le « maillon le plus faible » cité en cours : qui le compromet contrôle tout. Les mesures suivantes ont été appliquées. Elles couvrent les pare-feux, les passerelles VPN (portées par les pare-feux), les serveurs (SSH depuis le bastion, règle 2) et, par extension, tout routeur ou équipement de sécurité futur, qui serait placé sous la même règle (SSH uniquement depuis la zone ADMIN).

Mesure	Mise en œuvre	Preuve
Zone d'administration dédiée	Zone ADMIN (192.168.91.0/24) sur sa propre interface, sans accès Internet (règle 6).	Captures 11, 73
Interface web réservée à la zone ADMIN	Hôtes autorisés à administrer : Network_admin uniquement (Network_internals retiré).	Capture 61
SSH réservé au poste d'administration	Règle implicite SSH désactivée ; règle explicite n° 3 poste_admin → Firewall_admin, journalisée avec alarme.	Captures 62, 65a
Comptes nominatifs et droits différenciés	Groupe administrateurs : tous les droits ; groupe informaticiens : lecture seule ; compte admin conservé comme compte de secours.	Captures 66, 67, 68
Authentification des administrateurs	Règle d'authentification limitée à l'interface admin.	Capture 69
Administration à distance par bastion	VPN SSL (groupe administrateurs) → SSH sur le bastion avec un compte nominatif → SSH vers le pare-feu. Jamais d'accès direct à l'interface depuis le VPN.	Captures 70, 71
Protection contre la force brute	3 tentatives, puis blocage d'une minute.	Capture 61
Déconnexion automatique	Session d'administration fermée après 30 minutes d'inactivité.	Capture 61
Un seul administrateur en écriture	SNS refuse un second accès en écriture simultané (intégrité de la configuration).	Capture D3
Traçabilité	Chaque connexion SSH d'administration déclenche une alarme mineure ; toute tentative vers la zone ADMIN est bloquée et journalisée.	Captures 87, 87b, 88

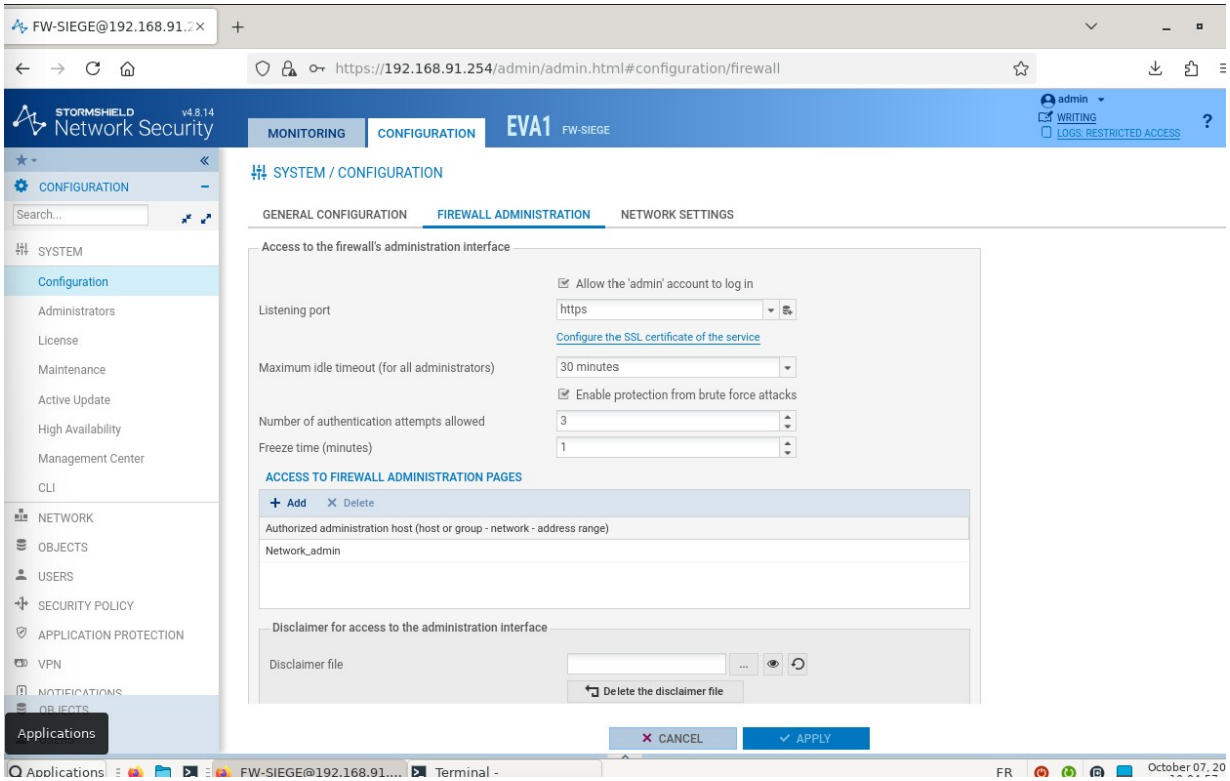
12.1 Pourquoi un bastion plutôt que l'accès direct depuis le VPN

La liste des hôtes autorisés à administrer est fondée sur l'**adresse IP**, pas sur l'identité. Y ajouter le réseau du VPN SSL aurait permis à **n'importe quel utilisateur VPN** (un comptable, par exemple) d'atteindre la page de connexion d'administration. Avec le bastion, le filtrage par **groupe** s'applique : seuls les administrateurs atteignent le poste d'administration (règle 4), et c'est de là qu'ils administrent. Le pare-feu voit toujours arriver l'administration depuis 192.168.91.2 (« Last login … from 192.168.91.2 », capture 71). C'est la logique de **bastion d'administration** recommandée par l'ANSSI.

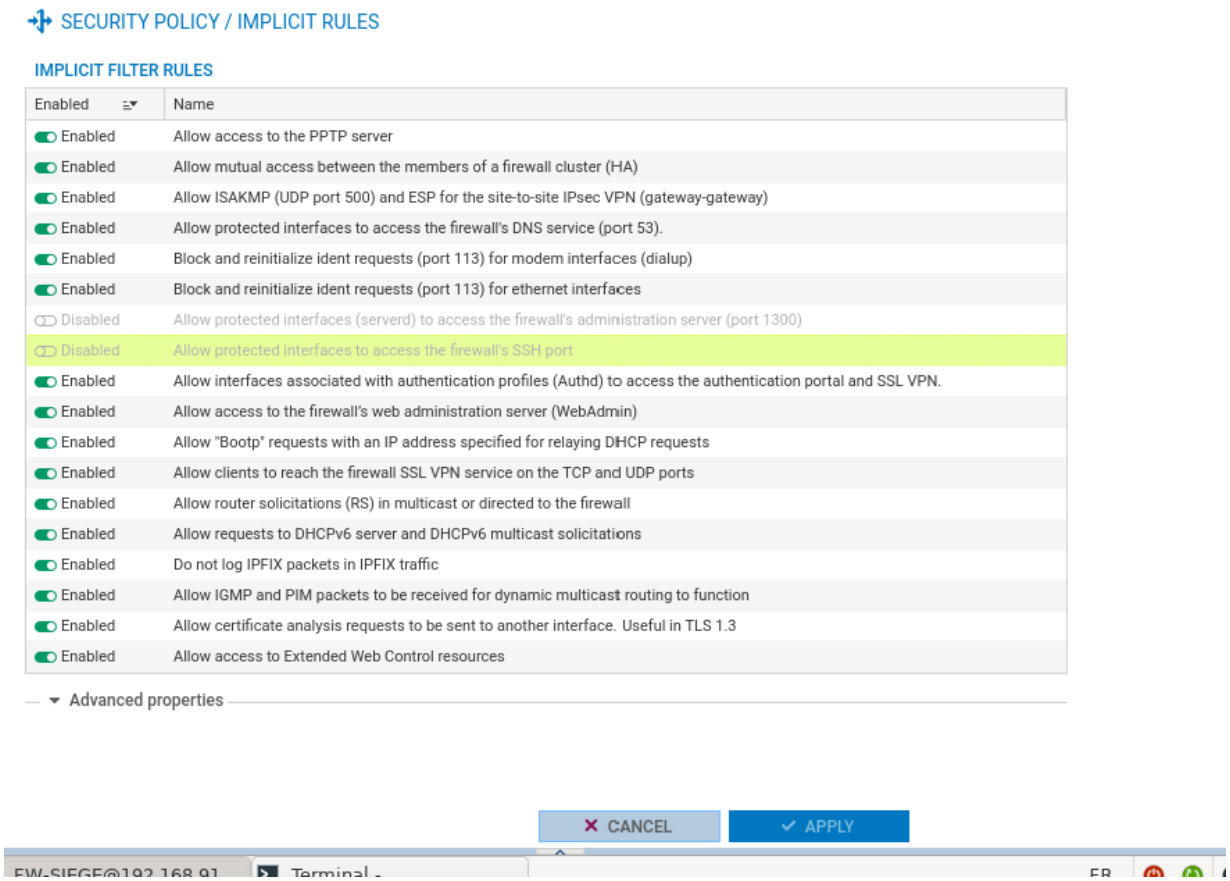
12.2 Validation

Depuis	SSH vers le pare-feu	Interface web d'administration	Preuve
Internet	Aucune réponse (bloqué)	Refusée (403)	Capture 65b
LAN du siège	Aucune réponse (bloqué par la règle 17)	Refusée (403)	Captures 63, 65b
Zone ADMIN (poste_admin)	Accepté	Acceptée	Captures 61, 64
VPN d'un administrateur	Via le bastion uniquement : accepté	—	Capture 71
VPN d'un comptable	Bastion inaccessible (bloqué par la règle 5)	—	Captures 72, 88
LAN du site 2 → FW-SITE2	Aucune réponse (règle implicite désactivée)	Autorisée depuis son LAN (limite)	Capture 92

Ce sont les **tests négatifs** qui ont révélé la règle implicite SSH : avant sa désactivation, un poste du LAN obtenait l'invite de mot de passe du pare-feu. Sans ce test, l'exigence n'aurait été satisfaite qu'en apparence.



Capture 61 — Hôtes autorisés : Network_admin seul ; délai d'inactivité de 30 min ; protection contre la force brute



Capture 62 — Règle implicite d'accès SSH au pare-feu désactivée

```
/home/user/Downloads # ssh -o ConnectTimeout=5 admin@192.168.1.254
ssh: connect to host 192.168.1.254 port 22: Operation timed out
/home/user/Downloads # curl -k -s -o /dev/null -w "%{http_code}\n" --max-time 5 https://192.168.1.254/admin/
403
```

Capture 63 — Depuis le LAN : SSH sans réponse, interface web refusée (403)

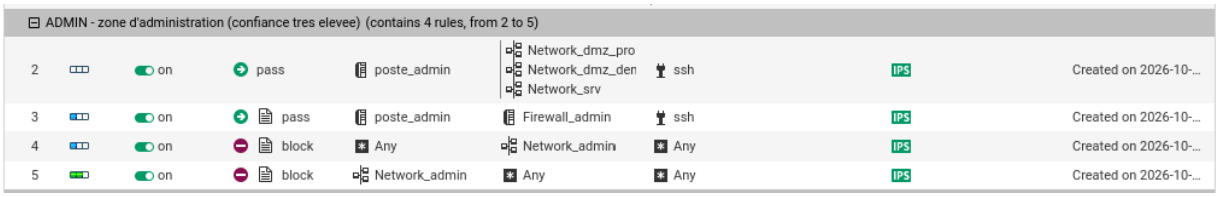
```
~ $ ssh -o ConnectTimeout=5 admin@192.168.91.254
The authenticity of host '192.168.91.254 (192.168.91.254)' can't be established.
ECDSA key fingerprint is SHA256:xy1CvRsV9k3Sh7ZcB59MDy9oiRoDSxhdlC9m6iV1eyA.
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:4: 192.168.1.254
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.91.254' (ECDSA) to the list of known hosts.
(admin@192.168.91.254) Password:
VMSNSX09K0639A9: FW EVA1 (XL / EUROPE)
Firewall software version 4.8.14 VM-RELEASE
System Name: FW-SIEGE

port       name       NS-BSD   state  addressIPv4         addressIPv6
   1        out          em0      up  192.36.253.10/24
   2         in          em1      up  192.168.1.254/24
   3   dmz_prod          em2      up  172.16.1.254/24
   4   dmz_demo          em3      up  172.17.1.254/24
   5        srv          em4      up  192.168.11.254/24
   6      admin          em5      up  192.168.91.254/24

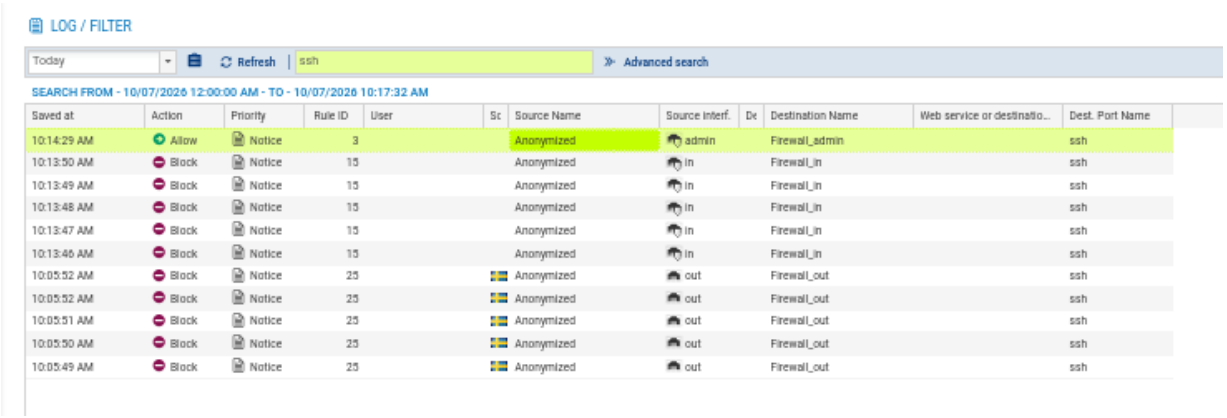
FW-SIEGE-VMSNSX09K0639A9>exit
logout

Connection to 192.168.91.254 closed.
```

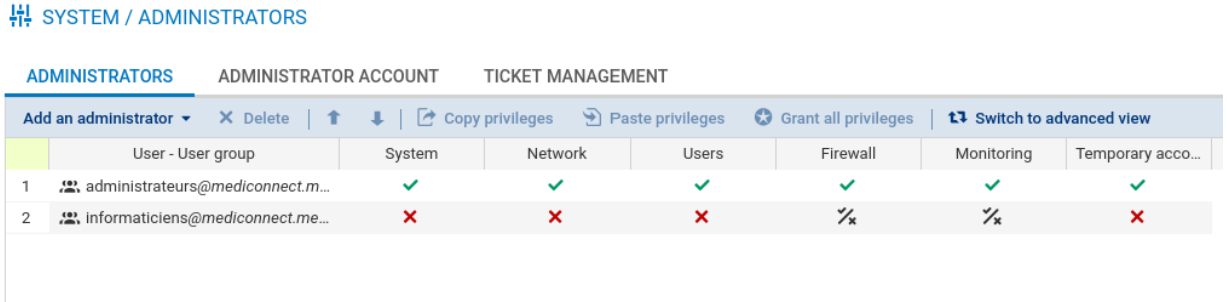
Capture 64 — Depuis la zone ADMIN : SSH sur le pare-feu accepté



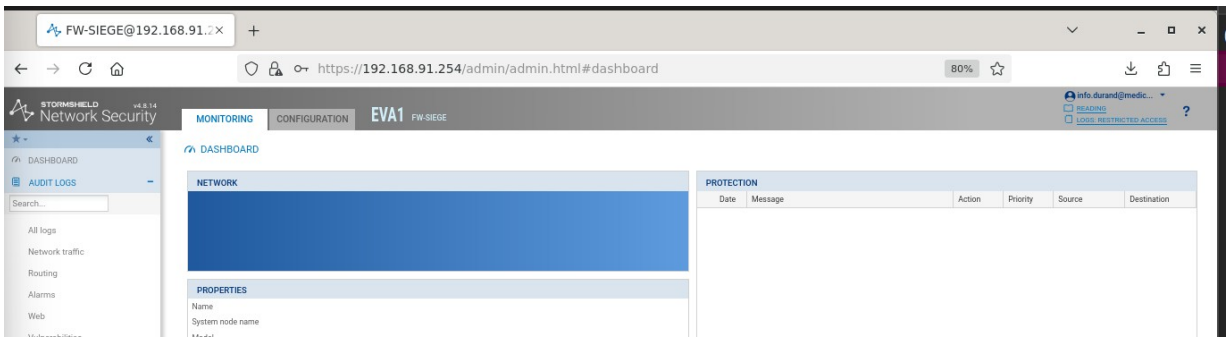
Capture 65a — Règle explicite : SSH vers le pare-feu uniquement depuis poste_admin



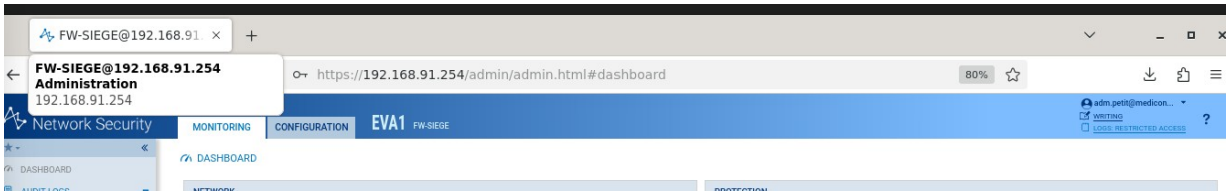
Capture 65b — Journal : SSH vers le pare-feu bloqué depuis Internet et le LAN, autorisé depuis ADMIN



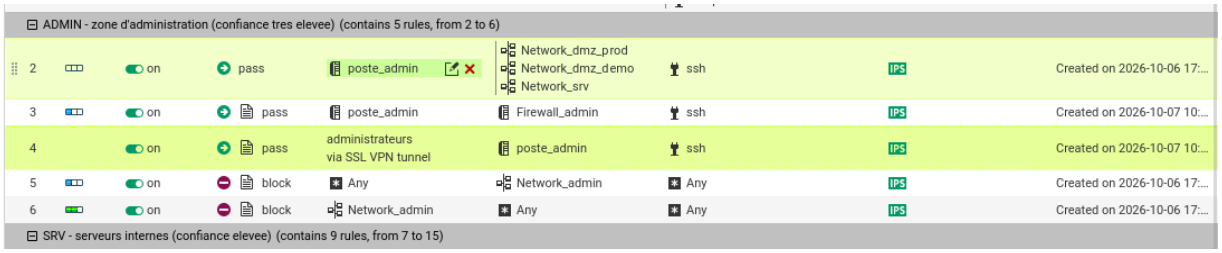
Capture 66 — Administrateurs nominatifs : tous les droits pour les administrateurs, lecture seule pour les informaticiens



Capture 67 — info.durand connecté en lecture seule (READING)



Capture 68 — adm.petit connecté en écriture (WRITING)



Capture 70 — Bloc ADMIN : les administrateurs en VPN n'atteignent que le bastion

```
~ $ ip route
default via 192.36.253.1 dev eth0
172.17.1.0/24 via 172.30.1.5 dev tun0
172.30.1.1 via 172.30.1.5 dev tun0
172.30.1.5 dev tun0 proto kernel scope link src 172.30.1.6
192.36.253.0/24 dev eth0 proto kernel scope link src 192.36.253.100
192.168.11.0/24 via 172.30.1.5 dev tun0
192.168.91.2 via 172.30.1.5 dev tun0
~ $ ssh admpetit@192.168.91.2
The authenticity of host '192.168.91.2 (192.168.91.2)' can't be established.
ED25519 key fingerprint is SHA256:c9yWZjDro1yAarxpP1hbRi6G4VokMrk1SrPM+CQb7R8.
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:1: 127.0.0.1
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.91.2' (ED25519) to the list of known hosts.
admpetit@192.168.91.2's password:
Welcome to Alpine!

The Alpine Wiki contains a large amount of how-to guides and general
information about administrating Alpine systems.
See <https://wiki.alpinelinux.org/>.

You can setup the system with the command: setup-alpine

You may change this message by editing /etc/motd.

alpine:~$ ssh admin@192.168.91.254
The authenticity of host '192.168.91.254 (192.168.91.254)' can't be established.
ECDSA key fingerprint is SHA256:xy1CvRsV9k3Sh7ZcB59MDy9oiRoDSxhdlC9m6iV1eyA.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.91.254' (ECDSA) to the list of known hosts.
(admin@192.168.91.254) Password:
Last login: Wed Oct  7 10:14:44 2026 from 192.168.91.2
VMSNSX09K0639A9: FW EVA1 (XL / EUROPE)
Firewall software version 4.8.14 VM-RELEASE
System Name: FW-SIEGE

port       name       NS-BSD   state  addressIPv4         addressIPv6
   1        out          em0      up  192.36.253.10/24
   2         in          em1      up  192.168.1.254/24
   3   dmz_prod          em2      up  172.16.1.254/24
   4   dmz_demo          em3      up  172.17.1.254/24
   5        srv          em4      up  192.168.11.254/24
   6      admin          em5      up  192.168.91.254/24

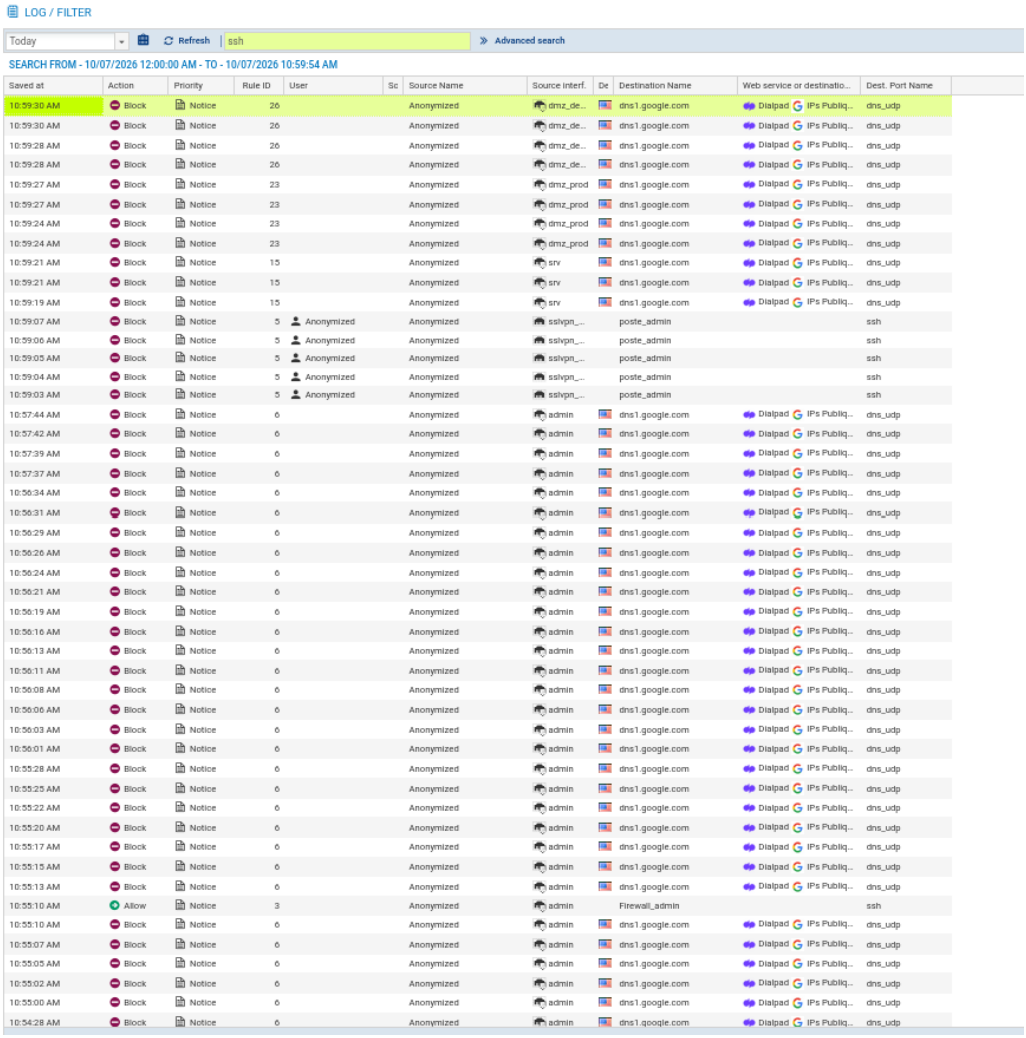
FW-SIEGE-VMSNSX09K0639A9>exit
logout

Connection to 192.168.91.254 closed.
alpine:~$
```

Capture 71 — Administration à distance : VPN, puis bastion avec un compte nominatif, puis pare-feu

```
~ $ ip route
default via 192.36.253.1 dev eth0
172.17.1.0/24 via 172.30.1.5 dev tun0
172.30.1.1 via 172.30.1.5 dev tun0
172.30.1.5 dev tun0 proto kernel scope link src 172.30.1.6
192.36.253.0/24 dev eth0 proto kernel scope link src 192.36.253.100
192.168.11.0/24 via 172.30.1.5 dev tun0
192.168.91.2 via 172.30.1.5 dev tun0
~ $ ssh -o ConnectTimeout=5 admpetit@192.168.91.2
ssh: connect to host 192.168.91.2 port 22: Operation timed out
~ $
```

Capture 72 — Comptable en VPN : même route vers le bastion, mais SSH bloqué par le filtrage par groupe



Capture 73 — Journal : rebond du bastion vers le pare-feu autorisé, comptable bloqué

13. Stratégie de journalisation

La journalisation sert trois objectifs : **prouver** que la politique est appliquée (tests), **détecter** les comportements anormaux (alarmes) et **enquêter** après un incident en sachant qui a fait quoi et quand (critère Preuve).

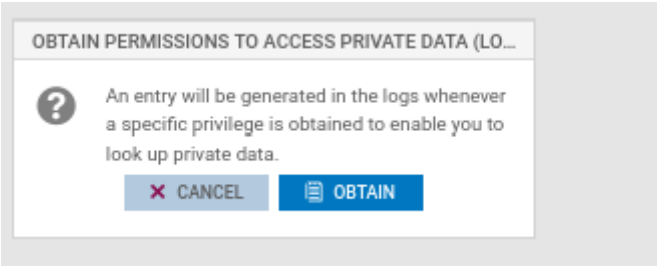
13.1 Ce qui est journalisé

Journal SNS	Contenu	Usage dans le projet
Filter	Décisions des règles journalisées : action, règle, source, destination, port, utilisateur	Validation de chaque test ; attribution des blocages (captures 21, 27, 58, 65b, 82, 88, 99)
Users	Authentifications réussies et échouées, méthode, TOTP, durée de session	Preuve du MFA (capture 37) ; échecs « bad password » (capture 59)
VPN	Création et destruction des tunnels IPsec et SSL, utilisateur, adresses	Qui s'est connecté, quand et depuis où (captures 60, 85)
Web	Requêtes HTTP et décision du filtrage d'URL	Preuve du filtrage d'URL (capture 81)
Alarms	Alarmes IPS et alarmes déclenchées par les règles	Détection (captures 74, 87b)
System events	Événements du pare-feu : licences, services, accès aux données privées	Diagnostic (capture 86)

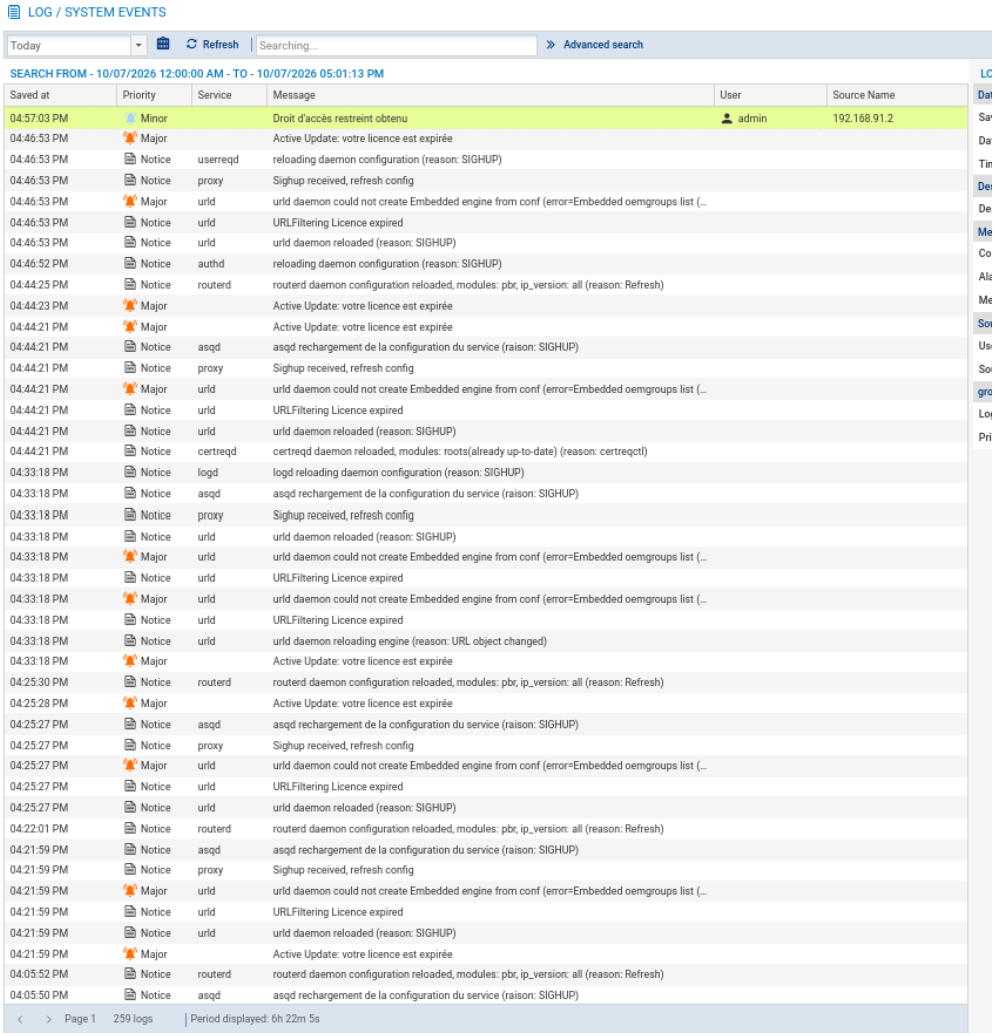
Niveaux de journalisation choisis : toutes les règles « block » et les règles « pass » par identité sont journalisées dans le journal de filtrage ; la règle finale « block any » l'est aussi, pour révéler toute erreur de politique ; les accès d'administration autorisés déclenchent une **alarme mineure** (règles 3 et 4), les tentatives vers la zone ADMIN une **alarme majeure** (règle 5).

13.2 Protection des données personnelles des journaux

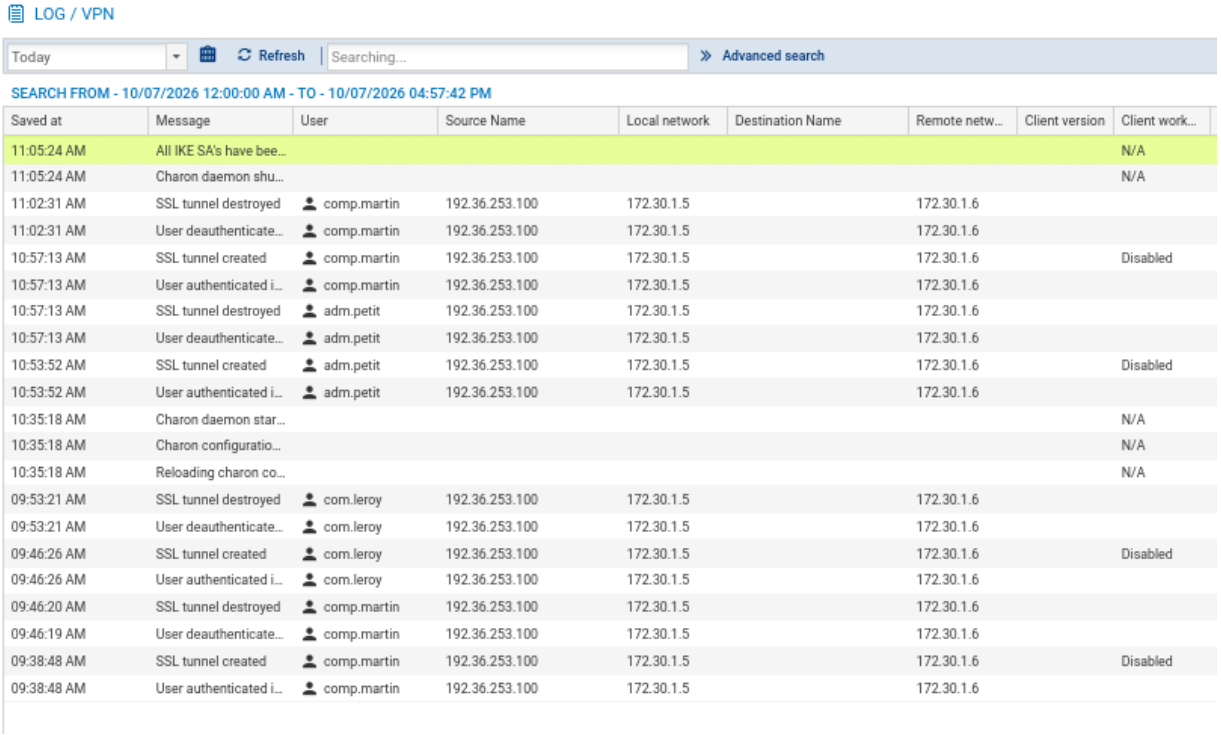
Les journaux contiennent des données personnelles (noms, adresses, horaires de connexion). Par défaut, SNS les **anonymise** ; ce réglage a été conservé (« Logs : restricted access »). Pour une enquête, un administrateur peut obtenir l'accès complet ; **cette ouverture est elle-même journalisée** (« Droit d'accès restreint obtenu », avec le compte et le poste utilisés). On applique ainsi au journal le principe de responsabilité du RGPD : les administrateurs aussi sont tracés. SNS permet aussi de délivrer cet accès de façon temporaire par ticket à un administrateur qui n'a pas ce droit en permanence.



Capture 84 — Demande d'accès aux données privées des journaux : l'ouverture est tracée



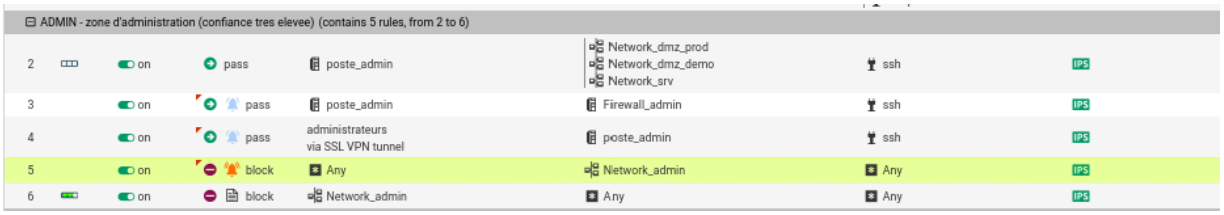
Capture 86 — Journal système : accès aux données privées tracé (admin, depuis 192.168.91.2) et licences expirées



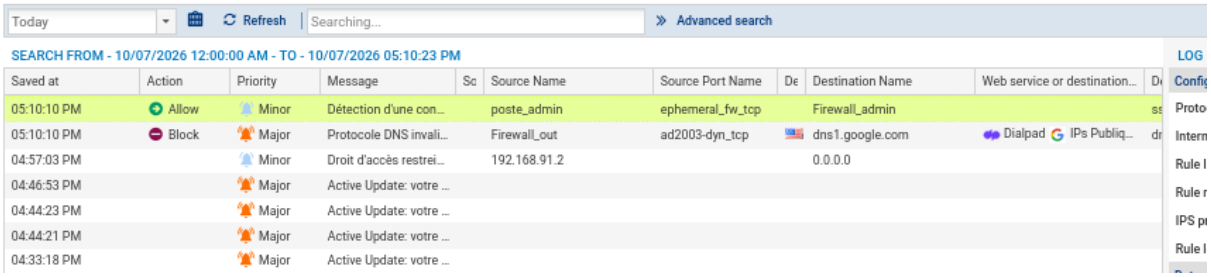
Capture 85 — Journal VPN en accès complet : chaque tunnel est attribué à un utilisateur nominatif

13.3 Alarmes

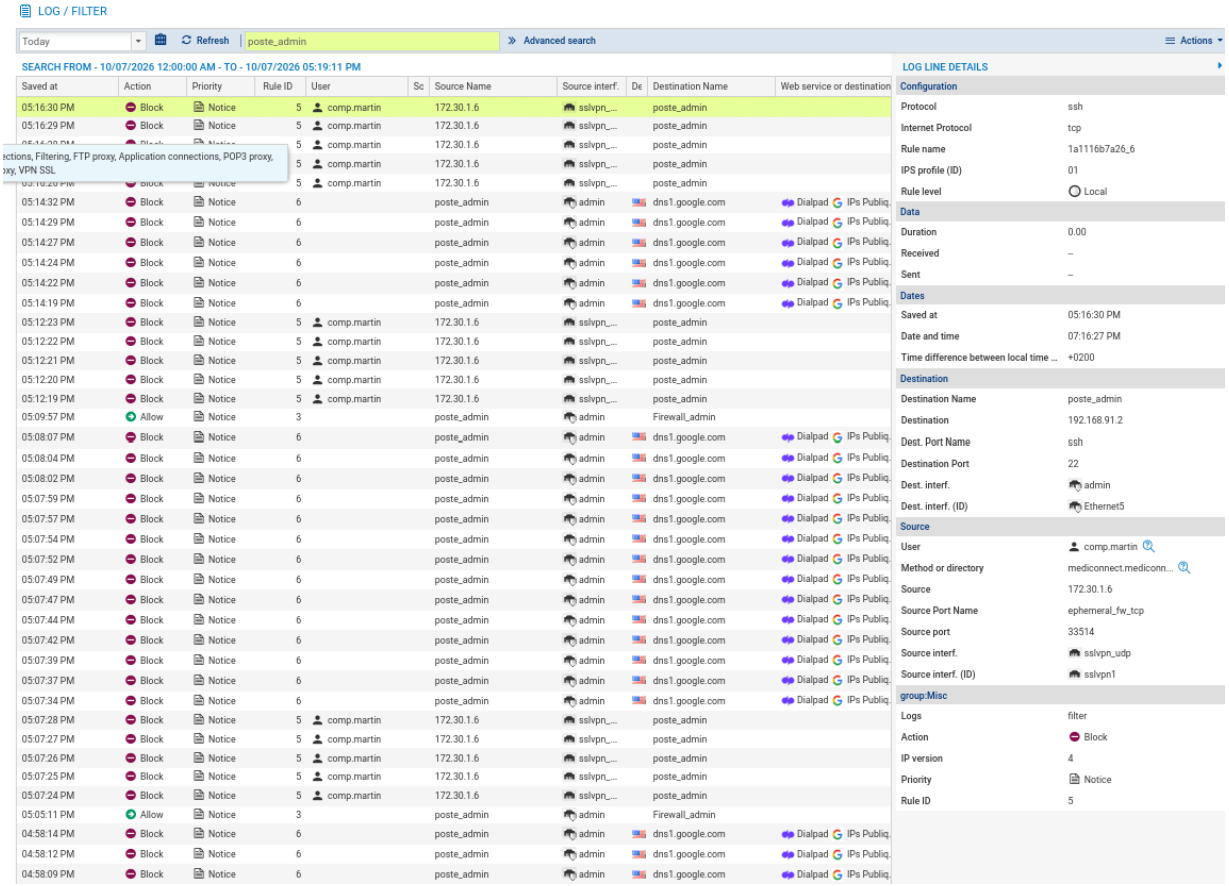
L'alarme mineure de la règle 3 a été vérifiée : chaque connexion SSH d'administration au pare-feu apparaît dans le journal des alarmes. L'alarme majeure de la règle 5 est correctement configurée (règle et profils IPS vérifiés), mais elle n'est pas remontée dans le journal des alarmes lors du test. La tentative reste néanmoins **bloquée, journalisée et attribuée à l'utilisateur** dans le journal de filtrage (capture 88). Ce point est documenté comme limite constatée.



Capture 87 — Alarmes mineures (règles 3 et 4) et majeure (règle 5) sur le bloc ADMIN



Capture 87b — Alarme mineure déclenchée par une connexion SSH d'administration

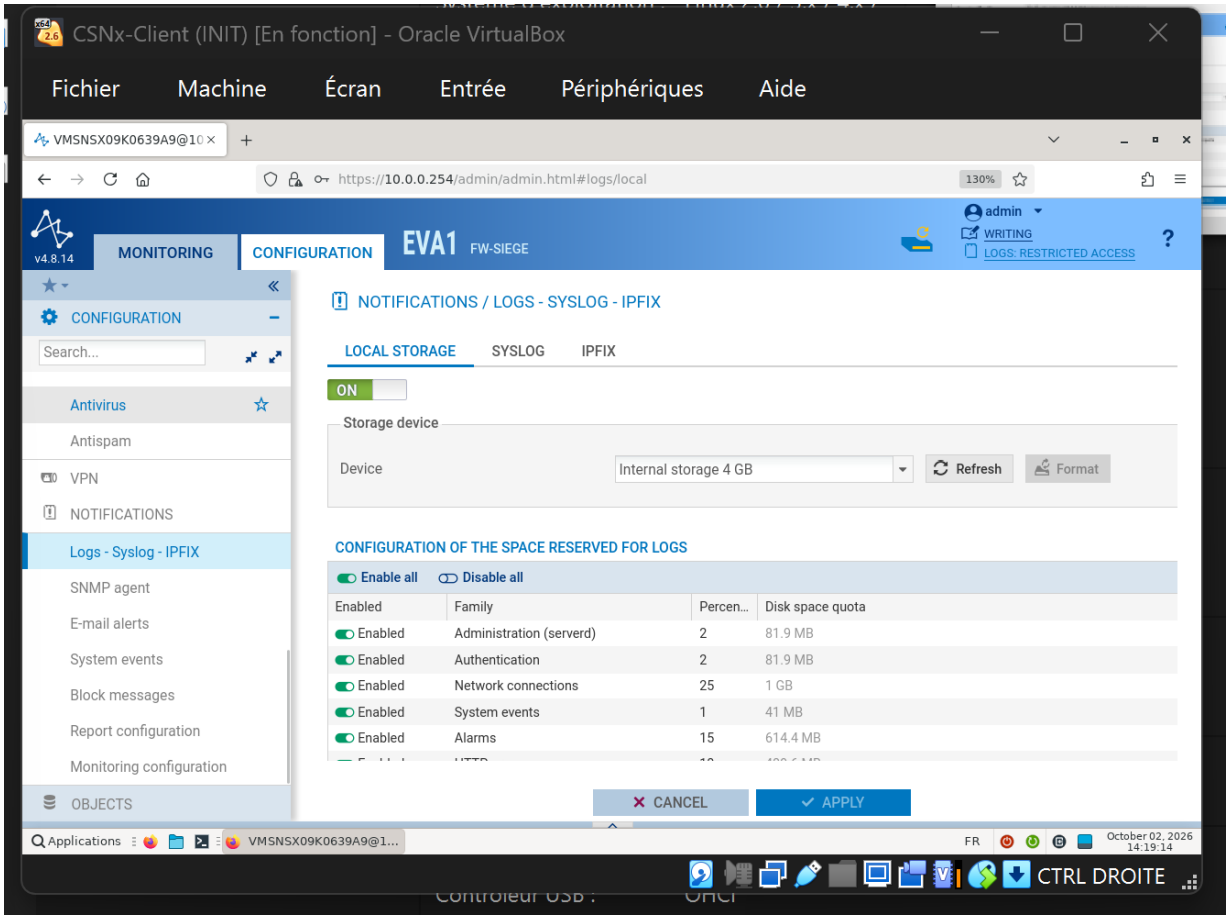


Capture 88 — Journal Filter : tentatives de comp.martin vers la zone ADMIN bloquées et attribuées

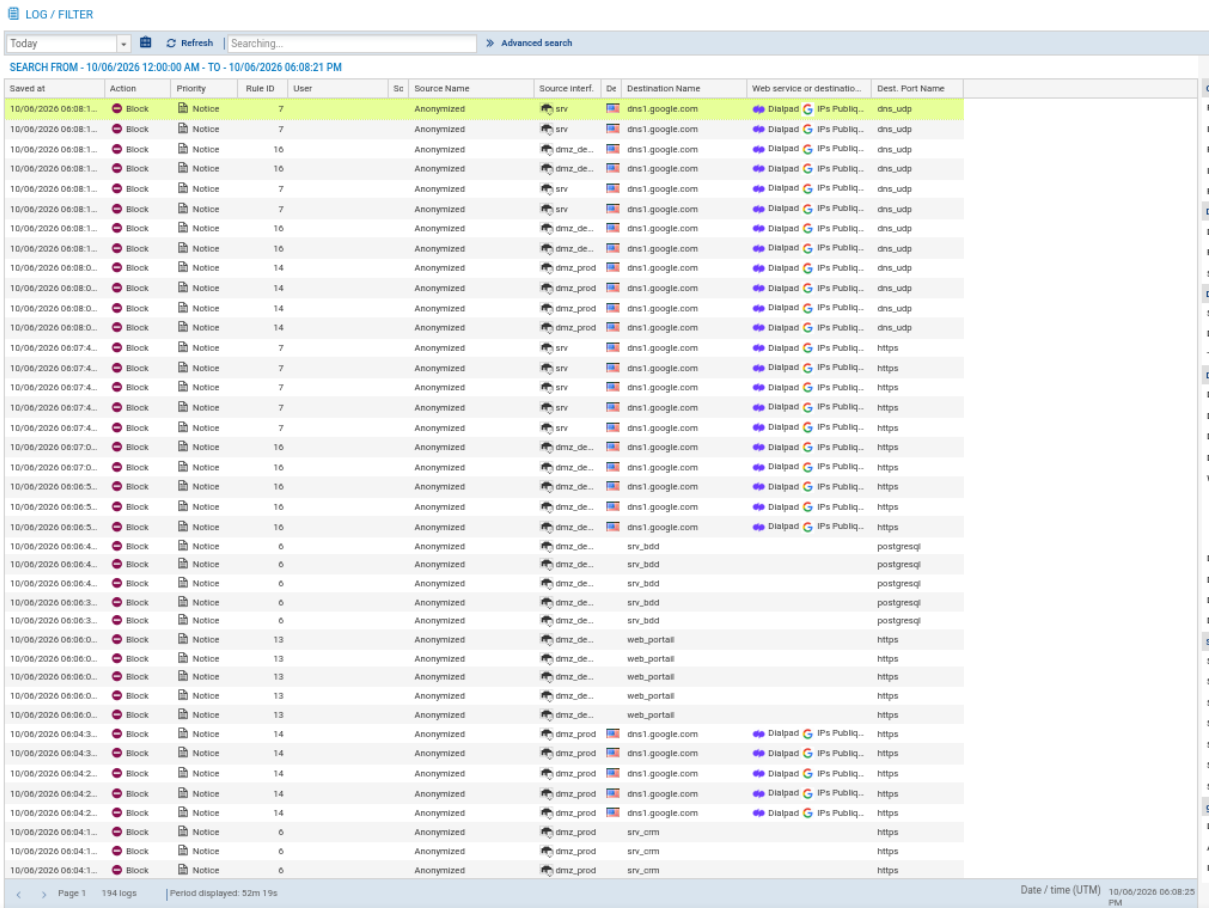
13.4 Stockage, horodatage, supervision et sauvegardes

- **Stockage local** activé pour toutes les familles de journaux, avec 4 Go réservés (capture 10).

- **Horodatage fiable** : fuseau Europe/Paris et synchronisation NTP. Sans heure exacte, on ne peut pas corréler les journaux de plusieurs équipements, et le TOTP ne fonctionne pas.
- **Supervision** en temps réel des tunnels IPsec et SSL et des utilisateurs authentifiés (captures 47, 57).
- **Sauvegarde de la configuration** des pare-feux à la fin de chaque étape, et **instantanés** VirtualBox ; liste en annexe B.
- **Conservation :** en production, une durée de conservation serait fixée (de l'ordre de 6 mois à 1 an, selon les recommandations de la CNIL), et les journaux seraient envoyés vers un **serveur syslog / SIEM externe**, pour qu'un attaquant ayant pris le contrôle du pare-feu ne puisse pas effacer ses traces (section 16).



Capture 10 — Stockage local des journaux activé pour toutes les familles (4 Go)



Capture 27 — Journal Filter : chaque blocage attribué à sa règle (étape 7)

14. Tests réalisés

14.1 Méthode

- **Chaque profil** du sujet a été joué depuis l'endroit où il se trouve réellement (Internet, LAN, site 2, VPN, zone ADMIN, serveurs).
- **Tests positifs et négatifs** : ce qui doit passer passe, et ce qui doit être bloqué l'est. Les tests négatifs sont les plus importants, car ils prouvent l'absence d'accès.
- **Outils :** curl (code de retour HTTP ; « 000 » ou « (28) » = connexion abandonnée, donc bloquée par le pare-feu), ssh, ping, openvpn, journaux et supervision du pare-feu.
- **Double preuve** : le résultat côté client, puis la ligne correspondante dans le journal (règle, utilisateur, destination).

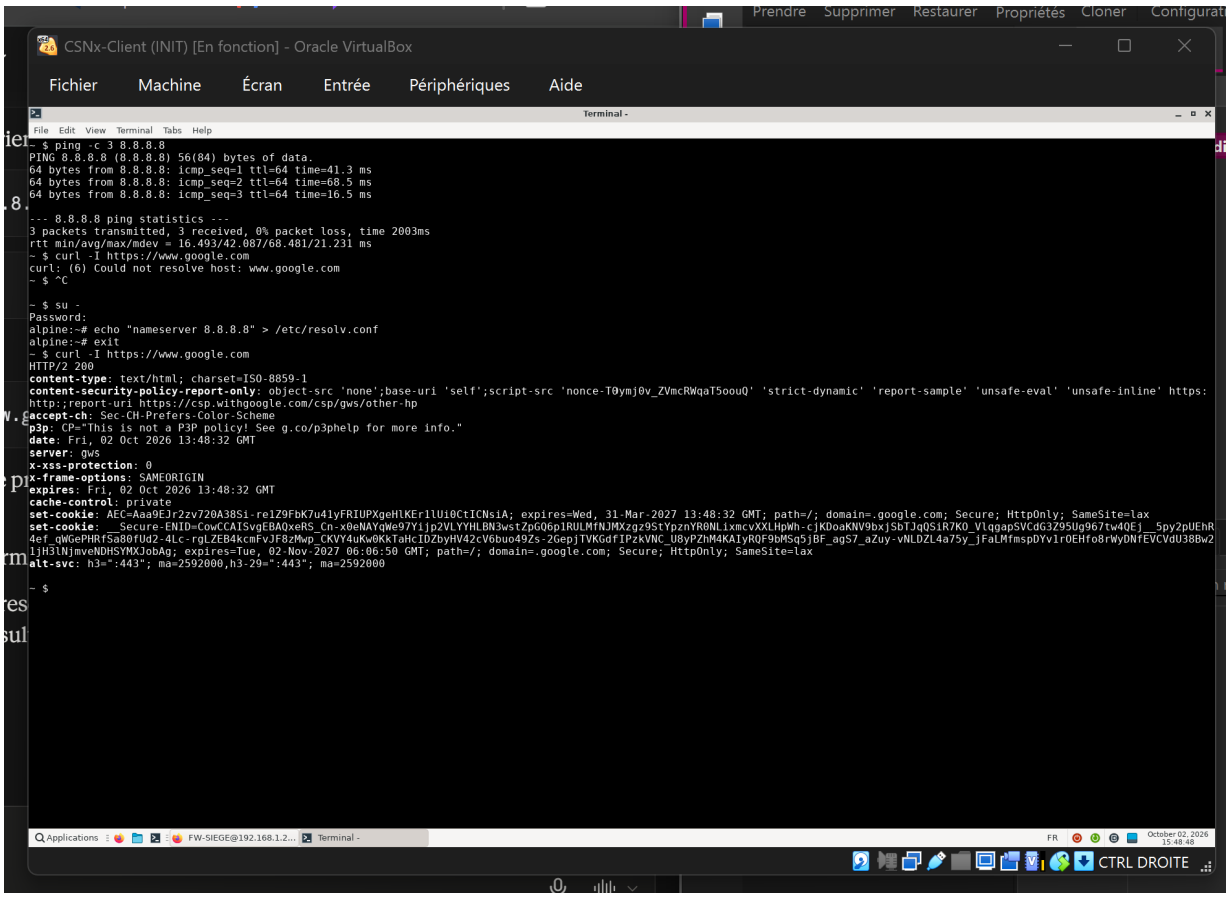
14.2 Tableau des tests

N°	Profil / origine	Scénario	Attendu	Obtenu	Capture
T01	Patient (Internet)	Portail en HTTPS (192.36.253.11)	Page du portail	Conforme	20
T02	Patient (Internet)	Portail en HTTP	Aucun service en clair	Conforme : bloqué ; le serveur redirige en 301	6b, 20
T03	Patient (Internet)	Espace professionnel sans authentification	Bloqué	Conforme	20, 38a
T04	Patient (Internet)	Accès direct aux adresses de la DMZ et du SI	Bloqué	Conforme	20, 21
T05	Médecin	Authentification sur le portail captif avec mot de passe + TOTP	Authentifié (session 4 h)	Conforme	35, 37
T06	Médecin	Espace professionnel après authentification	Accessible en HTTPS	Conforme	36
T07	Médecin	Espace professionnel après déconnexion	Bloqué	Conforme	38a
T08	Commercial (Internet)	Authentification sur le portail public	Refusée	Conforme : « Access denied »	38b
T09	Médecin	Ouverture d'un tunnel VPN	Aucun droit VPN	Conforme par configuration (défaut Block)	49b
T10	LAN siège	Navigation HTTP / HTTPS	Autorisée	Conforme	19, 23
T11	LAN siège	Bureautique en HTTPS	Autorisée	Conforme	23
T12	LAN siège	Ping, SSH vers Internet, compta, base PROD, DEMO	Bloqués	Conforme	23
T13	DMZ (web-prod)	Base PROD sur le port 5432	Autorisée	Conforme	24
T14	DMZ (web-prod)	CRM, Internet	Bloqués	Conforme	24, 21
T15	DEMO (web-demo)	Portail PROD, base PROD, Internet	Bloqués	Conforme	25
T16	SRV (srv-interne)	Connexion vers Internet	Bloquée	Conforme	26
T17	Site 2	Navigation par son propre accès Internet	Autorisée	Conforme	40, 91
T18	Site 2	Établissement du tunnel IPsec	SA IKE et IPsec actives	Conforme : AES-256, PFS 28	47
T19	Site 2	Bureautique du siège par IPsec	Autorisée	Conforme	46, 91
T20	Site 2	Comptabilité et base PROD du siège	Bloquées	Conforme	46, 91
T21	Comptable (VPN)	Ouverture du tunnel, routes reçues	Tunnel établi, routes SRV et DEMO seulement	Conforme	54
T22	Comptable (VPN)	Comptabilité	Autorisée	Conforme	55, 58
T23	Comptable (VPN)	CRM, bureautique, base PROD, DEMO, PROD	Bloqués	Conforme	55, 58
T24	Commercial (VPN)	CRM et DEMO	Autorisés	Conforme	56, 58
T25	Commercial (VPN)	Comptabilité, bureautique, base PROD, PROD	Bloqués	Conforme	56, 58
T26	Employé (VPN)	Bureautique, puis comptabilité, CRM et DEMO	Bureautique seule	Conforme	96, 99
T27	Support (VPN)	Applications de support, puis comptabilité et ressources techniques	Support seul	Conforme	97, 99

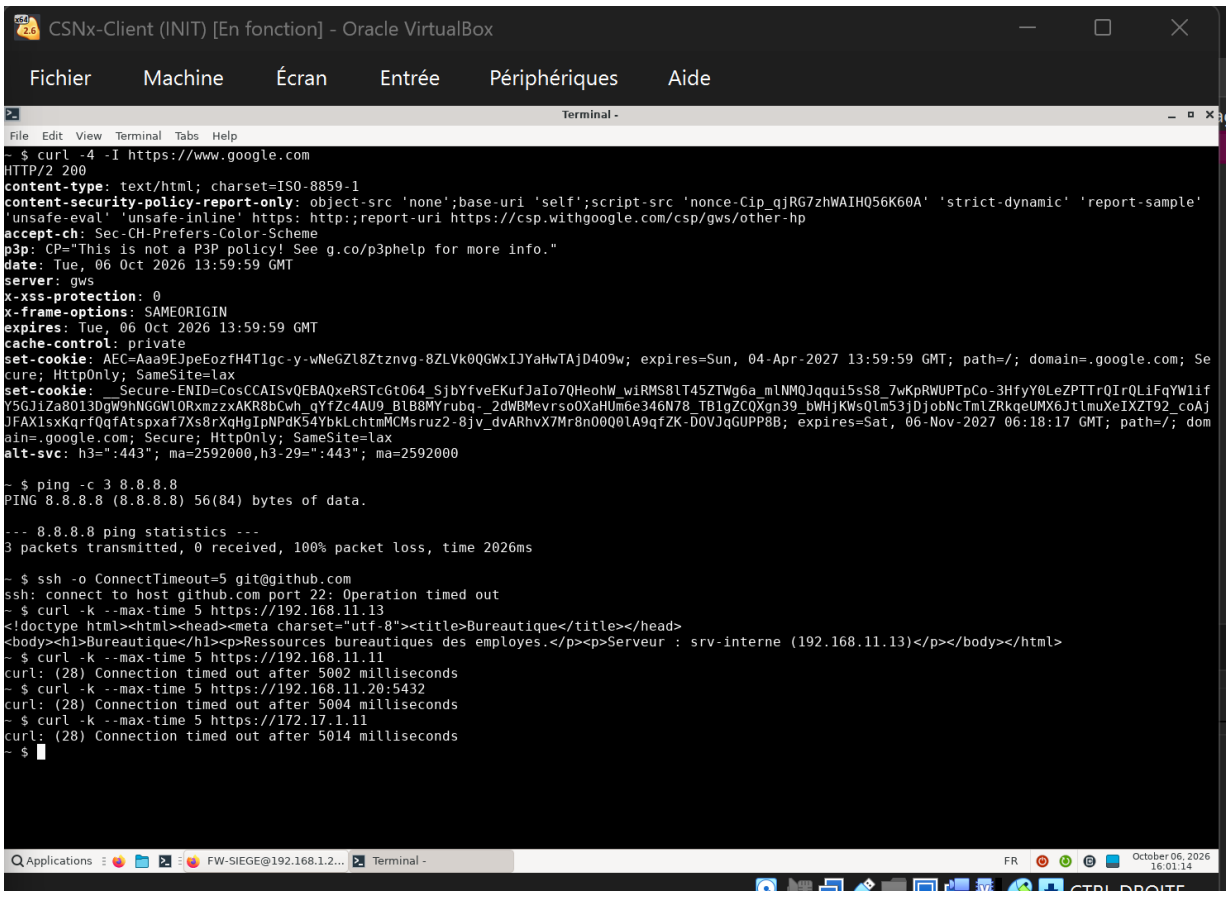
N°	Profil / origine	Scénario	Attendu	Obtenu	Capture
T28	Informaticien (VPN)	Ressources techniques, puis comptabilité et support	Ressources techniques seules	Conforme	98, 99
T29	Internet	SSH et interface d'administration du pare-feu	Refusés	Conforme : délai dépassé, 403	65b
T30	LAN siège	SSH et interface d'administration du pare-feu	Refusés	Conforme après désactivation de la règle implicite	63, 65b
T31	Zone ADMIN	SSH et interface d'administration	Autorisés	Conforme	61, 64
T32	Informaticien	Connexion à l'administration	Lecture seule	Conforme : READING	67
T33	Administrateur	Connexion à l'administration	Écriture	Conforme : WRITING	68
T34	Administrateur (VPN)	VPN, puis bastion, puis pare-feu	Autorisé	Conforme	71, 73
T35	Comptable (VPN)	SSH vers le bastion	Bloqué	Conforme	72, 88
T36	LAN siège	Site de la liste noire en HTTP	Page de blocage	Conforme après correction de syntaxe	80, 81
T37	LAN siège	Facebook en HTTPS	Bloqué	Conforme	80, 82
T38	LAN siège	Google en HTTPS, certificat reçu	Autorisé, certificat d'origine	Conforme : Google Trust Services	80
T39	Trafic DNS	Anomalie de protocole	Bloquée par l'IPS	Conforme	74
T40	Internet	Portail après activation des protections anti-DoS	Toujours accessible	Conforme (non-régression)	—
T41	Zone ADMIN	Connexion SSH d'administration	Alarme mineure	Conforme	87b
T42	Comptable (VPN)	Tentative vers la zone ADMIN	Blocage + alarme majeure	Partiel : bloqué et tracé, alarme non remontée	88, D6
T43	Administrateur	Ouverture de l'accès aux données privées	Accès tracé	Conforme	84, 86
T44	LAN site 2	SSH vers FW-SITE2	Refusé	Conforme	92

14.3 Bilan des tests

42 tests sur 44 sont conformes, un est conforme par configuration (T09, absence de droit VPN des médecins) et **un est partiel** (T42 : la tentative est bloquée et tracée, mais l'alarme majeure n'apparaît pas). Deux tests ont d'abord échoué et ont conduit à une **correction** : l'accès SSH depuis le LAN (règle implicite, T30) et le filtrage d'URL (syntaxe, T36). Ces échecs montrent l'intérêt des tests négatifs et de la vérification systématique dans les journaux.



Capture 19 — Sortie Internet du LAN (ping et HTTPS)



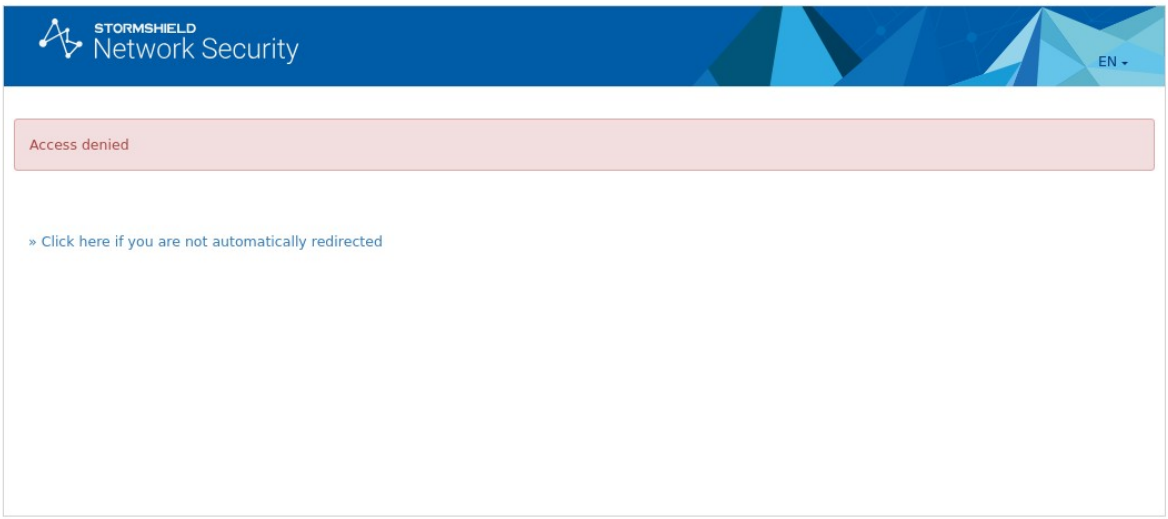
Capture 23 — Tests depuis le LAN : web et bureautique autorisés ; ping, SSH, comptabilité, base PROD et DEMO bloqués

```
~ $ curl -k --max-time 5 https://192.36.253.12
<!doctype html><html><head><meta charset="utf-8"><title>MediConnect - Espace pro
fessionnels de sante</title></head>
<body><h1>MediConnect - Espace professionnels de sante</h1><p>Acces reserve aux
medecins authentifies (PRODUCTION).</p><p>Serveur : web-prod (172.16.1.12)</p></
body></html>
~ $
```

Capture 36 — Espace professionnel accessible après authentification du médecin

```
~ $ curl -k --max-time 5 https://192.36.253.12
curl: (28) Connection timed out after 5011 milliseconds
```

Capture 38a — Espace professionnel de nouveau bloqué après déconnexion



Capture 38b — Un commercial ne peut pas s'authentifier sur le portail public

```
~ $ curl -4 -I https://www.google.com
HTTP/2 200
content-type: text/html; charset=ISO-8859-1
content-security-policy-report-only: object-src 'none';base-uri 'self';script-src 'nonce-MytsqgY50eb06NFMqzYHIw' 'strict-dynamic' '
eport-sample' 'unsafe-eval' 'unsafe-inline' https: http:;report-uri https://csp.withgoogle.com/csp/gws/other-hp
accept-ch: Sec-CH-Prefers-Color-Scheme
p3p: CP="This is not a P3P policy! See g.co/p3phelp for more info."
date: Tue, 06 Oct 2026 16:29:25 GMT
server: gws
x-xss-protection: 0
x-frame-options: SAMEORIGIN
expires: Tue, 06 Oct 2026 16:29:25 GMT
cache-control: private
set-cookie: AEC=Aaa9EJqeBqipDAUJwLC_C65GUFaOSc0dUtHpVSlMSATN_udKtqGOjVX0UQ; expires=Sun, 04-Apr-2027 16:29:25 GMT; path=/; domain=.
oogle.com; Secure; HttpOnly; SameSite=lax
set-cookie: __Secure-ENID=Co0CCAISvwEBAQxeReMW1qCYw5KvZa177UNjKQg8XzAeDTl67dFk_Qhx79RR60SnYWYbPB9BkbCOBMnw6Y5kYRyVu7iqvZOG8aLphndOE
Xn45zzq8-qYkOLvCSyZwsKWb5Y5OMMb0KbbTtTHwliQsljtfVCDeXCA1JdrsYloAbcyNHvORzCYaeVHW4BsJpL3H8UKJPApeWnxU7xGLsXWmBUi3b4-N4NqSf8Fw5H4dVBm
Pc_U7ad3qJiQ58rfIZO7wwzyAckigCMkUBfWzEqurRHmzCeoP0ZQW7D5MHo9EDGc0RQpwZZIk2bu-yl0UfoQsEToVSP24UJmZAZIt56610LOmKsabuBlBxQvu93Ao; expi
es=Sat, 06-Nov-2027 08:47:43 GMT; path=/; domain=.google.com; Secure; HttpOnly; SameSite=lax
alt-svc: h3=":443"; ma=2592000,h3-29=":443"; ma=2592000
```

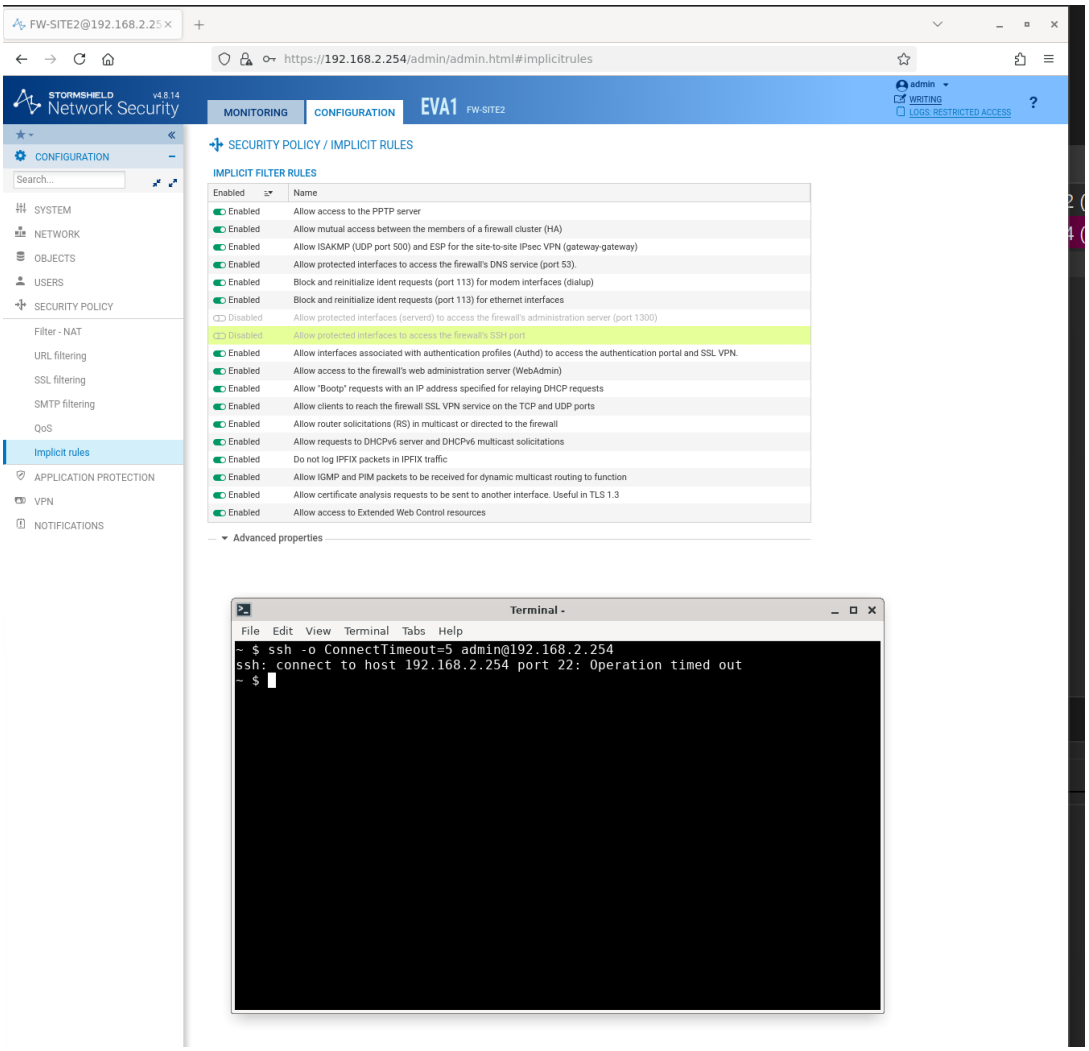
Capture 40 — Site 2 : sortie Internet par sa propre connexion

```
~ $ curl -k --max-time 10 https://192.168.11.13
<!doctype html><html><head><meta charset="utf-8"><title>Bureautique</title></head>
<body><h1>Bureautique</h1><p>Ressources bureautiques des employes.</p><p>Serveur : srv-interne (192.168.11.13)</p></body></html>
~ $ curl -k --max-time 5 https://192.168.11.11
curl: (28) Connection timed out after 5002 milliseconds
~ $ curl -k --max-time 5 https://192.168.11.20:5432
curl: (28) Connection timed out after 5004 milliseconds
~ $
```

Capture 46 — Tests à travers le tunnel IPsec (étape 9)

```
Terminal -
File  Edit  View  Terminal  Tabs  Help
~ $ curl -k -s -o /dev/null -w "%{http_code}\n" --max-time 10 https://192.168.11.13
200
~ $ curl -k -s -o /dev/null -w "%{http_code}\n" --max-time 5 https://192.168.11.11
000
~ $ curl -s -o /dev/null -w "%{http_code}\n" --max-time 5 http://192.168.11.20:5432
000
~ $ curl -4 -s -o /dev/null -w "%{http_code}\n" --max-time 10 https://www.google.com
200
~ $
```

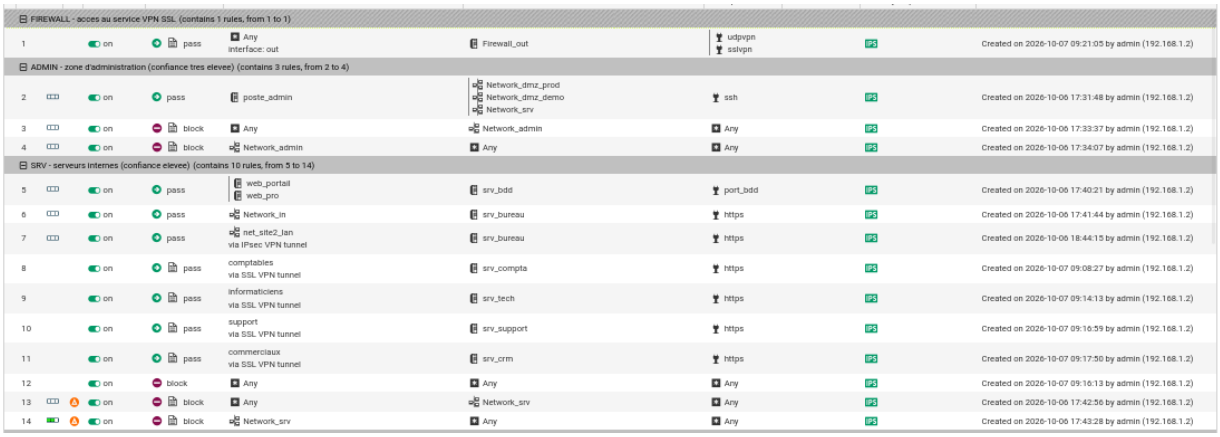
Capture 91 — Site 2, tests finaux : bureautique par IPsec ; comptabilité et base PROD bloquées ; Internet propre



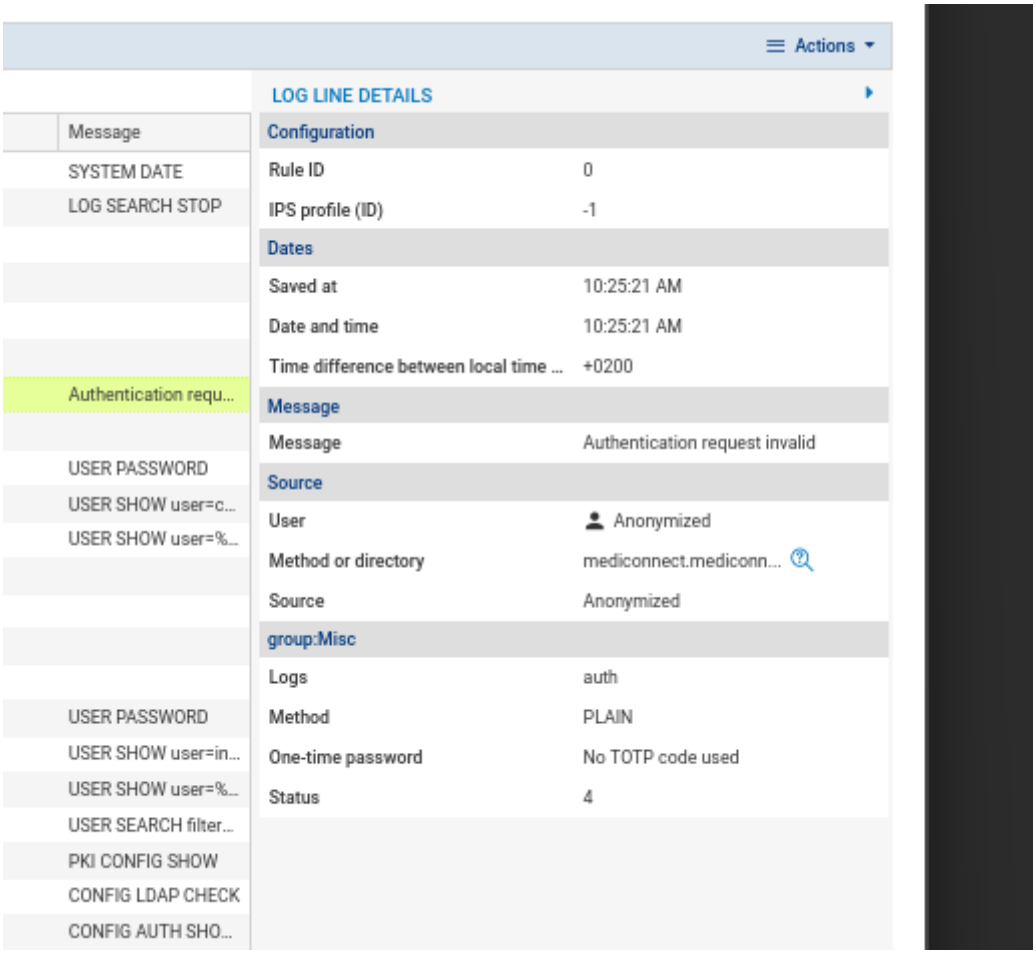
Capture 92 — FW-SITE2 : SSH implicite désactivé et refusé depuis le LAN du site 2

15. Difficultés rencontrées

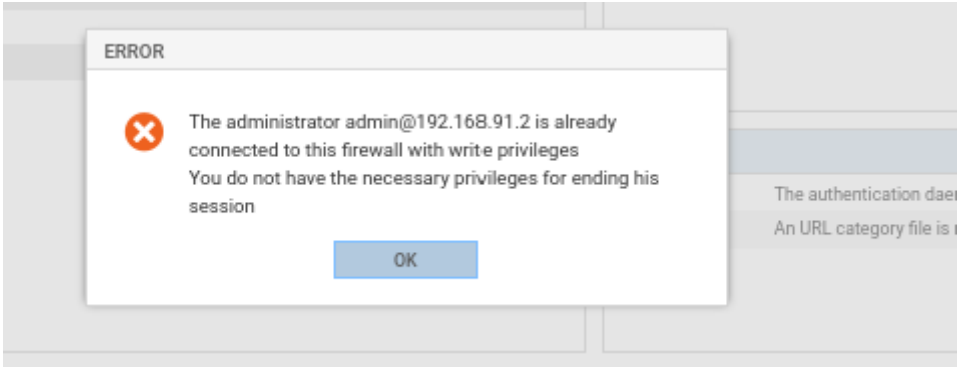
Étape	Difficulté	Cause identifiée	Résolution / enseignement
1	Plan à 6 zones avec un pare-feu à 4 cartes	Limite de l'interface graphique de VirtualBox	Cartes 5 et 6 ajoutées par VBoxManage ; SNS EVA1 les accepte (captures 1, 2).
2	VM fantôme et disque Alpine en conflit	Enregistrement incomplet dans VirtualBox	Désenregistrement (unregistervm) puis recréation.
2	Installation Alpine : clavier, DNS, masque refusé	Assistant en QWERTY, saisie de l'adresse avec /24	setup-keymap fr ; DNS ajouté ; adresse saisie sans masque.
3	Boutons d'administration grisés	Session en lecture (READING)	Repasser en écriture (WRITING).
3	Mot de passe refusé en SSH	Chiffres tapés sans Maj sur un clavier AZERTY	Vérifier le clavier avant toute saisie de secret.
6	Portail bloqué malgré une règle « pass »	SNS filtre avant la traduction d'adresse	Règle réécrite vers l'adresse publique pub_portail ; diagnostic grâce au journal de la règle finale.
7	Bloc ADMIN placé après un blocage total	Ordre des règles	Réordonnancement ; les triangles d'avertissement de SNS signalent les règles inaccessibles.
8	Médecin authentifié mais bloqué	Groupe saisi dans le mauvais champ de l'onglet Source	Groupe placé dans le champ User.
8	QR code TOTP perdu	Secret affiché une seule fois	Réinitialisation de l'enrôlement du compte.
10	Pare-feu injoignable depuis le client	Mauvaise VM câblée (CSNx-Client sur NatNetwork)	Diagnostic ARP (« Destination Host Unreachable ») puis VBoxManage showvminfo / controlvm.
10	Règle vide insérée au milieu de la politique	Une nouvelle règle vide vaut « block any »	Suppression ; toujours relire la politique avant d'appliquer (capture D1).
10	« bad password » pour des comptes valides	Comptes recréés à l'étape 8 avec un autre mot de passe	Mots de passe redéfinis ; cause lue dans le journal Users.
11	LAN capable d'ouvrir une session SSH sur le pare-feu	Règle implicite SSH ouverte aux interfaces protégées	Révélé par un test négatif ; règle désactivée et remplacée par une règle explicite.
11	Administrateurs nominatifs refusés	Aucune règle d'authentification pour l'interface admin (« Rule ID 0 »)	Règle ajoutée (capture D2).
11	Second administrateur bloqué en lecture	Un seul administrateur en écriture à la fois	Comportement normal, cité comme protection (capture D3).
11	Poste d'administration figé	Mémoire insuffisante (deux fenêtres Firefox)	Redémarrage de la VM ; une seule fenêtre de navigateur à la fois.
12	Filtrage SSL bloquant tout le HTTPS	Moteur de classification sans licence	Règle désactivée, remplacée par le blocage par service web (captures D4, 86).
12	Faux positif du filtrage d'URL	Entrée sans « /* », non conforme à la syntaxe	Détecté dans le journal Web ; entrées corrigées (capture D5).
12	TikTok absent du catalogue des services web	Catalogue fourni par l'éditeur	Facebook, Twitch et Instagram retenus ; objet FQDN possible.
13	Alarme majeure non remontée	Non déterminée (configuration vérifiée)	Documentée ; preuve conservée dans le journal Filter (capture D6).
14	Groupe « Employés » du sujet absent de la maquette	Oubli lors de la création des groupes	Détecté en relisant le rapport face au tableau de l'énoncé ; groupe, droit VPN et règle ajoutés puis testés (captures 93 à 96).
14	Droits du nouveau groupe inversés (portail SSL au lieu du VPN SSL)	Erreur de saisie dans la grille des droits	Repérée sur la capture avant le test et corrigée (capture 94).



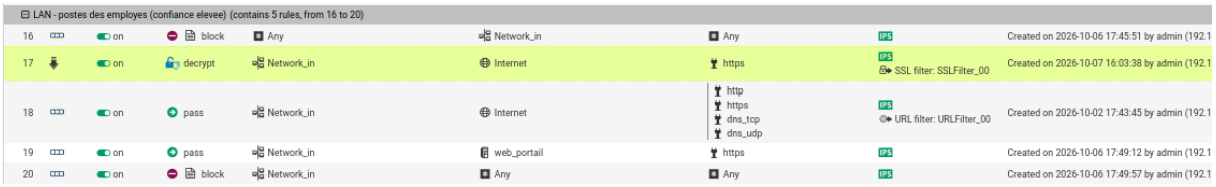
Capture D1 — Règle vide « block any » insérée par erreur : les triangles signalent les règles devenues inaccessibles



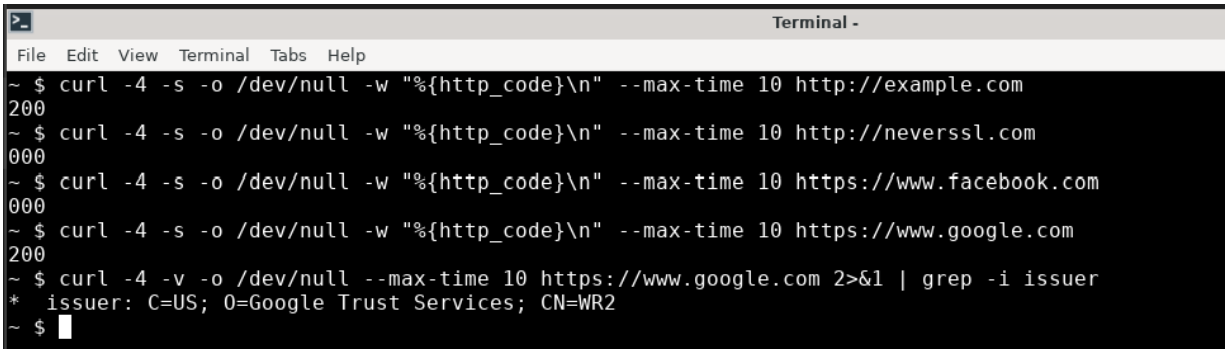
Capture D2 — Refus des administrateurs : « Authentication request invalid », Rule ID 0



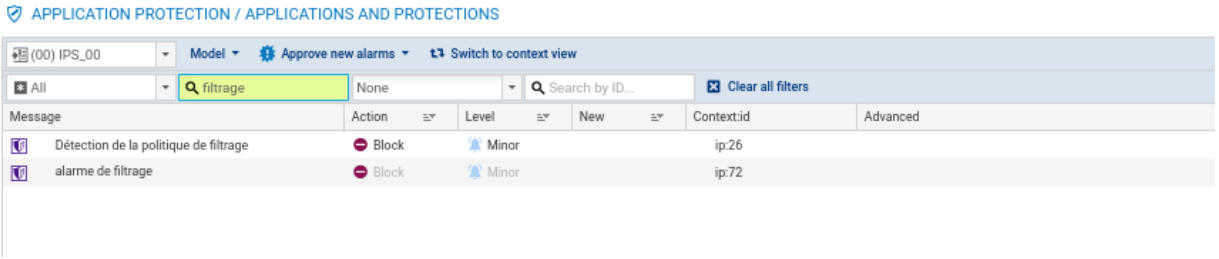
Capture D3 — Un seul administrateur peut être en écriture à la fois



Capture D4 — Règle « decrypt » activée pour le filtrage SSL : une fois appliquée, elle bloquait tout le HTTPS du LAN



Capture D5 — Premier test du filtrage d'URL : délai dépassé, mais requête autorisée dans le journal (faux positif)



Capture D6 — Réglage de l'alarme de filtrage identique dans les deux profils IPS

16. Limites de la solution et pistes d'amélioration

16.1 Limites de la maquette

Limite	Risque	Amélioration en production
Un seul pare-feu par site, sans redondance	Point unique de défaillance (le goulot d'étranglement devient critique)	Grappe haute disponibilité Stormshield (actif / passif)
Certificats auto-signés (serveurs, portail)	Avertissements, risque d'habituer l'utilisateur à les accepter	Certificats d'une autorité reconnue ; PKI interne pour les usages internes
IPsec authentifié par clé pré-partagée	Secret partagé, pas de révocation	Authentification par certificats
TOTP limité aux médecins	Mot de passe seul pour le VPN et l'administration	MFA pour tous les accès VPN et pour tous les administrateurs (priorité ANSSI)
Profil OpenVPN sans vérification explicite du rôle du certificat serveur	Risque théorique d'homme du milieu (avertissement du client)	Ajout de « remote-cert-tls server » au profil
Tunnel VPN partagé (split tunneling)	Poste du télétravailleur exposé à Internet pendant la session	Tunnel complet pour les profils sensibles ; contrôle de conformité du poste (ZTNA)
Licence de la VM : signatures IPS, catégories d'URL, antivirus et sandboxing non mis à jour	Détection limitée aux anomalies de protocole et aux listes manuelles	Licences de mise à jour, Extended Web Control, antivirus
Filtrage SSL désactivé	Pas d'inspection du contenu HTTPS	Filtrage SSL sous licence, sans déchiffrement des catégories sensibles (santé, banque)
Pas de relais applicatif devant le portail	Attaques applicatives (injection) vues seulement par l'IPS	Zone de relais ANSSI avec reverse proxy et pare-feu applicatif (WAF)
Base PROD dans la même zone que les autres serveurs internes	Un flux DMZ → SRV, même restreint	Zone dédiée aux données de santé (hébergement certifié HDS)
Journaux uniquement locaux ; alarme majeure non remontée	Effacement possible des traces ; détection incomplète	Syslog TLS vers un SIEM, conservation définie, corrélation, alertes par e-mail
FW-SITE2 administré depuis son LAN, compte local sur le bastion	Administration non séparée au site 2 ; comptes du bastion hors annuaire	Administration du site 2 par IPsec depuis le bastion du siège ; bastion relié à l'annuaire, avec enregistrement des sessions
Mots de passe de maquette simples et communs	Non représentatif de la production	Politique de mots de passe, coffre-fort de secrets
Pas de test de charge anti-DoS	Seuils non éprouvés	Tests de charge en environnement dédié ; protection anti-DDoS de l'opérateur
Internet simulé, IPv4 seulement, clients mutualisés, deux pare-feux issus de la même image (même numéro de série)	Maquette simplifiée	Déploiement réel, IPv6, équipements distincts
Support et commerciaux du site 2 : accès par VPN SSL non rejoué depuis le LAN du site 2	Le comportement est déduit du mécanisme démontré depuis Internet	Test dédié depuis le site 2 ; éventuelle extension du tunnel par sous-réseaux métier
Validateur : avertissement résiduel sur la règle 20	Aucun effet fonctionnel	Scinder la règle (HTTP avec filtrage d'URL, HTTPS et DNS sans)

16.2 Feuille de route proposée

1. **Court terme :** MFA pour le VPN et l'administration ; certificats signés ; « remote-cert-tls server » dans le profil VPN ; envoi des journaux vers un syslog.
2. **Moyen terme :** haute disponibilité des pare-feux ; licences de mise à jour (IPS, catégories d'URL, antivirus) ; reverse proxy avec WAF en zone relais devant le portail.
3. **Long terme :** SIEM et supervision 24 h/24 ; zone dédiée aux données de santé et hébergement HDS ; approche ZTNA pour les accès distants ; audits réguliers (scans de vulnérabilités, tests d'intrusion).

17. Conclusion

L'infrastructure réalisée répond à l'ensemble des objectifs du sujet. Les deux sites sont interconnectés par un tunnel IPsec chiffré, chacun avec son propre accès Internet. Les patients n'atteignent que le portail en HTTPS. Les médecins disposent d'un chemin distinct, protégé par une authentification à deux facteurs, sans aucun accès réseau aux serveurs internes. Les télétravailleurs et les commerciaux accèdent, par un VPN SSL, uniquement aux ressources de leur groupe. Les démonstrations se font sur une plateforme isolée de la production. L'administration est réservée à une zone dédiée et à un bastion. Enfin, tout ce qui n'est pas autorisé est bloqué et journalisé.

Au-delà de la configuration, le projet montre l'importance de la **méthode** : un niveau de confiance par zone, des règles ordonnées et commentées, l'interdiction par défaut, et surtout des **tests négatifs vérifiés dans les journaux**. Ce sont eux qui ont révélé les écarts invisibles autrement (la règle SSH implicite, le faux positif du filtrage d'URL, le comportement du proxy SSL sans licence).

Les limites identifiées (redondance, MFA généralisé, licences, journalisation centralisée, relais applicatif) tracent une feuille de route réaliste pour passer de la maquette à une production capable d'héberger des données de santé.

Annexe A — Objets et comptes

Objet	Type	Valeur	Usage
gw_internet	Machine	192.36.253.1	Passerelle par défaut (deux sites)
pub_portail	Machine	192.36.253.11	Adresse publique du portail patients
pub_pro	Machine	192.36.253.12	Adresse publique de l'espace médecins
fw_site2 / fw_siege	Machine	192.36.253.20 / .10	Correspondants IPsec
web_portail / web_pro	Machine	172.16.1.11 / .12	Serveurs de la DMZ-PROD
web_demo	Machine	172.17.1.11	Plateforme de démonstration
srv_crm, srv_compta, srv_support, srv_bureau, srv_tech	Machine	192.168.11.10 à .14	Applications internes
srv_bdd	Machine	192.168.11.20	Base PROD
port_bdd	Port	TCP 5432	Accès à la base (PostgreSQL)
poste_admin	Machine	192.168.91.2	Poste d'administration / bastion
net_site2_lan / net_siege_srv	Réseau	192.168.2.0/24 / 192.168.11.0/24	Sélecteurs IPsec
net_ssl_udp / net_ssl_tcp	Réseau	172.30.1.0/24 / 172.31.1.0/24	Clients VPN SSL
grp_vpn_ressources	Groupe	Network_srv, Network_dmz_demo, poste_admin	Réseaux annoncés aux clients VPN
mc_liste_noire_url	Catégorie d'URL	neverssl.com/*, *.neverssl.com/*	Filtrage d'URL
mc_liste_noire_cn	Catégorie de CN	*.facebook.com, facebook.com, *.tiktok.com, *.twitch.tv	Filtrage SSL (désactivé)

Compte	Groupe	Droits d'administration	Droit VPN SSL	Authentification
med.dupont	medecins	—	Non	Portail out, mot de passe + TOTP
comp.martin	comptables	—	Oui	VPN SSL
info.durand	informaticiens	Lecture seule	Oui	VPN SSL, interface admin
sup.bernard	support	—	Oui	VPN SSL
emp.roux	employes	—	Oui	VPN SSL
com.leroy	commerciaux	—	Oui	VPN SSL
adm.petit	administrateurs	Tous les droits	Oui	VPN SSL, interface admin, bastion (compte admpetit)
admin	— (compte intégré)	Tous les droits	—	Compte de secours, depuis la zone ADMIN uniquement

Annexe B — Sauvegardes et instantanés

La configuration des pare-feux a été sauvegardée à la fin de chaque étape (SYSTEM ⇒ Maintenance ⇒ Backup), ce qui permet de revenir à un état connu et de documenter l'évolution de la configuration :

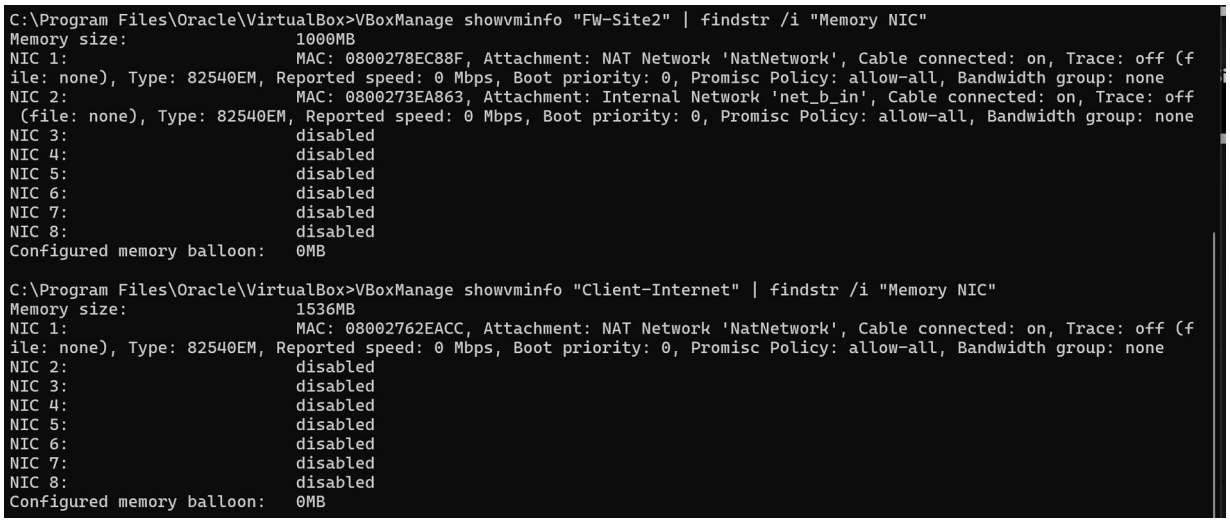
- **FW-SIEGE :** etape3A, etape3, etape6, etape7, etape8, etape9, etape10, etape11, etape12, etape13, final, final2 (après l'ajout du groupe employes) ;
- **FW-SITE2 :** etape4, etape9A, etape9, final ;
- **Instantanés VirtualBox** pris machines éteintes (arrêt ACPI) aux étapes clés : INIT, ETAPE1-6NIC, ETAPE2-ROLE (serveurs), ETAPE3-SOCLE, ETAPE4-SOCLE (site 2), ETAPE6-NAT, ETAPE11, **FINAL** pour les deux pare-feux et le poste d'administration, puis **FINAL2** pour FW-SIEGE.

Les fichiers de sauvegarde sont binaires et propres à SNS ; ils ne sont pas reproduits ici. La configuration finale est entièrement décrite par les tableaux de ce rapport et par les captures 89a, 89b, 17, 39a et 39b.

Annexe C — Captures complémentaires

Cette annexe regroupe les captures qui ne figurent pas dans le corps du rapport, afin que chacune des 99 captures numérotées soit présente une fois. La capture 90 n'existe pas : le NAT final est identique à la capture 17.

FW-Site2 est relié à Internet (NatNetwork) et au LAN du site 2 (net_b_in) ; Client-Internet (1,5 Go) est placé sur NatNetwork pour jouer les utilisateurs externes.



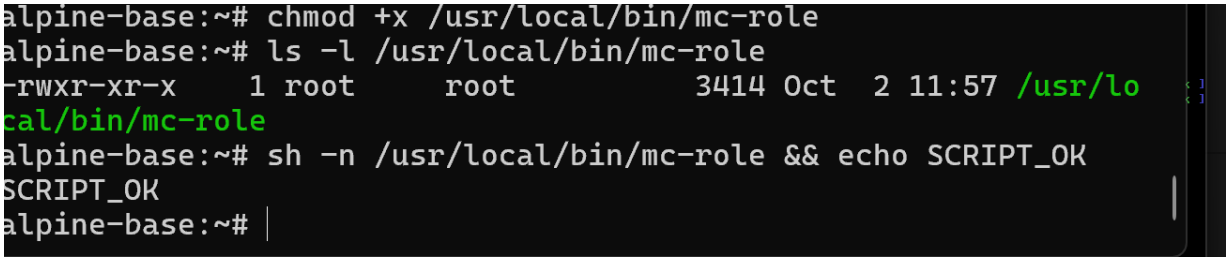
Capture 3 — Branchement de FW-Site2 et de Client-Internet

Le modèle Alpine (192.36.253.200) fait tourner nginx et dispose d'OpenSSL 3.5 pour générer les certificats HTTPS.



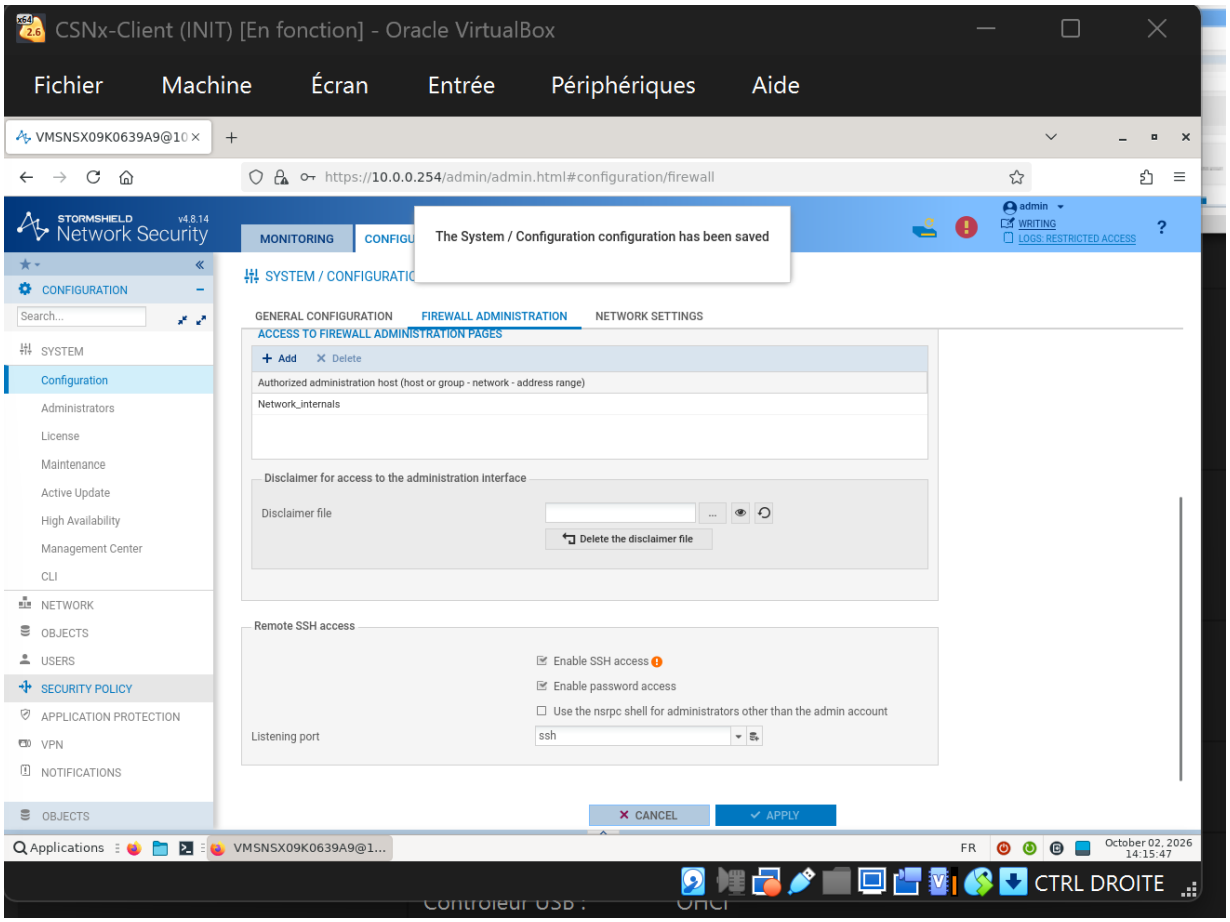
Capture 4 — VM Alpine de base : nginx démarré

Le script /usr/local/bin/mc-role configure chaque clone (adresses, nom, certificat, pages HTTPS) ; sa syntaxe est validée (SCRIPT_OK).



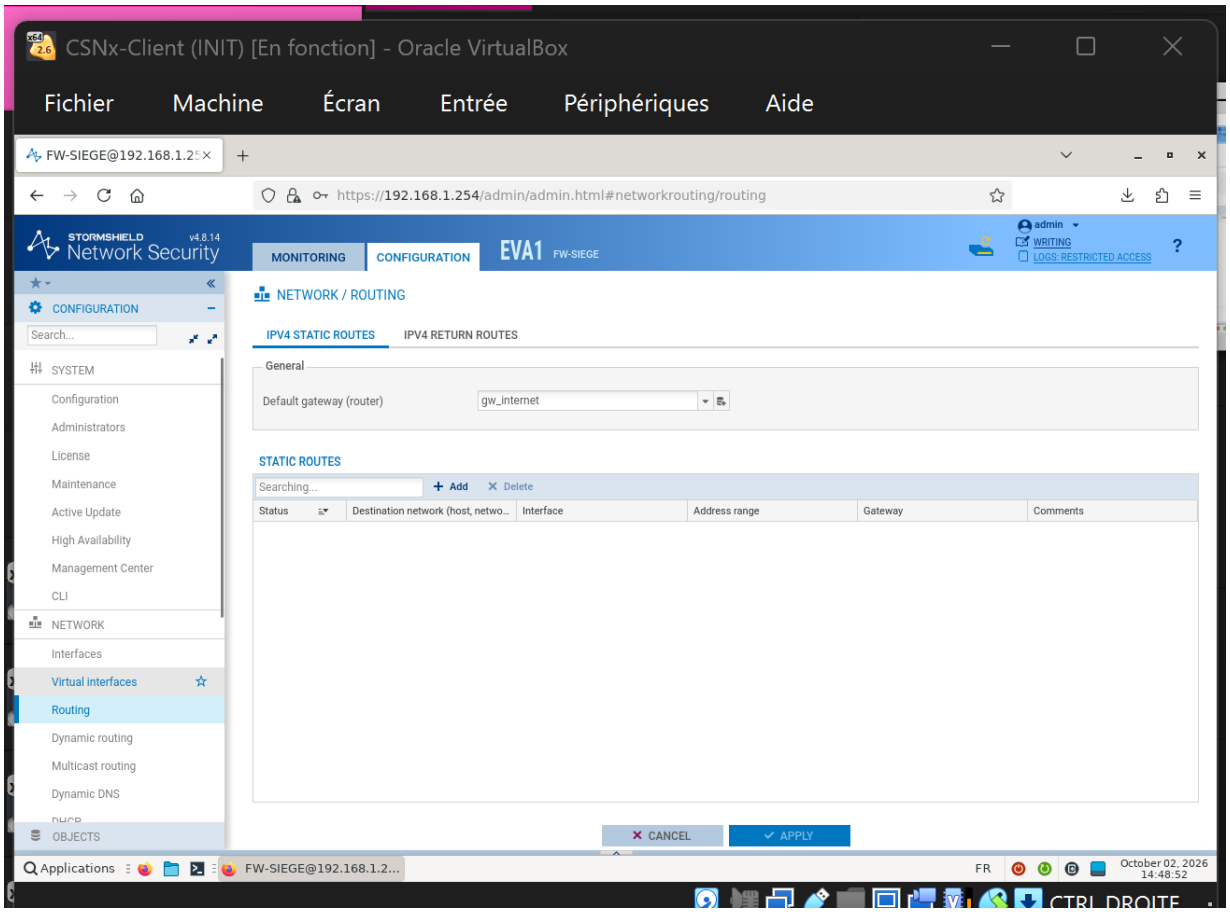
Capture 5 — Script de rôle mc-role validé

L'accès SSH par mot de passe est activé pour l'administration en ligne de commande ; il sera restreint à la zone ADMIN. Les hôtes autorisés sont encore Network_internals.



Capture 9 — SSH activé sur FW-SIEGE

La passerelle par défaut du siège est l'objet gw_internet (192.36.253.1).



Capture 13 — Passerelle par défaut

Session SSH sur FW-SIEGE : la passerelle et Internet (8.8.8.8) répondent sans perte.

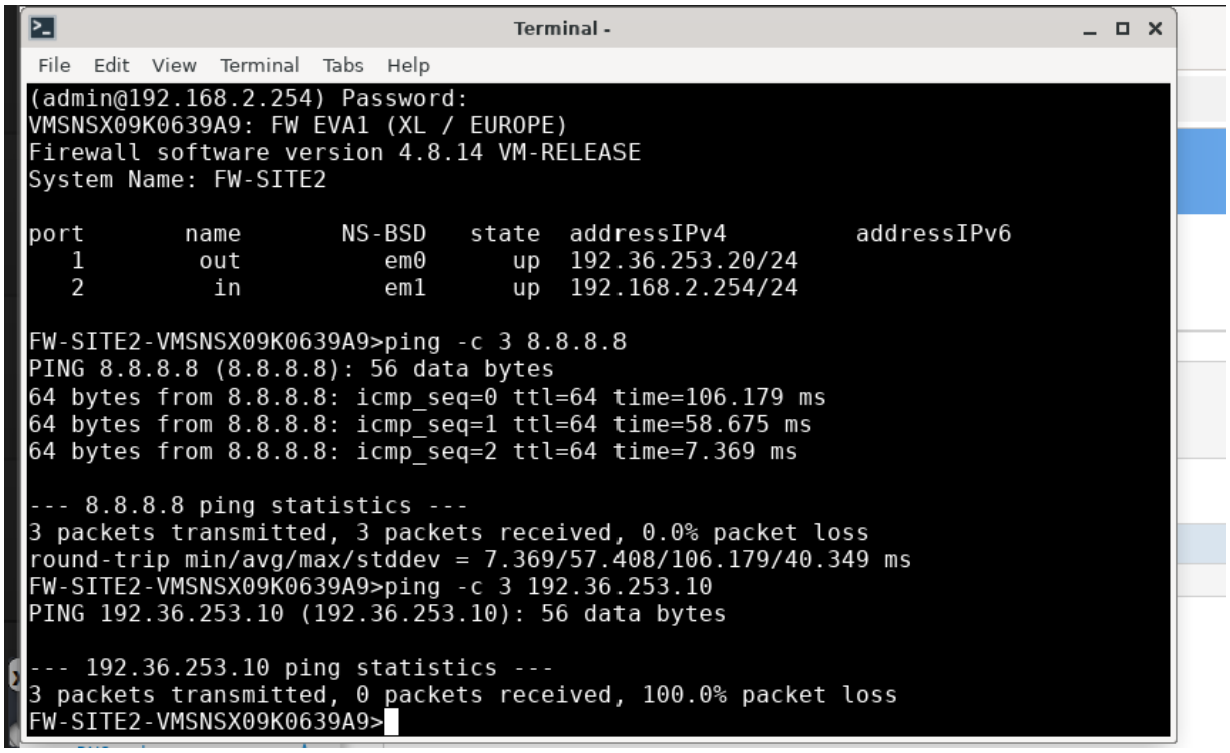
```
FW-SIEGE-VMSNSX09K0639A9>ping -c 3 192.36.253.1
PING 192.36.253.1 (192.36.253.1): 56 data bytes
64 bytes from 192.36.253.1: icmp_seq=0 ttl=64 time=52.527 ms
64 bytes from 192.36.253.1: icmp_seq=1 ttl=64 time=61.211 ms
64 bytes from 192.36.253.1: icmp_seq=2 ttl=64 time=43.767 ms

--- 192.36.253.1 ping statistics ---
3 packets transmitted, 3 packets received, 0.0% packet loss
round-trip min/avg/max/stddev = 43.767/52.502/61.211/7.122 ms
FW-SIEGE-VMSNSX09K0639A9>ping -c 3 8.8.8.8
PING 8.8.8.8 (8.8.8.8): 56 data bytes
64 bytes from 8.8.8.8: icmp_seq=0 ttl=64 time=54.322 ms
64 bytes from 8.8.8.8: icmp_seq=1 ttl=64 time=68.985 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=64 time=56.135 ms

--- 8.8.8.8 ping statistics ---
3 packets transmitted, 3 packets received, 0.0% packet loss
round-trip min/avg/max/stddev = 54.322/59.814/68.985/6.527 ms
FW-SIEGE-VMSNSX09K0639A9>
```

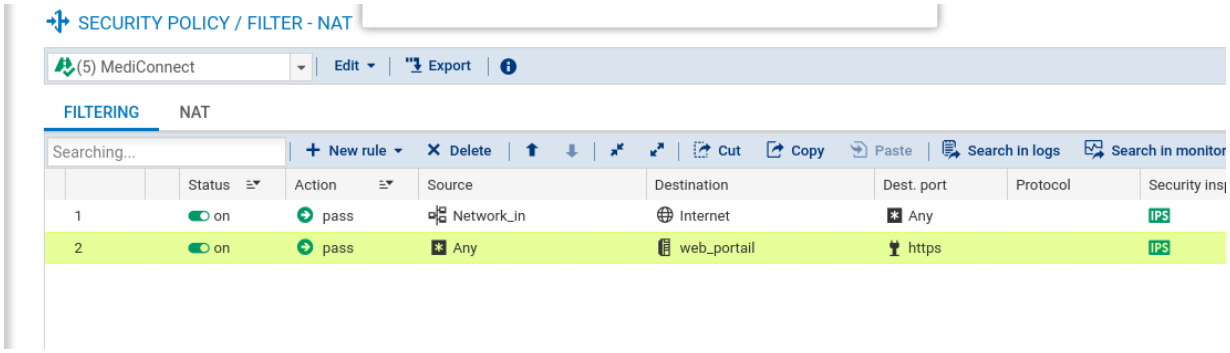
Capture 14 — SSH sur le firewall et accès à Internet

Le site 2 joint Internet par sa propre connexion. Le ping vers le siège échoue car FW-SIEGE était éteint.



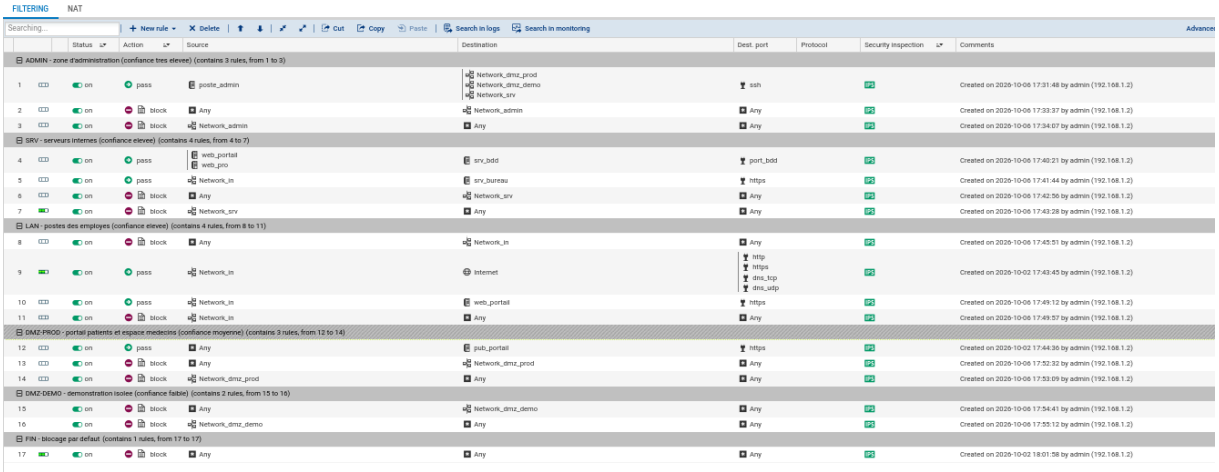
Capture 16 — FW-SITE2 : accès Internet indépendant

Deux règles pass pour tester le NAT, avec inspection IPS active.



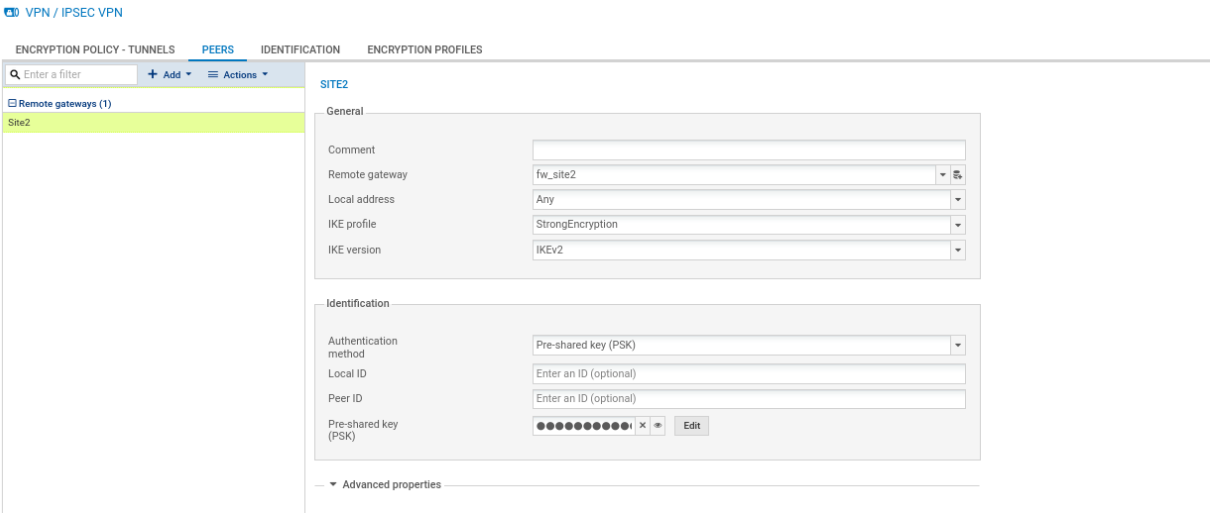
Capture 18 — Premières règles de filtrage

Six blocs du plus sûr au moins sûr (ADMIN, SRV, LAN, DMZ-PROD, DMZ-DEMO, FIN) : autorisations explicites puis interdictions journalisées, blocage total final.



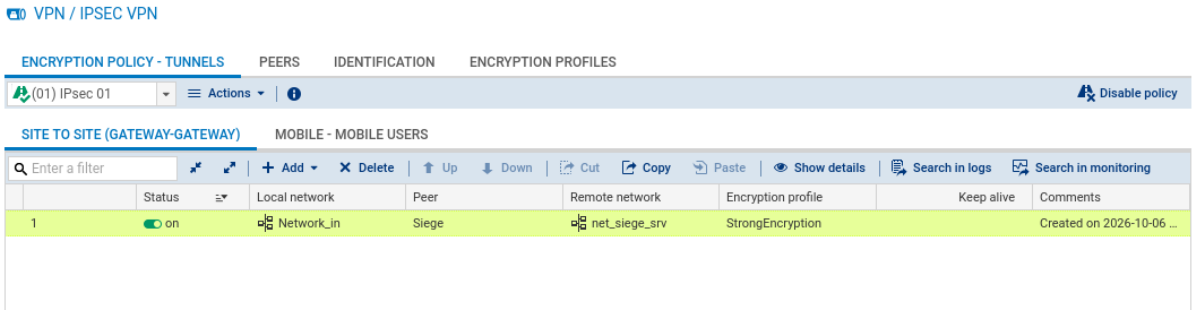
Capture 22 — Politique de filtrage complète par zones

Passerelle fw_site2, IKEv2, profil IKE StrongEncryption, clé pré-partagée masquée.



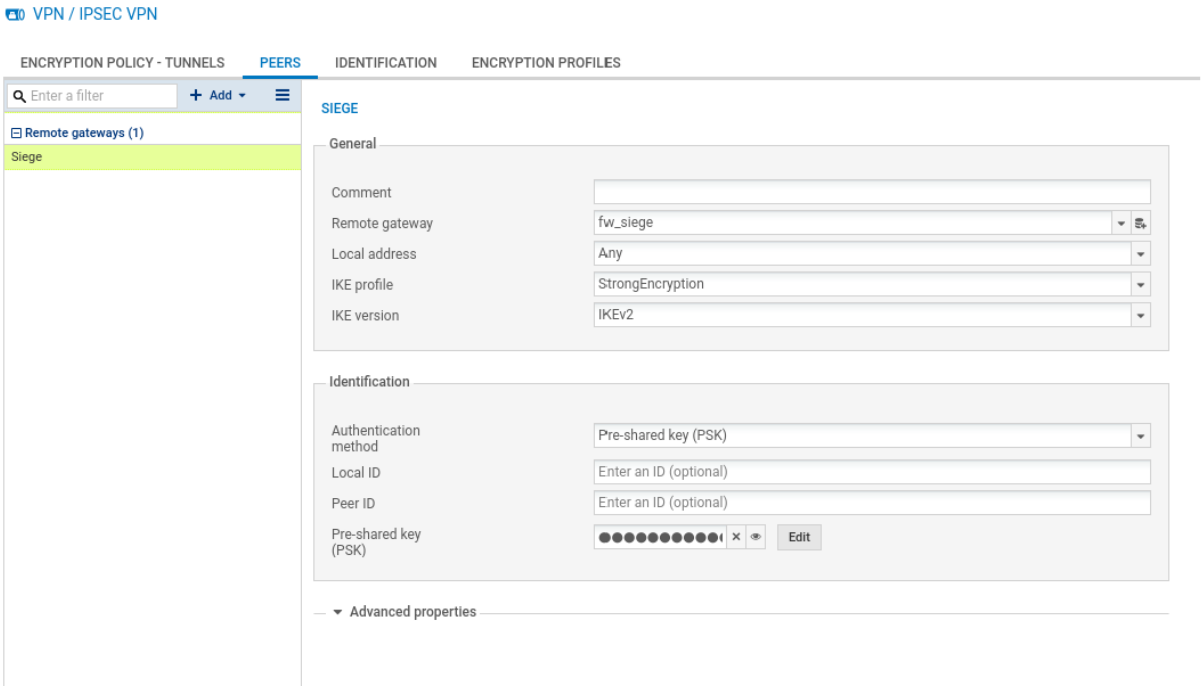
Capture 42 — Correspondant Site2

Configuration miroir : Network_in ↔ Siege ↔ net_siege_srv, StrongEncryption.



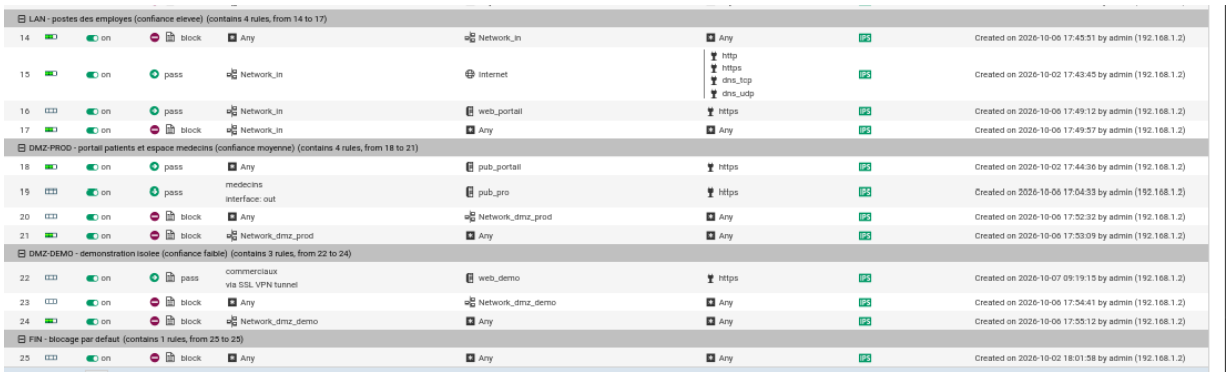
Capture 43 — Tunnel IPsec côté site 2

Passerelle fw_siege, IKEv2, StrongEncryption, clé pré-partagée.



Capture 44 — Correspondant Siege

Blocs LAN, DMZ-PROD, DMZ-DEMO (commerciaux → DEMO via VPN) et blocage final.



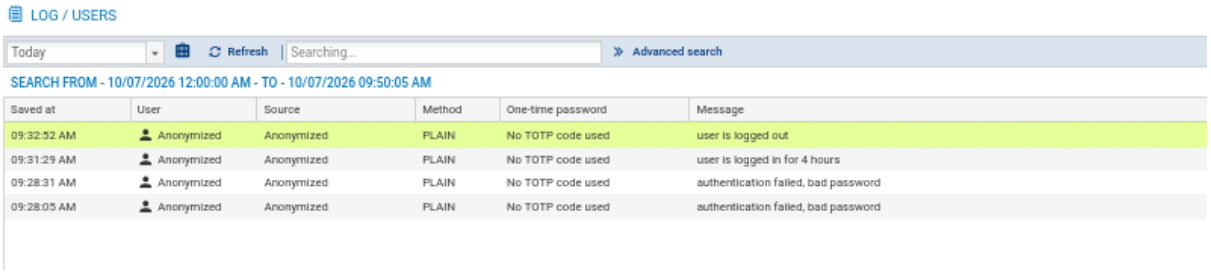
Capture 51b — Politique de filtrage (bas)

Le profil openvpn_mobile_client.ovpn est présent ; Client-Internet voit le portail patients comme un patient.

```
~ $ ls ~/Downloads
FW-SITE2-etape9  FW-SITE2-etape9A  openvpn_mobile_client.ovpn  proxyauthority.crt
~ $ curl -k --max-time 5 https://192.36.253.11
<!doctype html><html><head><meta charset="utf-8"><title>MediConnect - Portail patients</title></head>
<body><h1>MediConnect - Portail patients</h1><p>Recherche de praticiens et prise de rendez-vous (PRODUCTION).</p><p>Serveur : web-pr
od (172.16.1.11)</p></body></html>
~ $
```

Capture 53 — Profil .ovpn récupéré, retour sur Internet

Deux échecs « bad password » tracés, puis connexion de comp.martin pour récupérer son profil VPN.



Capture 59 — Journal Users : connexions au portail